

AUDITORÍA INFORMÁTICA

Un enfoque práctico

2ª EDICIÓN AMPLIADA Y REVISADA



Mario G. Piattini
Emilio del Peso

Alfaomega  Ra-Ma®

Auditoría Informática

Un enfoque práctico

2.ª edición ampliada y revisada

Coordinadores

Mario Gerardo Piattini Velthuis
Universidad de Casilla-La Mancha

Emilio del Peso Navarro
IEE Informáticos Europeos Experto«

Auditoria Inbumilea I ncn!<yx ptittKo. 2» **OHIO « f linlj >i oi w li**
© Mano Geraido f*Lituri Velthuit >Umilio Jet Peto Navarro

ISBN K4-7X97-M4-X. «JKI.W«rifinal puMeada RAMA Idilon.il,
MADRID. F.»pJAa Donhui icwvJJoi O RA-MA tidiloial

MARCAS COMERCIALES: RAMA ha ment*y> alolargode OK libro dMinguu
la» mite.» re*i«Uada» de Ri» I4ITilW>ÒCKIptivO*.tiyuens>el olilo dem.owwul.i'
Hoc uilli/j <LlabtKaMe.»in menciòa de minivpr U auro y «ilo <• hcnellii io del
propinarlo de Ij n t n u

0 »* 1 AI.FAOMKGA GRUFO F.DITOR, S.A. 4« C.V.
Pnifoeat I I.IV.Col. Del Valle.0M00 Mitico. D.F

Micmhiude U C k u u Naootul de li ladutliia F-dilori.il Mentana
Repuro No. JJIT

InieiiKi lifipy/»aw.air»omec«xonu>«
Fmail n M n I WiKumtia^iwLnI

ISBN: 970-15-07)1!

IVrwIw retcrvado».
t>u iINj o piopxdjd imelivluildcu auloi >lo»dcre»lande fuN* A iùo enlenirua
opjV'Ij h.m tido legalmente tramferidot al edito* PloftiNda tu teptodactKta pii
ivil o (ot*I pea cualfaaer m n k «in permito poi eterno dei profittino de lo» dero-
<ho» del eopyitfht

NOTA IMPORTANTE

L»»(ormaeKjn contcnxla en etla obra tiene «a lin etclutivameMe didfellco y.poi lo unto, no e-vUpievino tu afrovetamicMo j mvel pnrffettoaal ■indatirul li v.«*-iAHmci tevnii.it y piorijnu» laeluidot. lua udo elafaradi»»» eon («un euidado p* el JUIOI > reproducidoi bojo etinciat norma» de eonirol AI.IAOMWiA CRI PO EDITOR. S A. ile C.V. ■» ieri juriduaineaee re»poowblc poi ctrotet u orminone»; daftot yIVI)«KK»»>ue »e pudician allibali al n o de Li infomacidn comprendida en ette libro, ni pò» U uiliracita imkbidi <«pu*eiJ dirtele

Imprrùxi:

GemeSuo i EdUoril
Bojcci. D C . Coloratola

PREFACIO

Desde los inicios de la humanidad las distintas culturas, han dado una importancia enorme a los lemas de contabilidad, y por tanto también han necesitado de medios que permitieran verificar sus registros, es decir, de la auditoría. Desde entonces se piensa que la invención de la escritura surgió como respuesta a la necesidad de auditar. Flesher (1993): por lo que la de auditor sería una de las profesiones más antigua*.

Pero es realmente a partir de finales de 1800 cuando la auditoría financiera se extiende por el Reino Unido y Norteamérica, y se sientan las bases de las prácticas que conocemos en la actualidad.

A partir de 1950, la informática se convierte en una herramienta muy importante para las labores de auditoría financiera. Lo que permite llevar a cabo de forma rápida y precisa, operaciones que manualmente consumirían demasiados recursos. Empieza la denominada “auditoría con el computador”, que no puede considerarse verdadera auditoría informática, sino que utiliza el computador como herramienta del auditor financiero.

Sin embargo, al convertirse los sistemas de información de la empresa cada vez más dependientes de los computadores, surge la necesidad de verificar que los sistemas informáticos funcionan correctamente, empezando a finales de los años sesenta a descubrirse varios casos de fraude cometidos con ayuda del computador que hacen inviable seguir conformándose con la auditoría “alrededor del computador”. Surge así la necesidad de una nueva especialidad dentro de la auditoría, cuyo objetivo es precisamente verificar el funcionamiento correcto, eficaz y eficiente de la informática, en definitiva, la “auditoría del computador”.

En la actualidad nadie duda que la información se ha convertido en uno de los activos principales de la empresa*, que representa su principal ventaja estratégica

Las empresas invierten enormes cantidades de dinero y tiempo en la creación de sistemas de información que les ofrezcan la mayor productividad y calidad posibles. Es por eso que los temas relativos a la auditoría informática cobran cada vez más relevancia tanto a nivel internacional como nacional.

De esa importancia creciente de la información nace la necesidad de que el bien jurídico sea protegido por el derecho y aparezca regulado en el ordenamiento jurídico.

La entrada en vigor de la Ley Orgánica 15/1999 de 13 de diciembre de Protección de Datos de Carácter Personal; la Ley Orgánica 1/1995 de 23 de noviembre que aprueba el nuevo Código Penal, y por último el Texto Refundido de la Ley de Propiedad Intelectual aprobado por el Real Decreto Legislativo 1/1996 de 12 de abril así como una serie de normas específicas del sector establecen un marco jurídico de la informática que se viene denominando Nuevas Tecnologías de la Información.

El establecimiento de ese marco jurídico incide de forma imponente en la Auditoría Informática. Pues si antes comprobábamos que era imposible realizar una Auditoría de Cuentas si no se audita lo que comentan esas "cajas negras" que son los sistemas de información y que contienen todos los datos económicos de las organizaciones, ahora vemos que difícilmente se puede realizar una Auditoría Informática si no tenemos en cuenta el marco jurídico en que se sitúan esos sistemas informáticos.

Colaboran en el libro veintiocho autores, entre los que se encuentran profesores de universidad y profesionales de reconocido prestigio en el mundo de la auditoría informática, reuniendo algunos de ellos las dos cualidades, lo que aporta un gran valor añadido a la obra al ofrecer perspectivas y experiencias muy variadas sobre prácticamente todos los aspectos relacionados con la auditoría informática.

Los objetivos que nos hemos propuesto en esta obra son los siguientes:

- Presentar de forma clara y precisa los conceptos fundamentales de control interno y auditoría informática.
- Ofrecer un tratamiento sistemático de las técnicas y métodos del auditor informático.
- Dar a conocer los aspectos organizativos, jurídicos y deontológicos asociados a la auditoría informática.
- Exponer en profundidad las principales áreas de la auditoría informática: física, seguridad, desarrollo, mantenimiento, explotación, informática, calidad, redes, dirección, etc.
- Suministrar una visión global de la auditoría informática en diversos sectores: banca, sector aéreo, público. PYMES, etc.

- Proporcionar pautas y experiencias que ayuden al profesional informático en las tareas de auditoría.

En esta segunda edición del libro se han actualizado y corregido varios capítulos, incorporando otros nuevos, con el fin de ofrecer una panorámica actual y completa de este campo.

CONTENIDO

La obra está dividida en tres partes claramente diferenciadas:

Parte I: Introducción

En esta primera parte, que consta de siete capítulos, se examinan diversos conceptos fundamentales de la auditoría informática. En el primer capítulo se describe la utilización de la informática como herramienta del auditor financiero. Mientras que en el segundo capítulo ya empieza la auditoría informática propiamente dicha, analizándose su relación con el control interno, dedicándose el capítulo siguiente a exponer las principales metodologías de control interno, seguridad y auditoría informática.

El capítulo 4 trata de uno de los aspectos fundamentales de la auditoría y de cuya calidad depende realmente el éxito de la misma: el informe de auditoría. Otro aspecto esencial es la organización del departamento de auditoría informática que se analiza en el capítulo siguiente.

Esta parte finaliza con dos capítulos que se dedican a explorar sendos aspectos a los que no se les suele dedicar la extensión necesaria en los libros exigentes: el marco jurídico y la deontología del auditor informático, pero que nosotros estimamos imprescindibles en la formación de cualquier profesional que trabaje en esta área.

Parte II: Principales áreas de la auditoría informática

Los capítulos que configuran esta parte central del libro se dedican a analizar las diversas áreas a las que se aplica la auditoría informática. Así, se empieza en el capítulo 8 con la auditoría física, mientras que el capítulo siguiente se dedica a la auditoría de la ofimática, que cada día tiene un mayor peso en las empresas e instituciones; y el capítulo 10 a la auditoría de la dirección.

Los capítulos 11 al 13 se dedican a exponer las consideraciones de auditoría informática sobre tres áreas bastante relacionadas: explotación, desarrollo y mantenimiento; que se complementan con el contenido de los dos capítulos siguientes que abordan las bases de datos y la técnica de sistemas respectivamente.

Dos aspectos que cada día cobran más importancia dentro de la aplicación de las Tecnologías de la Información a las empresas, la calidad y la seguridad, son objeto de los capítulos 16- 17.

El capítulo 18 se dedica por completo a analizar la auditoría de redes, uno de los componentes* más importantes en un sistema de información, que está experimentando un cambio espectacular en la última década.

El capítulo siguiente se dedica a exponer los principales elementos* que deben examinarse a la hora de auditar las aplicaciones informáticas', mientras que el capítulo 21 profundiza en estos aspectos para las auditorías de los sistemas EIS/DSS y las aplicaciones de simulación.

Esta parte finaliza con un capítulo dedicado a la auditoría de los entornos informáticos desde el punto de vista jurídico, totalmente actualizado para esta segunda edición.

Parte III: Auditoría informática en diversos sectores

No queríamos dejar fuera de esta obra algunas consideraciones sobre la aplicación de la auditoría informática a diversos sectores económicos que sirviera para aglutinar de forma práctica los conceptos expuestos en la parte anterior.

Siguiendo esta filosofía, dedicamos el capítulo 22 a la auditoría informática en el sector bancario, mientras que el capítulo 23 analiza la auditoría informática en el sector transportes, específicamente el aéreo. Los capítulos 24 y 25 tratan sobre la auditoría informática en dos sectores muy importantes en nuestro país: la Administración Pública y las PYMES.

Parte IV: Otras cuestiones relacionadas con la auditoría informática

En esta segunda edición del libro se han incorporado dos nuevos capítulos que complementan a los anteriores tratando importantes cuestiones relacionadas con la auditoría informática. El capítulo 26 aborda la relación entre el peritaje y la auditoría informática, mientras que el capítulo 27 analiza el contrato de auditoría.

El libro finaliza con una amplia bibliografía que ha servido de referencia y que, en parte, también se ofrece como lecturas recomendadas en cada uno de los* capítulos. También hemos incluido en cada capítulo unas preguntas de repaso que pueden indicar al lector el grado de asimilación que ha alcanzado sobre la materia.

Por último se incluyen los acrónimos utilizados en el texto.

ORIENTACIÓN A LOS LECTORES

Aunque un conocimiento en profundidad de la técnica* y los temas de la auditoría informática puede estar reservado a los profesionales de la materia, nuestro propósito al editar esta obra ha sido dirigirnos a una audiencia mucho más amplia que comprende:

- Participantes en seminarios o cursos monográficos sobre auditoría informática, bien sean de introducción o más avanzados.
- Profesionales informáticos y economistas que estén trabajando en el área de auditoría, ya sea financiera o informática, y que deseen ampliar y perfeccionar sus conocimientos.
- Directivos que sean responsables de la gestión del departamento de sistemas de información, su desarrollo o explotación.
- Profesionales del Derecho que se encuentren trabajando en el campo informático.
- Estudiantes universitarios de la asignatura Auditoría informática. que afortunadamente se va incorporando actualmente en los planes de estudio de un mayor número de universidades.
- Consultores informáticos y usuarios avanzados que tengan interés en adquirir algunos conocimientos sobre auditoría informática.

Debido a la diversidad de la audiencia, el estudio de esta obra puede realizarse de maneras muy distintas*, dependiendo de la finalidad y conocimientos previos del lector, ya sea auditor o auditado.

Cada parte y cada capítulo pueden consultarse de manera autónoma sin tener que seguir el orden que se ha establecido.

AGRADECIMIENTOS

Queríamos expresar nuestro agradecimiento, en primer lugar, a los autores que colaboran en esta obra y que son sus verdaderos artífices. Sus conocimientos, experiencias y autoridad en el campo de la auditoría informática constituyen, sin lugar a dudas, una garantía de la calidad de su contenido.

Queremos agradecer a Rafael Rodríguez de Cora, antiguo presidente de la OAI (Organización de Auditoría Informática), el haber aceptado escribir el prólogo a la primera edición de esta obra, y a Marina Tosini Vo presidenta actual de la OAI por el prólogo a esta segunda edición, pues al igual que el resto de los miembros de la

OAI. ha sido durante varios años una fuente constante de aprendizaje y de intercambio de ideas, manteniendo encendida la llama de la auditoría informática en nuestro país.

Asimismo agradecemos a Miguel Recio Gayo su inestimable ayuda en la revisión de la obra.

Desde estas páginas queremos también agradecer a los lectores de la primera edición del libro por sus sugerencias y felicitaciones, ya que ellos han hecho posible la realización de esta segunda edición.

Mario Piattini quiere dejar testimonio de su reconocimiento a los distintos profesores que tuvo, ya hace varios años. en el Máster de Auditoría Informática dirigido por Carlos Manuel Fernández, organizado por la empresa CENE1. Ellos despertaron su interés por un área cada día más relevante dentro de la Informática.

Emilio del Peso quiere expresar particularmente su agradecimiento a todos aquellos que han confiado en él siendo el que menos sabe en esta materia: a su familia que siempre, de una forma u otra, colabora en todo aquello que hace, y especialmente a sus hijas Nuria y María del Mar. que han colaborado en la transcripción y corrección de esta obra.

Por último, nos resta dar las gracias a Ana M.ª Reyes por sus valiosas sugerencias que, como en otras muchas ocasiones, han contribuido a mejorar considerablemente este libro, así como a la empresa Albadalejo. S.L, que se encargó de la composición del mismo, y a la editorial Ra-Ma. especialmente a José Luis Ramírez, por su apoyo y confianza.

Mario Piattini
Emilio del Peso

María. OteferrXDO

PRÓLOGO A LA PRIMERA EDICIÓN

Tengo el gran placer de presentar *Auditoria Informática: Un enfoque práctico*, de los Editores Emilio del Peso y Mario Piattini. Me parece un libro extraordinariamente oportuno para la situación en que vivimos, desde el punto de vista tecnológico, de los negocios, y de la auditoría y seguridad informática, ya que aporta un enfoque ¡«abogado y completo».

Estamos inmersos en un profundo cambio de todo tipo que nos llevará al próximo siglo XXI. Las «empresas» y organizaciones dependen de los órdenes económicos, industriales, y sociales en los que se encuentran inmersas por lo que, si las tendencias tecnológicas y los entornos económicos e industriales cambian, deben adaptarse rápidamente a las nuevas circunstancias para sobrevivir. Una de las tendencias actuales más significativas es la que se dirige desde una Sociedad Industrial hacia la llamada Sociedad de Información.

Este cambio es muy rápido, está afectando al mundo entero, y su comprensión es fundamental para las organizaciones de todo tipo, particularmente en el contexto de los Sistemas y Tecnologías de Información. Aunque los avances tecnológicos de los últimos veinte años han sido constantes y espectaculares, en los últimos cinco años se ha producido una verdadera revolución tecnológica de gran calado «impacto para la propia industria informática, así como de consecuencias importantes para el resto de los sectores.

Cada vez un mayor número de organizaciones considera que la información y la tecnología asociada a ella representan sus activos más importantes. De igual modo que se exige para los otros activos de la empresa, los requerimientos de calidad, controles, seguridad e información, son indispensables. La gerencia debe establecer un sistema de control interno adecuado. Tal sistema debe soportar debidamente los procesos del negocio.

Haciéndose eco de estas tendencias. U propia Organización ISACA (Information Systems Audit and Control Avsociation). a través de su Fundación, publicó en diciembre de 1995 el CoNT (Control Objectives for Information and Relates! Technology). como consecuencia de cuatro aAos de intensa investigación y del trabajo de un gran equipo de expertos internacionales.

El marco del CobiT es la definición de estándares y conducta profesional para la gestión y el control de los Sistemas de Información, en todos sus aspectos, y unificando diferentes estindarev métodos de evaluación y controles anteriores. Adicionalmente, esta metodología apoda un factor diferencial enormemente importante: la orientación hacia el negocio. Está disertado no sólo para ser utilizado por usuarios y auditores, sino también como una extensa guía para gestionar los procesos de negocios.

Sin embargo, en términos generales, podemos decir que a pesar de los grandes adelantos tecnológicos, la situación actual de los Sistemas de Información en las Empresas y Organizaciones españolas se caracteriza frecuentemente por una falla de asimilación de las nuevas tecnologías, por una mfrautilización de los equipos informáticos, por un descontento generalizado de los usuarios, por una obsolescencia de las aplicaciones informáticas actuales, por una falta de planificación de los Sistemas de Información, y por soluciones planteadas parcialmente que. al no estar integradas, producen islotes de mecanización y de procesos manuales difíciles de controlar y caros de mantener. En definitiva, por una falta de estándares y metodologías, y por una falta de formación y cultura generalizada, sobre todo en los aspectos de control y de seguridad informática.

I-a Auditoría Informática ha aportado soluciones, en el pasado, para estos problemas; pero se ha realizado frecuentemente, hasta ahora, sólo en grandes empresas y. en la mayoría de los casos, como un complemento a la Auditoría Financiera.

Por diversas razones y por el mayor impacto que están adquiriendo las Tecnologías de Información en la empresa, esta disciplina está siendo cada vez más importante y su aplicación puede llevarse a cabo también en la PYME. La Auditoría Informática plantea unos métodos y procedimientos de control de los Sistemas de Información que son válidos para cualquier tamaAo de empresa.

Aquí es donde creo que este libro de *Auditoria Informática: Un enfoque práctico* es de una gran utilidad al presentar un compendio exhaustivo de los temas de más actualidad por los autores más cualificado» del sector.

Puede servir de base, por un lado, para llevar a cabo la cultura y formación sobre Auditoría Informática, a la que me refería anteriormente, desde un punto de vista técnico: por otro lado, toca otros temas de interés actual y práctico, desde el punto de vista del negocio y de la empresa, relativos a la organización, a la deontología. al marco jurídico, a la responsabilidad del empresario, y a la aplicación práctica de la Auditoría Informática en diversos sectores empresariales.

Es de destacar, y de agradecer, el subtítulo de *Un enfoque práctico*. La mayoría de Us publicaciones de Auditoría Informática se han escrito en otra» idiomas o han sido traducidas en Sudamérica. y eran manejadas y utilizadas por especialistas, pero no han calado suficientemente en "el público en general". Mucha« de ellas se han orientado hacia especialistas de Auditoría Informática para realizar su trabajo, lo que está también ampliamente descrito en él. pero entiendo que este libro además, tal como está planteado, supone ese acercamiento de la Auditoría a los empresarios. a los usuarios y a esc público en general.

La competencia global ya está aquí. Las empresas y organizaciones se deben reestructurar hacia operaciones cada vez mis competitivas y. cono consecuencia, deben aprovechar los avances de las tecnologías de los Sistemas de Información para mejorar su situación competitiva.

Hoy día hablamos de reingeniería de negocios y de procesos, d: calidad total, de procesos distribuidos, de organizaciones planas, de EIS/DSS. etc., om o cambios que generan un impacto en la manera en que operan las organizaciones privadas y públicas. Estos cambios están teniendo y continuarán teniendo implicaciones profundas para la gestión y para las estructuras de control en las organizaciones del mundo entero.

Entre las implicaciones de las tecnologías de información sobre la gestión empresarial no quiero desaprovechar la oportunidad para comentar el gran impacto, en I» empresas y organizaciones, que tendrá el efecto del cambio al *euro* y del problema del año 2000 en las aplicaciones actuales.

Esto será un ejemplo dramático de que la previsión, el control, la seguridad, y la reducción de costes, implicados en los Sistemas de Información mecanizados. pueden convertirse en una estrategia fundamental de las organizaciones. La automatización de Us funciones y procesos de la organización, por su propia naturaleza, genera una mayor dependencia de mecanismos de control en los computadores y redes desde el purco de vista del hardware y del software.

En este marco, de cambio acelerado, si los responsables van a estar a la altura de las circunstancias, es necesario que se pongan al día en cuanto a tecnología y entorno de la Auditoría Informática. Este libro, compilado por Emilio dtl Peso y Mario Piattini. puede ser fundamental para ello.

Desde las Organizaciones como la OAI. que nos dedicamos a difundir y a promooonar esta actividad, deseamos fervientemente que el libro tenga la divulgación que se merece y que efectivamente llegue a crear una "escuela" espióla, que se echa de menos en nuestro enlomo, para mentalizar a la Sociedad de la inportancia de exü disciplina.

por *Rafael hoJrigue; de Cora*

PRÓLOGO A LA SEGUNDA EDICIÓN

*Lo importante es mirar nuevamente
los trabajos en cuenta las obras ya existentes.
teniendo en cuenta sus leyes,
sus códigos semánticos
e interrelaciones.
Equipo Crónica*

Al releer este libro. *Auditoría Informática: un enfoque práctico*, entendí que iba a restillar una labor muy ardua poder añadir algún concepto de interés a los lectores ya en las páginas siguientes. Por esta razón, me he permitido un primer atrevimiento: esbozar algunas reflexiones propias sobre la Auditoría de Sistemas de Información, así como comentarnos sobre el contenido de esta obra.

El segundo atrevimiento es, en esta presentación, hablar de "Auditoría de Sistemas de Información" en vez de "auditoría informática". La primera denominación me he sustituyendo de alguna manera a la segunda. La expresión Auditoría de Sistemas de Información, que se está consolidando en todo el mundo, corresponde a la realidad y previsión actual del avance de las tecnologías. Actualmente el acento está en la información, siendo el elemento técnico un componente variado, diverso y cambiante, al servicio de la información. Este cambio también ha sido adoptado hace varios años por la Information Systems Audit and Control Association (ISACA) reflejándolo en el nombre para la asociación.

Volviendo la vista atrás, y tratando de explicarme, también a mí misma, qué aliente tiene ser un profesional de la Auditoría de Sistemas de Información, descubro que la principal atracción está en su aspecto "creativo". De ahí la elección, como prólogo, de una frase de un equipo de creadores que resume para mí una concepción aplicable a la actividad de la que hablamos: aprender de las obras de otros, con una

mirada nueva y actualizada, icner en cuerna los fundamentos h¿<*cos para el desarrollo de la profesión, establecer un lenguaje común de comunicación e integrad«* de todas las disciplinas o actividades que están relacionadas, y al mismo tiempo, investigar en nuevas direcciones. lista, es tal vez la ra/ón mis importante que me ha hecho permanecer en esta profesión.

la opción para esta permanencia engloba otro factor: la creciente consciencia del cometido social que puede desempeñar esta profesión. Ij tecnología caá cada día más presente en nuestras vidas, desde la doméstica y privada kasta la profesional, y frente a este imparable impulso tecnológico, la sociedad necesita tener una opinión objetiva c independiente sobre el margen de confianza que pued* tener en los sistemas de información.

Por lo tanto, sigo convencida de lo acertado de la decision cuando acepté en el aik> 1977 “cons'cftirme” en un auditor informático. Para mf. en ese momento en EspaAa era una profesión incipiente, aunque, en otros países tuviese ya mayoría de edad. Desde aquel entonces la Auditoría de Sistemas de Información ha experimentado en EspaAa. una notable expansión, hasta el punto de convertirse en un elemento clave con relación a fiabilidad de los servicios, usos y prestaciones de los sistemas informáticos y nuevas tecnologías.

Publicaciones como la presente son de vital importancia para la difusión de la actividad y utilidad de la Auditoría de Sistemas de Información, y además permiten, especialmente para aquellos que se inician en esta actividad, apoyarse en el camino ya recorrido por otros profesionales como punto de referencia.

La actividad profesional se basa en unas "buenas prácticas" consensuadas por los profesionales a través de sus asociaciones profesionales. Los auditores de sistemas de información deben ser los verdaderos protagonistas de establecer los fundamentos del ejercicio de su profesión de una forma coherente, meditada y atendiendo a kit avance* de la tecnología, así como a las necesidades de la sociedad a la cual se deben. Éste es uno de los objetivos de la Organización de Auditoría liiormática. capitulo de la ISACA. que en España, de forma pionera, fue fundada <n el arto 1987. Una asociación de este tipo, con la participación activa de sus integrantes, debería intentar mejorar, desarrollar, consolidar y armonizar la profesión, logrando el afianzamiento de las metodologías de Auditoría de Sistemas de Información.

Se trata de establecer unas bases sólidas que tienen qu: ver. principalmente, con el objetivo de la Auditoría de Sistemas de Información, el conocimiento de los elementos auditados y la capacidad para detectar riesgos. La Auditoría de Sistemas de Información, ul como se entiende en el ámbito internacional, en los colectivos de profesionales, no tiene como propósito esencial saber si un dete-minado control, tanto predeterminado como adecuado, se ha implantado simplemente, sino saber qué control o controles existen con la misma finalidad, qué objetivo y fin timen, cómo se realizan

y la eficacia tienen cu cuanto al cumplimiento. y qué nesgas existen aún para los sistemas de información, o bien qué perjuicios pueden causar indirectamente.

A partir de aquí, dada la diversidad de la tecnología y sus usm e implantación, se puede decir que no existe una verdad absoluta y taxativa sobre qué se considera buenos mecanismos de control, ya que ésto* son siempre el producto de una situación determinada, así como de su especificidad- Por eso los auditores de Sistemas de Información, a través de sus experiencias, colaboran para mejorar, consolidar y armonizar lis prácticas de esta profesión.

La mejora se obtendrá con una actitud innovadora y creativa de los profesionales que las comparten y contrastan para tratar de consolidar y armonizar un referente común tanto para los integrantes del colectivo como para l» usuarios de sus servicios.

En los últimos tiempos, la legislación relacionada con las tecnologías de la información y con el tratamiento de datos personales, alude a las auditorías sin darles un apellido determinado, ni una definición concreta Se entiende, dado el elemento auditado y los resultados que se le pide a esa auditoría, que debería tratarse de una Auditoría de Sistemas de información. Tampoco esta actividad estf definida en los diccionarios, incluyendo el de la Lengua Española l-a más cerca-ia es la auditoría contable, o la de auditor, que no cooperan al esclarecimiento de la pofesión. sino que al contrario, es posible que confundan aún más. Sin embargo, se desprende de todas ellas, a mi entender, la idea de la independencia u objetividad del auditor, así como la necesidad de un trabajo profesional claramente definido.

A modo de ilustración sobre kxs principios de la actividac. se incluyen dos manifestaciones de la ISACA: "Los objetivos de la Auditoría de Sistemas de Información deben brinda» a la Dirección de una seguridad razonabl que los controles se cumplen, fundamentar los riesgos resultantes donde existan debilidades significativas de control y aconsejar a La Dirección sobre accione* correctivas": así como "la realización de una Auditoría de Sistemas de Información implica la evaluación y emisión de una opinión objetiva e independiente, y de recomendaciones sobre la fiabilidad de un sistema de información".

La Auditoría de Sistemas de Información, dada su relación intrínseca con las tecnologías de la información, con las entidades y organizaciones que utilizan estas tecnologías, y con lon usuarios en general, mantiene necesariameate mtenciones con otras disciplinas o actividades profesionales, con las que comparten proyectos aunque, con distintas metas, áreas de actuación y responsabilidades.

De hecho, la profesión se ha nutndo y se nutre de experto provenientes de distintas disciplinas afines. Los requisitos esenciales para realzar este tipo de actividad son: conocimientos sólidos de auditoría, así como conocmiento* técnicos y entrenamiento permanente en las nuevas tecnologías. Esta situación, dados los avances

de la tecnología. está llevando a lo« auditores de sistem» de información a especializarte en determinadas áreas o entorno« tecnológico«. La realidad seAala que lo« equipos de Auditoría de Sistemas de Información de las entidades de dimensión importante están formados por profesionales multidisciplinares.

El presente libro *Auditoria Informática: un tnfoqtc práctico*, incluye acertadamente este aspecto de las interrelaciones, desde la utilización de la informática o herramientas tecnológicas, en concreto con respecto a lo« auditores financieros, al impacto de la creciente legislación cocí relación a la utilización de las tecnologías. Oportunamente, se analizan aquello« elemento« comunc« para distintos tipos de auditoría, como son lo* principios de un informe de auditoría, y los aspectos ¿ticos que debe observar un auditor, Es de agradecer la clarificación «obre jn sistema de control ■memo y la realización de una Auditoría de Sistemas de Informición. El ejercicio de ambos actividades tiene puntos en común, incluso en situackoe* determinadas se utilizan la« mismas herramientas técnicas. Sin embargo, existen diferencias específicas que se indican en los capítulos correspondientes. El control interno de los sistemas de información es una responsabilidad primaria de «us responsables. Además aporta aspectos prácticos tanto de la organización de la función de Aucitoría de Sistemas de Información, como de la realización de peritajes informáieo*.

Coincidiendo con las definiciones de la ISACA referidas en esta presentación, la Auditoría de Sistema« de Información abarca la revisión y eviluación de todos los aspectos (o alguna sección/área) de los sistemas automatizado«de procesamiento de información, incluyendo procedimientos relacionados no automáticos, y las interrelaciones entre ellos. De ahí que. eficazmente, se hayan previsto tratamientos separados de distintas áreas objeto de la Auditoría de Sistemas de Información, desde la seguridad física y ofimática. hasta lo« aspectos de tipo legal, la calidad, y b seguridad, considerando tambiln los aspectos de gestión le los sistemas de información, la adecuación de la actividad a entornos medios, lat áreas de desarrollo, sistemas concretos y tecnologías específicas.

Es importante destacar que este enfoque práctico abarca isimísimo el ejercicio de esta actividad en determinados sectores de actividad, que pueden imprimir en la realización del trabajo del auditor una cierta particularización. ya que lo« riesgos de los sistemas de información, en muchos casos, varían y dependen de la actividad empresarial.

Los profesionales que han hecho posible este libro, estái haciendo un aporte cualitativo a este "camino que se hace al andar", contribuyendo i que la Auditoría de Sistemas de Información se entienda en cuantos a sus objetivos, y que al mismo tiempo cumpla con «u función «ocia! de dar confianza en los sistemas de información a sus responsables y a la sociedad en general que recibe sus servicio«.

Quiero personalmente agradecer a Mario Piattini y Emilio del Peso, por haberme honrado con la petición de hacer esta presentación. Cono parte del colectivo

profesional de auditores de sistemas de información. agradezco umwén el esfuerzo dedicado pora llevar a buen término estas publicaciones, y mi difuvón y. asimismo hago extensivo mi reconocimiento a los distintos autores por mi contribución.

Marina Tourito
Certified Information Systems Auditor
Presidenta de la Organización de Auditoria Informática

CONTENIDO

A u l o m	XXI
Prólogo a la primera edición.....	-
Prólogo a la segunda edición.....	XXXIII
Prólogo.....	XXXIX

PARTE I. INTRODUCCIÓN..... I

CAPÍTULO I. I.A INFORMÁTICA COMO HERRAMIENTA DEL AUDITOR FINANCIERO (*Monto Hernández García*) 3

1.1 Definición del enlomo.....	3
1.2 Auditoría. Concepto.....	4
1.3 Clases de auditoría.....	4
1.4 Procedimientos.....	5
1.5 Variación del objeto.....	9
1.6 Consultaría. Concepto.....	9
1.7 Ventajas de la Informática como herramienta de la Auditoría financiera.....	12
1.7.1 Grado de informan/acido.....	12
1.7.2 Mejora de U i técnica» habituales.....	12
I.7 J Evolución.....	19
1.7.4 Grado de utilización.....	20
1.8 Conclusiones.....	22
1.9 Cuestiones de reposo.....	22

CAPÍTULO 2. CONTROL INTERNO Y AUDITORÍA INFORMÁTICA (*Gloria Sánchez Valriberas*)..... 25

2.1 Introducción.....	25
-----------------------	----

CAPÍTULO 5. ORGANIZACIÓN DE LA AUDITORÍA INFORMÁTICA (Rafael Ruano Díez)-----	107
5.1 Antecedentes..... — -----	107
5.2 Ctaes y tipos de Auditoría Informática-----.....— -----	109
5.3 Función de Auditoría Informática——	110
5.3.1 Definición.....	110
5.3.2 Perfiles profesionales de la función de Auditoría Informática	111
5.3.3 Funciones a desarrollar por la función de Auditoría Informática...-----.....-----	112
5.4 Organización de la función de Auditoría Informática..... —	115
5.5 Cuestiones de repaso..... — — - — — ••	117

CAPÍTULO 6. EL MARCO JURÍDICO DE LA AUDITORÍA INFORMÁTICA (Emilio del Peso Navarro)-----	119
--	-----

6.1 Introducción.—..... — -.....	119
6.2 La protección de datos de carácter personal....-----	121
6.3 La protección jurídica de los programas de computador-----	124
6.4 Las bases de datos y la multimedia	128
6.5 Los delitos informáticos.—..... —	136
6.6 Los contratos informáticos*..... — —..... -	136
6.7 El intercambio electrónico de datos«-----	141
6.8 La transferencia electrónica de fondos»-----	142
6.9 La contratación electrónica.-----	144
6.10 El documento electrónico-----	147
6.11 Lecturas recomendadas-----	148
6.12 Cuestiones de repaso..—..... — - — —	149

CAPÍTULO 7. DEONTOLOGÍA DEL AUDITOR INFORMÁTICO Y CÓDIGOS ÉTICOS (Jorge Pérez Mañá).....	151
--	-----

7.1 Introducción.....	151
7.2 Principio* deontológicos aplicables a los auditores informáticos.....	156
7.2.1 Principio de beneficio del auditado.....	156
7.2.2 Principio de calidad..... —	158
7.2.3 Principio de capacidad-----	158
7.2.4 Principio de cautela.....	160
7.2.5 Principio de comportamiento profesional-----	160
7.2.6 Principio de concentración en el trabajo..... —	161
7.2.7 Principio de confianza.....	162
7.2.8 Principio de criterio propio..... — ----- — -----	162
7.2.9 Principio de discreción.....-	163
7.2.10 Principio de economía.....	163
7.2.11 Principio de formación continuada —...	163

2.2	Las funciones «de control interno > auditoría informáticos —	27
2.2.1	Control Interno Informático —	27
2.2.2	Auditoría Informática —..... — —-----.....	28
2.2.3	Control interno y auditoría informáticos: campos anál>gos....	29
2.3	Sistema de Control Interno Informático	30
2.3.1	Definición y tipos de controles internos.....	30
2.3.2	Implantación de un «stema «Se controles internos informáticos	32
2.4	Conclusiones-----	42
2.5	Lecturas recomendada*-----	43
2.6	Cuestiones de repaso----....----- —-«-----	43

CAPÍTULO 3. METODOLOGÍAS DE CONTROL INTERNO. SEGURIDAD Y AUDITORÍA INFORMÁTICA

(José María González Zubieta).....».....

3.1	Introducción a las metodologías.....	45
3.2	Metodologías de evaluación «Je rinati«*-----	49
3.2.1	Conceptos fundamentales.....	49
3.2.2	Tipos de metodologías —	51
3.2.3	Metodologías más comunes——	52
3.3	las metodología* de Auditoría Informática..-----	63
3.4	El plan auditor informático——-----	65
3.5	Control interno informático. Sus métodos y procedimientos. IJS herramientas de control__	67
3.5.1	La función «Je control.....	67
3.5.2	Metodologías de clasificación de la información y de obtención «de los procedimientos «de control.....	70
3.5.3	Las herramientas <k control.....	75
3.6	Conclusiones*__ —	82
3.7	Ejemplo de metodología «de auditoría de una aplicación.....— ...—	82
3.8	Lecturas recomendadas——	91
3.9	Cuestiones «de repaso	91

CAPÍTULO 4. EL INFORME DE AUDITORÍA

(Jos/de la Peña Sánchez)..... — ...-----.....93

4.1	Introducción.	93
4.2	Las nomos-----	95
4.3	La evidencia ____	97
4.4	IAS irregularidades-----	98
4.5	la documentación ——	99
4.6	El informe——	99
4.7	Conclusiones____	104
4 8	Lecturas recomendadas....-----	105
4.9	Cuestiones de repaso-----	106

7.1.12	Principio de fortalecimiento y respeto de U pro/esióo.....	164
7.2.13	Principio de independencia.....	165
7.2.14	Principio de información suficiente.....	166
7.2.15	Principio de integridad.....	167
7.2.16	Principio de legalidad.....	167
7.2.17	Principio de libre competencia.....	168
7.2.18	Principio de no discriminación.....	168
7.2.19	Principio de no injerencia.....	169
7.2.20	Principio de precisión.....	169
7.2.21	Principio de publicidad adecuada.....	169
7.2.22	Principio de responsabilidad.....	170
7.2.23	Principio de secreto profesional.....	170
7.2.24	Principio de servicio público.....	172
7.2.25	Principio de veracidad.....	173
7.3	Conclusiones.....	174
7.4	Lecturas recomendadas.....	177
7.5	Cuestiones de repaso.....	177

PARTE II. PRINCIPALES ÁREAS DE LA AUDITORÍA

INFORMÁTICA.....	179
------------------	-----

CAPÍTULO 8. LA AUDITORÍA FÍSICA (*Gabriel Desmonte Basilio*).....

8.1	Introducción.....	181
8.2	La seguridad física.....	182
8.2.1	Ante*.....	182
8.2.2	Durante.....	183
8.2.3	Después.....	184
8.3	Áreas de la seguridad física.....	185
8.4	Definición de Auditoría Física.....	187
8.5	Fuentes de la Auditoría Física.....	188
8.6	Objetivos de la Auditoría Física.....	189
8.7	Técnicas y herramientas del auditor.....	189
8.8	Responsabilidades de los auditores.....	190
8.9	Fases de la Auditoría Física.....	191
8.10	Desarrollo de las fases de la Auditoría Física.....	192
8.11	Lecturas recomendadas.....	195
8.12	Cuestiones de repaso.....	195

CAPÍTULO 9. AUDITORÍA DE LA OFIMÁTICA

(<i>Manuel Gómez Vaz</i>).....	197
----------------------------------	-----

9.1	Introducción.....	197
9.2	Controles de auditoría.....	198
9.2.1	Economía, eficacia y eficiencia..	199

9.2-2	Seguridad	204
9.2.3	Normativa vigente.....	207
9.3	Conclusiones-__	208
9.4	Lecturas recomendadas-----	209
9.5	Cuestiones de repaso	210

CAPÍTULO 10. AUDITORÍA DE LA DIRECCIÓN

<i>(Juan Miguel Ramos Escobosa>.....</i>	211
---	------------

10.1	Introducción	211
102	Planificar	212
10.2.1	Plan estratégico de Sistemas de Información.....	212
10.2.2	Otros planes relacionado*.....	214
10.3	Organizar y coordinar	215
10.3.1	Comité de Informática.....	215
10.3.2	Posición del Departamento de Informática en la empresa.....	217
10.3.3	Descripción de funciones y responsabilidades del Departamento de Informática. Segregación de funciones.....	218
10.3.4	Estándares de funcionamiento y procedimientos Descripción de los puestos de trabajo-----	220
10.3.5	Gestión de recursos humano«: selección, evaluación del desempeño, formación, promoción,finalización-----	221
10.3.6	Comunicación.....	223
10.3.7	Gestión económica-----	223
10.3.8	Seguros	225
10.4	Controlar	226
10.4.1	Control y seguimiento-----	226
10.4.2	Cumplimiento de la normativa legal	227
10.5	Resumen-----	227
10.6	Lecturas recomendadas	228
10.7	Cuestiones de repaso	228

CAPÍTULO II. AUDITORÍA DE LA EXPLOTACIÓN

<i>(Eloy Peña Ramos) -----</i>	31
--------------------------------	-----------

11.1	Introducción	231
11.2	Sistemas de Información	232
11.3	Carta de encargo	234
11.4	Planificación	234
11.4.1	Planificación estratégica	234
11.4.2	Planificación Administrativa.....	246
11.4.3	Planificación Técnica.....	246
11.5	Realización del trabajo (procedimientos)....	247
11.5.1	Objetivo general	247
11.5.2	Objetivos específicos	247

11.6	Informes.....	
11.6.1	Tipos de informes_____—	
11.6.2	Recomendaciones.....	
11.6.3	Normas para elaborar los informes.....	
11.7	La documentación de la auditoría y su organización.....	
11.7.1	Papeles de trabajo.....	
11.7.2	Archivos.....	
11.8	Conclusiones.....	
11.9	Lecturas recomendadas.....	
11.10	Cuestiones de repaso_____-----	

CAPÍTULO 12. AUDITORÍA DEL DESARROLLO (X)

(José Antonio Rodríguez Rodríguez)..... -

12.1	Introducción.....	
12.2	Importancia de la auditoría del desarrollo.....	
12.3	Planteamiento y metodología -----	
12.4	Auditoría de la organización y gestión del área de desarrollo.,.	
12.5	Auditoría de proyectos de desarrollo de S.l.....	
12.5.1		
12.5.2		
12.5.3	Auditoría de la fase de diseño...	
12.5.4	Auditoría de la fase de construcción...	
12.5.5	Auditoría de la fase de implantación...	
12.6	Conclusiones ,.	
12.7	Lecturas recomendadas ...	
12.8	Cuestiones de repaso.,.,.,.,.	

CAPÍTULO 13. AUDITORÍA DEL MANTENIMIENTO

(Juan Carlos Granja Álvarez).....

13.1	Introducción a la Auditoría Informática del mantenimiento del software.	
13.2	Listas de comprobación en Auditoría Informática del Mantenimiento..	
13.3	Modelización en la etapa de mantenimiento..... —	
13.4	Modelo de estimación en el mantenimiento..... -	
13.4.1	Elementos de la mantenibilidad.....	
13.4.2	Métricas de mantenibilidad.....	
13.4.3	Funciones de mantenibilidad.....	
13.4.4	Método de implementación.....	
13.5	Caso de estudio..... -	

13.8	Cuestiones de re	
------	------------------	--

CAPÍTULO 14. AUDITORÍA DE BASES DE DATOS

(Mario G. Piattini Velthuii).....

14.1	Introducción.....	—	-----	-----
14.2	Metodología* para U auditoría de b u n d e dalos.....	—		311
14.2.1	Metodología tradicional.....			—312
14.2.2	Metodología de evaluación de riesgos-----			3 12
14.3	Objetivos de control en el ciclo de vida de una ha« de datos			314
14.3.1	Estudio previo y plan de trabajo.....			314
14.3.2	Concepción de la base de datos y selección del equipo — ...			318
14.3.3	Diseño y carga..-----	-----	—	319
14.3.4	Explotación y mantenimiento-----	-----	-----	320
14.3.5	Revisión post-implantación.....			321
14.3.6	Otros procesos auxiliares	-----	-----	322
14.4	Auditoría y control interno en un entorno de bases de dalos.....			322
14.4.1	Sistema de Gestión de Bases de Dalos (SGBD).....			323
14.4.2	Software de auditoria —.....			324
14.4.3	Sistema de monilori/.ación y ajuste (luni/tg)			324
14.4.4	Sistema Operativo (SO)..— .-.-----	-----	-----	324
14.4.5	Monitor de Transacciones-.....	-----	-----	324
14.4.6	Protocolos y Sistemas Distribuidos.....			325
14.4.7	Paquete de seguridad.....			325
14.4.8	Diccionarios de datos.....			326
14.4.9	Herramientas CASE (Computer Aided Syuem/Software Engineering). IPSE (IntegrateJ Project Support Environmenis)			326
14.4.10	Lenguajes de Cuarta Generación (L4G) independientes.....			326
14.4.11	Facilidades de un ario — -----	-----	-----	327
14.4.12	Herramienta* de 'minería de dalos*.....			328
14.4.13	Aplicaciones__-----	-----	-----	328
14.5	Técnicas para el control de bases de dalos en un enlomo complejo.....			329
14.5.1	Matrices de control-----	-----	-----	329
14.5.2	Análisis delos caminos de acceso-----	-----	-----	330
14.6	Conclusiones_____			330
14.7	Lecturas recomendadas	-----		332
14.8	Cuestiones de repaso-----	-----	-----	332

CAPÍTULO 15. AUDITORÍA DE TÉCNICA DE SISTEMAS

(Julio A. Novoa Bermejo)---------- 335

15.1	Ámbito de técnica de sistemas	-----	-----	335
15.2	Definición de la función...— .«.— .-----	-----	-----	337
15.3	El nivel de servicio-----	-----	-----	337
15.4	Los procedimientos-----	-----	-----	339
15.4.1	Instalación y puesta en servicio.....			339
15.4.2	Mantenimiento y soporte.....	-----	-----	340

15.4.3	Requisitos para otros componentes...—	340
15.4.4	Resolución de incidencias..... — —	341
15.4.5	Seguridad y control-----342	342
15.4.6	Información sobre la actividad.....	343
15.5	Los controles..... -	343
15.6	Auditoría de la función.....—	351
15.7	Consideraciones sobre la tecnología y su evolución-----	356
15.8	Algunas referencias..... — —	358
15.9	Lecturas recomendadas—	359
15.10	Cuestiones de repaso___ ...----- .,-----	359

CAPÍTULO 16. AUDITORÍA DE LA CALIDAD

(JoU IMís IMetro Manreja).....	361
16.1 Preámbulo.....—	361
16.2 Definiciones previas.....	362
16.3 Introducción.....—	363
16.3.1 Revisión ____	364
16.3.2 Elemento software.....—	364
16.3.3 Auditoría-----	364
16.3.4 Concepto de evaluación según la EHA.....	365
16.3.5 Concepto de Auditoría según la EEA.....	365
16.4 Características de la calidad según ISO 9126.....	365
16.4.1 Características	365
16.4.2 Modelo ISO Extendido-----	367
16.5 Objetivos de las Auditorías de Calidad.....	370
16.6 Procesas de Calidad..-.....	371
16.7 El proceso de Auditoría del Software.....-	375
16.8 Auditaría de Sistemas de Calidad de Software.....	381
16.9 Proceso de aseguramiento de la calidad descrito por ISO 12207.....—	381
16.9.1 Impkmentación del proceso-----.....	383
16.9.2 Aseguramiento del producto	384
16.9.3 Aseguramiento del proceso.....-	384
16.9.4 Aseguramiento de la calidad de los sistemas.....	385
16.10 Proceso de Auditoría descrito por ISO 12207.....—	385
16.10.1 Implcmniación del proceso.....—.....	385
16.10.2 Auditoría-----	386
16.11 Conclusiones-----	386
16.12 Lecturas recomendadas.....	387
16.13 Cuestiones de repaso.....— —	387

CAPÍTULO 17. AUDITORÍA DE LA SEGURIDAD

<i>(Miguel Ángel Ramos González)</i>		 —
17.1	Introducción	 — 389

17.2	Áreas que puede cubrir la auditoría de la seguridad..— ...----- —	393
17.3	Evaluación de riesgos----- —	395
17.4	Fase* de la auditoría de seguridad_____..... —	399
17.5	Auditoría de la seguridad (toca-...----- —	400
17.6	Auditoría de la seguridad lógica..... —	••02
17.7	Auditoría de la seguridad y el desarrollo de aplicaciones..... —	-*04
17.8	Auditoría de la seguridad en el área de producción— -----..... —	404
17.9	Auditoría de la seguridad de los datos----- —	-*05
17.10	Auditoría de la seguridad en comunicaciones y red«-----407	
17.11	Auditoría de la continuidad de las operaciones----- —	409
17.12	Fuentes de la auditoría_____ — — —-----	411
17.13	El perfil del auditor-...----- —	411
17.14	Técnicas, métodos y herramientas----- —	413
17.15	Consideraciones respecto al informe-----414	
17.16	Contratación de auditoría externa..... —	416
17.17	Relación de Auditoría con Administración de Seguridad..... —	417
17.18	Conclusiones_____ —	419
17.19	Lecturas recomendadas_____..... —-----	421
17.20	Cuestiones de repaso----- —	422

CAPÍTULO 18. AUDITORÍA DE REDES

	(José Ignacio Boito Pírtz-HoUmda)..... —	423
18.1	Terminología de redes. Modelo OSI — —----- —	423
18.2	Vulnerabilidades en redes..... —-----	426
18.3	Protocolos de alto nivel----- —	
18.4	Redes abiertas (TCP/IP)----- —	430
18.5	Auditando la gerencia de comunicaciones----- —	434
18.6	Auditando la red física-----..... —	437
18.7	Auditando la red lógica —----- ... —-----	440
18.8	Lecturas recomendadas----- —	443
18.9	Cuestiones de repaso_____ —----- —	444

CAPÍTULO 19. AUDITORÍA DE APLICACIONES

	(José Mario Madurga Outyt)----- ...----- —	445
19.1	Introducción----- _...----- —	445
19.2	Problemática de la auditoría de una aplicación informática..... —	446
19.3	Herramientas de uso más común en la auditoría de una aplicación..... —	450
19.3.1	Entrevistas----- —	450
19.3.2	Encuestas_____ —	451
19.3.3	Observación del trabajo realizado por los usuarios..... —	452
19.3.4	Pruebas de conformidad..... —	452
19.3.5	Pruebas substantivas o de validación----- —	
19.3.6	Uso del computador—----- —	454

19.4	Etapas de la auditoría de una aplicación informática.....	456
19.4.1	Recogida de información y documentación sobre la	
19.4.2	Determinación de los objetivos y alcance de la auditoría.....	458
19.4.3	Planificación de U auditoria.....	461
19.4.4	Trabajo de campo, informe e implantación de mejoras.....	462
19.5	Conclusiones	463
19.6	Lectura* recomendadas	464
19.7	Cuestiones de repaso	464

CAPÍTULO 20. AUDITORÍA INFORMÁTICA DE EIS/DSS Y APLICACIONES DE SIMULACIÓN (*Manuel Palao García-Suelto*) 467

20.1	Propósito y enfoque.....	467
20.2	Desarrollo de la* definiciones operativa* de los conceptos clave ____	468
20.2.1	Auditoría Informática.....— - ————	468
20.2.2	SID[£/.?KSAD(DSS -----	469
20.2.3	Aplicaciones de Simulación-----	472
20.3	Singularidades de la AI de los SID(£75 . SADJDSSJySimulación-----	474
20.3.1	AI de los SID]¿ 75].....-	475
20.3.2	AI de k» SAD[Ztt\$] y Simulación	480
20.4	Conclusiones _____	481
20.5	Lecturas recomendadas	—
20.6	Cuestiones de repaso ____	481

CAPÍTULO 21. AUDITORÍA JURÍDICA DE ENTORNOS INFORMÁTICOS (*Uosep Jtn-eri Podrá*)----- 483

21.1	Introducción.....—	483
21.2	Auditoría del entorno.....—	485
21.3	Auditoría de las personas —	488
21.4	Auditoría de la información.....	492
21.5	Auditoría de los archivos.....— —-----.....	493
21.5.1	Niveles de protección de los archivos.....	493
21.5.2	Mecanismos de seguridad del archivo-----	495
21.5.3	Formación de la figura del responsable del archivo.....	495
21.6	Conclusiones _____	503
21.7	Lecturas recomendadas.....	5(H
21.8	Cuestiones de repaso-----	504

PARTE III. AUDITORÍA INFORMÁTICA EN DIVERSOS SECTORES 507

CAPÍTULO 22. AUDITORÍA INFORMÁTICA EN EL SECTOR BANCARIO (*Pilar Amador Corara*) 509

22.1	Características generales de la Auditoría Informática en las entidades financieras.....	509
22.1.1	Necesidad y beneficios de la auditoría informática en la banca.....	509
22.1.2	Tipología de las actividades a auditar.....	511
22.1.3	Objetivos de la auditoría y preparación del plan de trabajo....	514
22.2	Auditoría Informática de una aplicación bancaria típica—.....	515
22.2.1	(Rúbricas para la planificación anual de los trabajos.....	516
22.2.2	Establecimiento del ámbito de la auditoría.....	517
22.2.3	Procedimientos de auditoría a emplear-----	519
22.2.4	Consideraciones a tener en cuenta durante la realización de la auditoría.....	521
22.3	Auditoría informática de la protección de datos personales.....	523
22.3.1	La importancia y el valor de la información en el sector bancario.....	523
22.3.2	Actividades de auditoría en relación con la protección de datos personales.....	525
22.4	Cuestiones de repaso-----	530

CAPÍTULO 23. AUDITORÍA INFORMÁTICA EN EL SECTOR AÉREO (*Aurelio Hermoso Baños*) 533

23.1	Introducción.....	533
23.2	Sistema de reservas Amadeus -----	534
23.3	Facturación entre compañías aéreas-----	535
23.4	Código de conducta para CRS.....	536
23.5	Procesos informáticos.....	538
23.6	Auditoría Informática.....	540
23.7	Conclusiones-----	548
23.8	Lecturas recomendadas	548
23.9	Cuestiones de repaso-----	549

CAPÍTULO 24. AUDITORÍA INFORMÁTICA EN LA ADMINISTRACIÓN (*Álvaro Izquierdo Iñola*)—..... 551

24.1	Introducción.....	551
24.2	Las TIC en la LRJ-PAC.....	552
24.3	La informatización de registros.....	554

24.4	Las previsiones del Real Decreto 263/1996. «Je 16 de febrero, por el que se regula la utilización de 1 « técnicas <i>EIT</i> por la Administración General del Estado.....-	555
24.5	Identificación de los requisitos de seguridad, normalización y conservación en el texto del Real Decreto 263/1996.....	556
24.5.1	Garantías de seguridad de sopones, medios y aplicaciones....	556
24.5.2	Emisión de documentos: procedimientos para garantizar la validez de los medios: integridad, conservación, identidad del autor y autenticidad de la voluntad.....	557
24.5.3	Validez de las copias: garantía de su autenticidad, integridad y conservación	558
24.5.4	Garantía de realización de las comunicaciones.....	558
24.5.5	Validez de comunicaciones y notificaciones a k» ciudadanos: constancia de transmisión y recepción, estampación de fechas y contenido íntegro, identificación fidedigna de remitente y destinatario.....	559
24.5.6	Comunicaciones por medios preferentes del usuario: comunicación de la forma y código de accesos a sus sistemas de comunicación _____	559
24.5.7	Validez de fechas de notificación para cómputo de plazos; anotación en los registros generales o auxiliares a que hace referencia el artículo 38 de la LRJ-PAC _____	560
24.5.8	Conservación de documentos: medidas de seguridad que garanticen la identidad c integridad de la información necesaria para reproducirlos.....	561
24.5.9	Acceso a documentos almacenados: disposiciones del artículo 37 de la Ley 30/1992. y. en su caso, de la Ley Orgánica 5/1992. Norma* de desarrollo.....	561
24.5.10	Almacenamiento de documentos; medidas de seguridad que garanticen su integridad, autenticidad, calidad, protección y conservación..... _____	562
24.6	Conclusiones sobre el papel de la Auditoría Informática en la Administración Electrónica.....	563
24.7	Cuestiones de repaso _____ „_____	565

CAPITULO 25. AUDITORÍA INFORMÁTICA EN LAS PYMFS

(Carlos M. Fernández Sánchez)..... - 567

25.1	Preámbulo _____	567
25.1.1	Las PYMES y las tecnologías de la Información.....	567
25.1.2	Metodología de la Auditoría Informática.....	568
25.2	Introducción.....	568
25.2.1	¿En qué consiste la guía de autoevaluación?.....	568
25.2.2	¿A quién va dirigida? _____	569
25.2.3	Conocimientos necesarios.....	569

25.2.4	Entornos de aplicación..... -	570
25.2.5	Metodología utilizada-----	570
25.3	Utilización de la guía.....	571
25.3.1	Fases de la airtoevahiación.....-	571
25.3.2	Valoración de resultado*-----	573
25.4	Minicomputadores e informática distribuida. Riesgo en la eficacia «léi servicio informático.....	574
255	Cooclusiones.....	581
25.6	Lecturas recomendadas --- ----- ...	582
25.7	Cuestiones de repaso-----	583

PARTE IV. OTRAS CUESTIONES RELACIONADAS CON LA AUDITORÍA INFORMÁTICA..... 585

CAPÍTUIX) 26. PF.RITAR *VERSUS* AUDITAR (Jtsús Rh tro Laguna)----- 587

261	Introducción -----	587
26.2	Consuhorrs. Auditores > Pernos-----	
26.3	Definición conceptual de Perito-----590	
27.3.1	Equivalencia con la denominación de "Experto".----- ..	592
27J.2	Acerca de la adquisición de "txpertist~	593
26.4	"Pento" \tnus "Especialista**----- ...	594
27.3.1	Quién puede ver "Pento IT"----- ..	594
27J.2	Formación de "Pentos IT Profesionales"-----	597
27JJ	Conclusión-----	598
265	Diferenciación entre Informes. Dictámenes y Peritaciones.-.-.-.-----	598
27.3.1	Acerca del término "Informe**----- 599	
27J.2	Acerca del término "Dictamen"-----	600
27.3.3	Definiciones del COIT-----	601
27.3.4	Tanfas diferenciadas de Honorarios de Ingenieros en Trabajos a p a r t i c u l a r e s -----	603
266	Peritaciones extrajudicales y arbitraje».....-----	604
26.7	El Dictamen de Pcntos como Medio de prueba....-----	606
27.3.1	Objeto de la "prueba pericial**-----	607
27.3.2	El "Dictamen de Peritos" en la vigente LEC-----	608
27.3	J El "Dictamen de Peritos" en la LEC. de enero de 2000 -----609	
27.3.4	Comentarios fioales..-----	611
26.8	Cooclustooe*-----	611
26.9	Lecturas recomendadas.....-----612	
2610	Cuestiones de repaso-----	613

CAPÍTULO 27. EL CONTRATO DE AUDITORÍA

<i>(Isabel fiat-ara Fernández de Marcos)</i>	615
27.1 Introduccita	615
27.2 Una breve referencia a la naturales jurídica del contrato de auditoría..	620
27.3 Partes de un contrato de auditoría. El perfil del auditor informático.....	621
27.3.1 La entidad auditada.....	621
27.3.2 El auditor infonnMco	622
27.3.3 Terceras penoaas.....	626
27.4 Objeto del contrato de auditoría informática.....	628
27.4.1 Protección de dato» de carácter personal.....	629
27.4.2 La protección jurídica del software-----	630
27.4.3 1.a protección jurídica de la» b#*es de dalos.....	631
27.4.4 Contratación electrónica.....	632
27.4.5 La contratación uiíom iítica.....	634
27.4.6 Tram ícrercu electrónica de fondos.....	635
27.4.7 El delito informático.....	636
27.5 Causa-----	637
27.6 El informe de auditoría-----	637
27.7 Conclusiones.....	638
27.8 Lectura.» recomendadas.....	641
27.9 Cuestiones de repaso.....	6«!
ACRÓNLMOS.....	643
BIBLIOGRAFÍA.....	649
ÍNDICE.....	655

LA INFORMÁTICA COMO HERRAMIENTA DEL AUDITOR FINANCIERO

Alonso Hernández García

1.1 DEFINICIÓN DEL ENTORNO

Definid y no discutiréis. Y aun sin la pretensión de que lo que se exponga en este capítulo sea indiscutible, parece muy conveniente delimitar el campo en que nos desenvolvemos.

Dentro de una especialidad tan reciente y expansiva como la llamada auditoría informática, cabe perfectamente la confusión conceptual tanto entre los diferentes aspectos, áreas o enfoques en sí mismos como por la debida a la vertiginosa evolución que experimenta la especialidad.

Pero como ya pretende explicitar el título del capítulo, vamos a tratar de auditoría financiera, Parece indicarse que en cierta medida nos desgajamos del contenido general del libro y nos desviamos hacia las auditorías financieras.

No es exactamente así. Si desmenuzamos el contenido de la auditoría y su evolución podemos observar que el concepto permanece inamovible y son su objeto y finalidad lo que puede variar.

También parece procedente hacer una alusión específica a la consultaría como especialidad profesional, ya que se hace preciso delimitar sus respectivos campos que en ocasiones se confunden y superponen.

1.2. AUDITORÍA. CONCEPTO

Conceptualmente U auditoria, toda y cualquier auditoria, es la actividad consistente en la emisión de una opinión profesional sobre si el objeto sometido a anilius presenta adecuadamente la realidad que pretende reflejar y/o cumple Ut condiciones que le han sido prescritas.

Podemos descomponer este concepto en los elementos fundamentales que i continuación se especifican:

- 1) contenido: una opinión
- 2) condición: profesional
- 3) justificación: sustentada en determinados procedimientos
- 4) objeto: una determinada información obtenida en un cierto soporte
- 5) finalidad: determinar si presenta adecuadamente la realidad o ésta responde a las expectativas que le son atribuidas, es decir, su fiabilidad

En lodo caso es una función que se acomete a posteriorion. en relación era actividades ya realizadas, sobre las que hay que emitir una opinión

1.3. CLASES DE AUDITORÍA

Los elementos 4 y 5 distinguen de qué clase o tipo de auditoria se trata. El objeto sometido a estudio, sea cual sea su soporte, por una parte, y la finalidad con que K realiza el estudio, definen el tipo de auditoría de que se traía. A titulo ilustrativo podríamos enumerar entre otras:

Financiera	Opinión	Cuentas anuales	Presentan realidad
Informática	Opinión	Sistemas de aplicación, re- iOperatividad eficiente y] cursos informáticos, planes isegún normas establecí-1 de contingencia etc.	Idas
Gestión	Opinión	Dirección	Eficacia, eficiencia, eco-] nomicidad
Cumpli- miento	Opinión	Normas establecidas	ILas operaciones se ale-. cuan a estas normas

14. PROCEDIMIENTOS

La opinión profesional, elemento esencial de la auditoria, se fundamenta y justifica por medio de unos procedimientos específicos tendentes a proporcionar una seguridad razonable de lo que se afirma.

Como es natural, cada una de las clases o tipos de auditoria pcuee sus propios procedimientos para alcanzar el fin previsto aun cuando puedan <n muchos casos coincidir. El alcance de la auditoria, concepto de vital importancia, nos viene dado por k>s procedimientos, la amplitud y profundidad de los procedimiento* que se apliquen nos definen su alcance.

En las auditorias altamente reglamentadas como la financiera es preceptivo "aplicar las Normas Técnicas y decidir los procedimientos de audiurfa". "Cualquier limitación... que impida la aplicación de lo dispuesto en las Normas Técnicas debe ser considerada en el Informe de auditoria como una reserva al alcance".

Se pretende garantizar que se toman en consideración todos los aspectos, áreas, elementos, operaciones, circunstancias, etc. que sean significativas.

Para ello se establecen unas normas y procedimientos que en cuanto a la ejecución de la auditoria se resumen en que:

- El trabajo se planificará apropiadamente y se supervisará adetiadamente.
- Se estudiará y evaluará el sistema de control interno.
- Se obtendrá evidencia suficiente y adecuada.

Como corolario ve establece que la evidencia obtenida deberá recogerse en los papeles de trabajo del auditor como justificación y soporte del tralxjo efectuado y la opinion expresada.

Estas tres normas se deducen claramente de la situación real actual de los riesgos que ha de afrontar el auditor.

Inicialmente. cuando el objeto de la auditoría, los documcrios financieros a auditar, eran relativamente cortos y contenían más bien escasas operaciones, los procedimientos llamados de arriba a abajo, que parten de los documentos financieros y auditan hacia abajo, hacia la evidencia de auditoria subyacente, que le verificaba en su integridad, tradicionalmente conocido por censura de cuentas o en tase a las cuentas, era adecuado, suficiente y viable.

Sin embargo, cuánto llegó la llamada revolución cuantitativa, que (rajo conujs la creación de sociedades con importantes medios, que las operaciones tt ■nuliiplsaran enormemente y que la gestión y propiedad se diferenciaron cada v a tak claramente, el método tradicional resolvió laborioso, tedioso, largo, ineficaz y ecooómicámenle inviaMe.

No era posible verificar la totalidad de las muy cuantiosas operaciones y. por unto, había que reducir el campo de acción del auditor a parle de la numera información.

También, como no» manifiesta Dale S. Plesher. a partir de los primeros artos dd siglo XX. la banca se convirtió en el principal usuario de las auditorías de cara 4 seguimiento de sus créditos, y no estaba interesada en la exactitud administrativa de las cuentas sino "en la calidad y representadvnlad de los balances".

Este nuevo planteamiento, sin embargo, traía implícito un riesgo evidente, al te verificarse la totalidad de los movimientos.

Los controles establecidos por la entidad auditada pudieran permitir que K produjeran irregularidades, potencialmente significativas, casuales o voluntarias.

Al no someterse a revisión todas y cada una de las operaciones, cabe b posibilidad de que escape a la atención del auditor alguna de aquellas irregularidades

til auditor tiene el cometido irrenunciabJe de mantener el riesgo de que efl» ocurra dentro de límites tolerables.

Este aserto podría representarse de forma aritmética como:

$$R(c) * R(d) - S(e).$$

$R(c)$ * al riesgo en el proceso o riesgo de control.

$R(d)$ * nesgo de detección.

$S(e)$ = constante o parámetro admisible en que se desea mantener el riesgo de auditoria.

Es inmediato el hecho de que el riesgo de control y el riesgo de detección dentro de la ecuación planteada son inversamente proporcionales. Si artadimos que el ríigo de control es ajeno al auditor, pues depende de las normas establecidas por la entidad en MI sistema, es evidente que para definir el riesgo de detección que está dispuesto a admitir, ha de evaluarse primero el riesgo de control existente.

De ahí se justifica la imposición de las Normas Técnicas que establecen que la revisión del sistema tiene por objeto el que sirva como base para las pruebas de cumplimiento y para la evaluación del sistema.

En esta línea las Normas de Auditoría en su apartado 2.4.34. explicitan que el riesgo final del auditor es una combinación de dos riesgos separados.

- El primero de éstos está constituido por aquellos errores de importancia que ocurran en el proceso contable, del cual se obtienen las cuentas anuales.
- El segundo riesgo es de que cualquier error de importancia que pueda existir sea o no detectado por el examen del auditor.

El auditor confía en:

- el control interno establecido por la entidad auditada para reducir el primer riesgo y
- en sus pruebas de detalle y en sus otros procedimientos* para disminuir el segundo.

Basados en estos conceptos podemos esquematizar los procedimientos de auditoría financiera establecidos por las Normas en relación con la ejecución de la auditoría, de la siguiente forma:

15. VARIACIÓN DEL OBJETO

Por añadidura es innegable, (y aquí si reclamaríamos la condición de indiscutible para el aserto), que con mayor o menor profundidad la gestión de las entidades ha experimentado un cambio sustancial y hoy, salvo casos dignos del Guinness, se utiliza la TI (Tecnología de la Información) en todo proceso contable.

Se ha introducido un nuevo elemento cualitativo en el objeto de la auditoría, el uso de la informática como factor consustancial a la gestión, con la introducción de la

Tecnología de La Información (TI) en lo« sistema*. muy probablemente basada en lis ventaja* que aporta la informalización con respecto al trababa manual, entre la* que, según C. Martin, se podrían distinguir

Consolad

Cosío de explotación	Alto	Bajo
Costo de operación	Alto	Bajo
Rendimiento continuado	Disminuye	Constante
Consistencia	Poca	Excelente
Capacidad de cálculo	Buena	Pobre
Reacción ante lo inesperado	Buena	Pobre
Sentido común	Excelente	Pobre
Lenguaje	Bueno	Pobre

Este nuevo elemento, la Tecnología de la Información, puede estar y de hecho tiende a estar en todos los niveles del sistema.

liste mero hecho impone un nuevo condicionante al auditor ha de trabajar ame y con elementos de Tecnología de la Información. Dado que según las propia* Normas Técnicas de auditoría que regulan su actuación el auditor ha de tener en cuenta todos los elementos de la entidad incluso los informáticos, el cumplir con esta función no es una decisión graciable del auditor sino una obligación definida por la Norma. Sería mis que coherente que una firma de auditoría que por la razón que fuere no quiere o no puede cumplir con este requisito se viera obligada a introducir una limitación al alcance de su trabajo. Es evidente que no habría aplicado todos los procedimientos precisos.

En un excelente trabajo acometido por The Canadian Institute of Chartered Accountant*. una institución de reconocido prestigio internacional, se plantea la cuestión de cuáles son actualmente los "libros" o soporte de los documentos financiero* objeto de la labor del auditor en un entorno informatizado, y concluye que dicho* libros están materializados en lo* archivos electrónicos, es decir los archivos creados y mantenidos en forma electrónica por las aplicaciones contable*.

El objeto es distinto. Está en un soporte diferente. El auditor financiero we alterado el objeto de *u actividad en el sentido de que se ha introducido la TI. ahora está en soporte magnético y este cambio trac consecuencias de gran calado en cuanto a procedimientos de auditoría financiera.

Ha de cambiar su* procedimiento* en función de la* nueva* circunstancias y. por tanto, de la expan*ión de su alcance. La auditoría financiera sigue siendo auditoría y financiera con la diferencia de que en su objeto, el mismo de siempre, es decir en la información financiera, se ha introducido la TI.

los «retivos electrónico* y proceder * tu análisis de fon— Mttbién

La situación se hace más dramática por el hecho cada vez más extendido de que el soporte documental de los apuntes electrónicos no exista en absoluto. El rastro de auditoría tradicional ha desaparecido como, por ejemplo, en el FDI o H-T.

Afortunadamente la propia TI que incide en los procedimientos que el auditor ha de aplicar proporciona paralelamente medios de ejecutarlos de forma eficiente y directa. Las CAATS (Técnicas de Auditoría asistidas por computador) ponen a disposición del auditor una amplia variedad de herramientas que no sólo viabilizan los nuevos procedimientos sino que mejoran sensiblemente su aplicación y amplían la gama disponible.

Por tanto, deducimos claramente que la introducción de la TI en los sistemas de información afecta a los auditores de una forma dual:

- cambia el soporte del objeto de su actividad
- posibilita la utilización de medios informatizados (CAATs) para la realización de sus procedimientos

16. CONSULTORÍA. CONCEPTO

Es en esta fase de la exposición cuando parece pertinente añadir una referencia a la consultoría. Conviene distinguir su concepto del de auditoría para precisar nuestro planteamiento con la máxima exactitud.

La consultoría consiste en "dar asesoramiento o consejo sobre lo que se ha de hacer o cómo llevar adecuadamente una determinada actividad para obtener los fines deseados".

Las diferencias se hacen evidentes. Los elementos de la consultoría podrían

- 4) objeto: la actividad o cuestión sometida a consideración
 15) finalidad: establecer la manera de llevarla a cabo adecuadamente

Es una función a priori con el fin de determinar cómo llevar a cabo una función o actividad de forma que obtenga los resultados pretendidos. La auditoría verifica a posteriori si estas condiciones, una vez realizada esta función o actividad, se cumplen y los resultados pretendidos se obtienen realmente.

A título enunciativo podríamos relacionar los siguientes tipos o clases de consultorio:

Financiera	Asesoramiento	Planes de cuentas. Procedimientos administrativos	Diseño e implantación
Informática	Asesoramiento	Aplicaciones, y Planes de Contingencia	Desarrollo. Diseño e implantación.

Especialmente el elemento / distingue claramente la auditoría de la consultoría. Dependiendo de que su contenido sea opinar sobre unos resultados y dar asesoramiento o consejo en relación con una actividad a desarrollar, se tratará de auditoría o consultoría. Esta distinción nos resultará importante cuando queramos delimitar las funciones.

Se observa, sin embargo, que las definiciones de la auditoría informática tienden a englobar el concepto de consultoría. La auditoría financiera, con siglos de experiencia, se encuentra perfectamente definida: pero las definiciones, reflexiones o referencias a la auditoría informática son variadas, lo que es lógico en una especialidad tan reciente.

Dentro del abanico de definiciones, podemos citar

A) desde definiciones como la de A. J. Ibomas en el sentido de que "la auditoría informática, que es una parte integrante de la auditoría, se estudia por separado para tratar problemas específicos y para aprovechar los recursos de personal. La auditoría informática debe realizarse dentro del marco de la auditoría general. El cometido de la auditoría informática se puede dividir en:

- Un estudio del sistema y un análisis de los controles organizativos y operativos del departamento de informática.
- Una investigación y análisis de los sistemas de aplicación que se estén desarrollando o que ya estén implantados.

- La realización de auditoría* de dato* reales y de resultados de lo* sistemas que se estén utilizando.
- La realización de auditorías de eficiencia y eficacia.”

B) Incluyendo la de un destacado miembro de la OAI. Miguel Ángel Ramos, que define, según sus manifestaciones simplificadaamente. en su tesis doctoral la auditoría informática como "la revisión de la propia informática y de su entorno" y desglosa sin carácter exhaustivo que las actividades a que da lugar esta definición pueden ser:

- Análisis de riesgos.
- Planes de contingencia.
- Desarrollo de aplicaciones.
- Asesoramiento en paquetes de seguridad.
- Revisión de controles y cumplimiento de los mismos, así como de las normas legales aplicables.
- Evaluación de la gestión de los recursos informáticos.

C) A la de I. J. Adía que por su parte la define como "Un conjunto de procedimientos y técnicas para evaluar y controlar total o parcialmente un Sistema Informático, con el fin de proteger MIS activos y recursos, verificar si sus actividades se desarrollan eficientemente y de acuerdo con la normativa informática y general existente en cada empresa y para conseguir la eficacia exigida en el marco de la organización correspondiente".

De ellas se desprende que tienden a abarcar conceptos tanto de auditoría como de consultoría. En la línea de análisis que hemos trazado la primera distinción a realizar sería la diferenciación entre auditoría y consultorio. No son términos equivalentes y es preciso distinguirlos.

Nuestro enfoque pretende centrarse en la auditoría según el concepto que ya hemos dejado explícito. Y dentro de ella la financiera de acuerdo con su objeto y finalidad que incluye el soporte informático.

1.7. VENTAJAS DE LA INFORMÁTICA COMO HERRAMIENTA DE LA AUDITORÍA FINANCIERA

1.7.1. Grado de informatización

tu U doble vertiente relativa a la introducción e influencia de la TI en el objeto por una parte y en los procedimiento» por otra de la auditoria financiera hemos de referimos en primer lugar al grado o intensidad de tu utilización.

En cuanto al objeto puede considerarse desde el uso de un simple PC con un par de aplicaciones básicas como pueden ser la contabilidad y un procesador de texto», a un sistema complejo, distribuido, utilizando base de datos en cliente servidor, integrado y comunicado con otros sistemas con los que interactúa directamente como en el EDI. RMCCC evidente que las tres Normas para la ejecución de la auditoria adquieren una complejidad y amplitud diferente*. Mientras más desarrollado es el sistema, más problemático resulta su enfoque por parte del auditor. Si bien lo» riesgos de un pcqueAo PC pueden ser sustantivos, la complejidad de los mismos en un siuema es decisiva.

Entre los procedimientos (técnicas) que las tres Normas de ejecución de la auditoria establecen como medios de los que debe valerte el auditor en la ejecución de su trabajo destacan la inspección, observación, averiguación, confirmación, cálculo y análisis. De estas seis al menos cuatro se ejecutan de forma más eficiente con medios informáticos:

- Inspección: como la comparación de datos en dos archivos o cuentas distintas, conciliaciones.
- Cálculo: de amortizaciones, provisiones, ratios. etc.
- Análisis: regresiones o datos que cumplan determinadas condiciones.
- Confirmación: cálculo estadístico, selección y emisión de muestras, cumplimiento. etc.

1.7.2. Mejora de las técnicas habituales

No resulta difícil justificar que las posibilidades del auditor utilizando medios electrónicos se amplía enormemente con respecto a trabajos manuales sobre listados en papel. El incremento en velocidad, eficiencia y seguridad es evidente.

Para todo ello el auditor puede valerse sustancialmente de las diseñas herramientas informáticas que tiene a su disposición y que podríamos catalogar de la siguiente forma:

General	1Tratamiento de textos 1 <i>Hotixharting</i> 1Utilidades	Tratamiento de textos Hojas de cálculo
Acceso directo		ACL
Específico	Generadores de papeles de trabajo Administración	Simulación paralela Revisión de tu.
Especializados	Integradores	Sistemas expertos 1 <i>Test check</i>

IV forma somera podríamos reseñar los objetivos que se cubren con la utilización de las diversas herramientas enumeradas:

- *Tratamiento de textos*, utilizado generalmente en la práctica como una máquina de escribir superautomatizada para circular, memorandos, memoria, etc.

Con una mayor especialización permite automatizar operaciones, generar documentos, relacionar diversos documentos, etc.

- *Hoja de cálculo*, utilizada para efectuar cálculos, automatizar resultados de diferentes documentos numéricos y en algunos casos obtención de ratios, etc., así como generar actualizaciones automáticas, importar archivos de otras aplicaciones, y producir gráficos disponiendo de una amplia gama de fórmulas financieras, económicas, etc.
- *Generador de papeles de trabajo*, fundados esencialmente en el tratamiento de textos de donde se obtienen plantillas, formatos, etc.; permite edición y actualización. Clasifica los documentos por áreas, sectores, personal involucrado, etc.
- *Flowcharting*-. produce diagramas representativos de funciones realizadas o a realizar, flujo de documentos, etc.
- *Utilidades*: existe una amplia gama que cubre desde comunicaciones, visualizadores de archivos, búsquedas o incluso rectificadores de archivos.

El OCR es una asignatura pendiente.

- *Administradores*-, efectúan el seguimiento administrativo de las auditorías. Horas empleadas, áreas, control presupuestario, etc.

- *Accf.w directo*: todas las aplicaciones a que nos hemos referido hasta el momento y las posteriores se refieren a dato* o "archivos" específicos de la misma* que el auditor ha tecleado en las aplicaciones o ha copiado de otras ya existentes. La gran ventaja del acceso directo es que adopta como archivo a leer o analizar “los de la firma auditada”, generalmente los que contienen la contabilidad de la misma. Sea cual sea la aplicación de contabilidad que haya utilizado la firma auditada, las aplicaciones de acceso directo, como su nombre indica, adoptan como archivos propios los realizados por esas aplicaciones. De esta forma se materializa directamente la aseveración de que los libros del auditor son los archivos informáticos del auditado.

Tomando como hilo conductor la estructura de ACL (véase figura I.I). una de las aplicaciones más destacadas de este estilo y posiblemente la más extendida mundialmente. tomaremos como esquema básico, que vemos en la página siguiente.

Lo* archivos de datos son exactamente los existentes en el auditado, es decir los archivos físicos de la firma auditada, de la forma y con la codificación con que hayan sido grabados. Estos datos no cambian. ACL crea para su tratamiento el "documento" que contiene la información necesaria en cuanto a definiciones del formato del archivo de datos, botches, índices, vistas y espacio de trabajo.

La definición del formato contiene la estructura y contenido del archivo de datos. Incluye información como nombre de los campos, codificación de los datos, márgenes donde comienzan y donde terminan. Con esta información ACL es capaz, de leer e interpretar el archivo de datos original a auditar.

Figura 11.1. Estructura de ACL

Partiendo de esta situación ACL puede manipular los datos del archivo prácticamente de cualquier forma o manera:

- | | |
|----------------------------|----------------|
| - Ordenar | - Contar |
| - Crondogizar | - Agregar |
| - Kxirar según condiciones | - Totalizar |
| - Estadísticas | - Estratificar |
| - Muestras | - Comparar |
| - Clasificar | |

Sólo existen dos limitaciones a los análisis, cálculos, verificaciones, etc. que puede hacer ACL:

- Que el dato deseado esté en el archivo. (Por ejemplo, no se podría croooJogi/jr si en el archivo no figuraran las fechas.)
- La imaginación del auditor, que combina los diferentes mandatos para obtener la información final que desea. Creando incluso nuevos campos computados, producto del tratamiento de uno o varios de los ya exis(en«es.

Es de destacar la posibilidad de seleccionar la información que cumpla una o varias condiciones. Estos filtros resultan de incalculable valor cuando se audita.

Si añadimos que la respuesta a cualquier solicitud, sea cual sea el tamaño del archivo de datos, se realiza en segundos y en cualquier caso en pocos minutos, la importancia de esta aplicación queda perfectamente clara.

A título meramente enunciativo y como punto de partida para el auditor interesado, de los 101 cálculos y análisis que se practican en las áreas más habituales. seleccionamos dos a título de ejemplo:

Ejemplo I: COMPROBACIÓN DE BALANCE

Se indica la relación de mandato* que permite realizar esta operación.

OPEN Contabilidad	Abre el archivo "Contabilidad".
STRATIFY ON Cuenta	Genera, para cada cuenta del plan, su total
ACCUMULATE Debe Haber Saldo	al debe, al haber, y el saldo.

Ejemplo 2: CONCILIACIÓN ENTRE COMPRAS Y PROVEEDORES

Se indica la relación de mandatos que permite realizar esta operación.

OPEN Contabilidad	Abre el archivo "Contabilidad".
SORT ON Impone TO Compras IF Cuenta="604" AND DIU="D"	! Produce el archivo "Compras" con aquellos* asiento* de la contabilidad cuya cuenta sea la 604 y al debe, ordenado por el importe.
SORT ON Impone TO Proveedores	Produce el archivo "Proveedores.*" con IF Cuenta="400r AND DH="H" aquellos asientos de la contabilidad cuya cuenta sea la 400 y al haber, ordenado por el importe.
OPEN Compras	Abre el recién creado archivo "Compras".
OPEN Proveedores SECONDARY	Abre el recién creado archivo "Proveedores" como archivo secundario.
JOIN Fecha Asiento Importe WITH Impone Asiento Fecha TO "Conciliación Compras-Proveedores" PKEY Impone SKEY Impone PRIMARY SECONDARY	Produce el archivo "Conciliación Compras-Proveedores" con el resultado de conciliar "Compras" con "Proveedores", utilizando el importe como campo que los relaciona.

Revisión analítica

Normalmente se utiliza la hoja de cálculo para obtener, de los datos que habitualmente se le introducen (Balance, Cuentas de Pérdidas y Ganancias, etc.), los ratios, proporciones o funciones que proporcionan una nueva visión comparativa de MI contenido.

Sistemas expertos

Las aplicaciones más avanzadas en cualquier campo son las conocidas como sistemas expertos relativos a la también llamada inteligencia artificial. Se trata de usar el computador para que proporcione resultados o conclusiones producto del procesamiento de unos datos específicos en base a unos conocimientos preexistentes en el mismo.

Este sistema ya se ha utilizado en diversos campos, por ejemplo la medicina, para el diagnóstico* o tratamientos en base a los datos del paciente que se introducen en la aplicación.

En el campo de la auditoria su utilización más evidente es en el análisis y evaluación del control interno. No ha sido hasta el momento una aplicación que se haya prodigado, posiblemente por la dificultad de completar una base de conocimientos adecuada que sólo los expertos pueden proporcionar. Se dice, como es costumbre, que las grandes empresas ya han desarrollado sistemas expertos que aplican en mayor o menor medida. Sin embargo, que se sepa, no se ha dado mucha importancia al respecto.

Los fundamentos de un sistema experto, aplicando la misma filosofía establecida por las Normas Técnicas, consiste en crear uno o varios cuestionarios cuya respuesta sea "sí" o "no" para evitar matices opinables, divididos por áreas de actividad y que se pauten de la base de que una totalidad de respuestas positivas implica un sistema excelente. Menos de un determinado nivel implicaría un control débil o muy débil.

Ha de incorporarse las pruebas de cumplimiento correspondientes cuya cuantía se designe por medios estadísticos y que sirvan sus respuestas como retroalimentación para una clasificación definitiva del sistema.

Esta clasificación a su vez proporciona un tamaño de muestra para las pruebas de Muestreo a realizar así como una definición de las mismas.

Destacan entre sus ventajas, siempre bajo la supervisión del auditor: la objetividad del sistema, la utilización de fórmulas estadísticas, la cuantificación y especificación de pruebas de cumplimiento y sustantivas adecuadas, la actualización

de la base de conocimiento con los nuevos sistemas analizados y el soporte legal que implica en caso de litigio.



Figura 1.2. Ejemplo de aplicación de sistema experto a la auditoría

TcM Check

Esta práctica, cada vez en menor uso, consiste en introducir en la aplicación que el auditado utilice un conjunto de valores cuyo resultado se conoce. Estos valores se comparan con los que eventualmente proporcione la aplicación.

Integradores

Es decir, aquellas aplicaciones que interrelacionan todas las demás para crear un entorno único que utiliza la totalidad de la información obtenida a través de las diferentes herramientas creando un "sistema de auditoría".

Varias de las aplicaciones mencionadas proporcionan medios de programación o, sin ser tan ambiciosos, la posibilidad de crear "batches" de funcionamiento automático. Estos batches o conjuntos de instrucciones pueden operar conjuntamente brindando la posibilidad de realizar operaciones complejas de forma directa y cómoda.

Si tomamos en consideración el proceso completo de auditoría financiera -desde las normas y procedimientos establecidos para antes del propio inicio de la auditoría como la propuesta, contrato, cálculo de costes hasta el informe y recomendaciones finales pasando naturalmente por los procedimientos de ejecución de la auditoría, incluyendo el sistema experto, el acceso directo a archivos informáticos, las pruebas analíticas y adicionales o puntuales que el auditor debe llevar a cabo, y las integramos

en un sistema que automatice tanto las actualizaciones pertinentes en base a los cambios introducidos como la emisión y ordenación de papeles de trabajo justificativos de los procedimientos aplicados-, tendremos un sistema o metodología de integración que sitúa en un solo entorno las diverjas fases, documentos, resultados, actualizaciones, etc. de una auditoría. A todo este proceso es a lo que denominaríamos un integrado? que aun cuando no abunda, se viene percibiendo su necesidad.

Figura I. 1. Proceso completo de la auditoría financiera

1.7.3. Evolución

El propio (Canadian Institute of Chartered Accountants, que se ha preocupado muy especialmente por esta problemática, define un camino hacia la plena institución de un sistema de auditoría informatizado. En un planteamiento al que llanta la Hipótesis de Evolución ha distinguido diferentes etapas o niveles que a continuación transcribimos literalmente por su representatividad e importancia:

Las firmas de auditoría más avanzadas han cubierto las dos primeras etapas y actualmente algunas intentan adentrarse en la tercera. Las otras sólo consisten en "buenos deseos" para el futuro, pero que si las seguimos sucintamente vemos que nos conducen a que "la auditoría se convierte en una herramienta para la construcción de realidades políticas y económicas" donde la auditoría y consultoría se entrelazan.

Hipótesis de colisión

	Alcance A Aumento de la competitividad	Alcance B Creación de riqueza	Alcance C Mejora de la calidad de vida
Nivel 5 Nuevos conceptos y paradigmas basados en la TI	ÍÁ5 El valor añadido se convierte en el objetivo de toda la auditoría	¡B5 La auditoría adopta el carácter de un servicio de consultoría y análisis continuado	1 5 La auditoría se conviene en una herramienta para la definición de las políticas
Nivel 4 Gestión estratégica basada en la TI	ÍA4 Los auditores adoptan un nuevo concepto de su propia actividad	84 La integración de estas herramientas en la auditoría permite la auditoría	w fMejor comprensión de todas las partes implicadas de los beneficios de una auditoría
Nivel 3 Nuevos productos* dependientes de la	1 [Á3 Las herramientas del auditor se equiparan en s sofisticación al sistema de los clientes como el EFT	B3 M r >D ci^H lo de una definición de la herramienta de auditoría	C3 Se acaba el expectation gap
Nivel 2 Aumento de la calidad	A m pli3j4He la ."i otév jifSF	2 Aumento cuantitativo y cualitativo de los I*U-.cubr»miciUt»	C2 Menos argumentos en cuanto al papel del auditor
Nivel I Reducción de costos	'Reducción de horas de auditoría I	B1 Incremento en la recuperación de los costos	c i Reducción de trabajo administrativo

Figura 1.4. Intensidad del efecto de la evolución

1.7.4. Grado de utilización

Asalta de inmediato la idea de por qué, visto lo expuesto, el grado de utilización de estas posibilidades por los auditores es bajo y en muchos casos incipiente.

Se lun efectuado diver«» «ludios y parece desprenden« que algunas de las rezones pueden ser:

Costo económico

Falta de convencimiento en cuanto a la disminución de costos. No se ve con claridad que la inversión necesaria se vea compensada por la eficiencia que se alean«.

Parece innegable que los costos tanto del hardware como del software han disminuido extraordinariamente en los últimos artos y que la eventual inversión en un sistema para iníormatización de la auditoría no es en absoluto significativo. Cualquier somero estudio demuestra que su rentabilidad porcentual es siempre sumamente elevada.

Complejidad técnica

Cierto temor reverencial a una nueva técnica que mirada desde el exterior parece sumamente compleja y algo mágico que de por sí ahuyenta. Esta idea puede traer como corolarios otras consideraciones negativas como que se cree que:

- Se depende de los técnicos.
- No se puede revisar el trabajo de los técnicos
- Problemas de comunicación entre el técnico y el auditor.
- Costo de k» técnicos.

La introducción y ampliación de las posibilidades del PC que con sistemas operativos sumamente fáciles de usar pueden realizar trabajos hasta hace pocos años reservados a las grandes instalaciones, simplifica enormemente y pone al alcance de cualquier auditor medianamente familiarizado con la informática una importantísima gama de labores. Todas las que hemos venido exponiendo.

Falta de entrenamiento y experiencia

Es innegable que la utilización de tas técnicas de auditoria asistidas por computador requieren un mínimo de entrenamiento y conocimiento. La gran diferencia es que estos mínimos son perfectamente asequibles como ya hemos descrito y consiguen que el auditor retenga el control del proceso de auditoría

Según Klen. el auditor ha de estar en posesión como mínimo de las siguientes cualidades:

- Ser experto auditor (financiero).
- Conocer el diseño y modo de operar del S.I.
- Tener conocimientos básicos* de técnicas y lenguajes de programación.
- Estar familiarizado con los sistemas operativos.
- Serle factible poder identificar problemas con los formatos y estructuras de base de datos.
- Ser capaz de tender un puente con el profesional de la TL
- Saber cuándo pedir apoyo de un especialista.

No cabe duda de que en el entramado multidisciplinar que constituye el acervo de conocimientos de un auditor, este aspecto viene a ampliar su "programa". Es una nueva faceta que viene a enriquecer su perfil. Si nos atenemos a las estadísticas disponibles en EE.UU., el auditor viene adquiriendo estos nuevos conocimientos en un 70% de los casos por medio de entrenamiento en la propia empresa, en un 22% en seminarios y conferencias al efecto y en el 8% en el entorno académico. Mientras la Academia no desarrolle más sus servicios no cabe duda de que la pequeña y mediana empresa de auditoría se enfrenta al nuevo reto de resolver su reciclaje.

Otras incluyendo la preocupación del cliente en cuanto a la seguridad de datos.

1.8. CONCLUSIONES

El objeto de la auditoría financiera ha cambiado. Incorpora la TL. Esto trae consigo el cambio de los "libros" a analizar e igualmente la necesidad de aplicar nuevos procedimientos que utilizan herramientas informáticas.

En la práctica, al auditor se le presenta una disyuntiva: o se adapta a la nueva situación abordando el carro de la evolución hacia metas sumamente halagadoras, para lo que ha de adoptar una actitud receptiva hacia las nuevas tecnologías, o indefectiblemente será una víctima de la evolución que no quiso o no supo afrontar.

1.9. CUESTIONES DE REPASO

1. ¿Cuáles son los elementos fundamentales del concepto de auditoría?
2. ¿Cuántas clases diferentes de auditoría existen?
3. ¿Qué sector es uno de los principales usuarios de las auditorías?
4. ¿Qué ventajas aporta el computador respecto al trabajo manual?

5. ¿Qué significan los siglos CAAT?
6. ¿Frente a qué afecta a los auditores la introducción de la TI en los sistemas de información?
7. ¿Qué diferencias hay entre auditoría y consultoría?
8. ¿Cuáles son las ventajas de la informática como herramienta de la auditoría financiera?
9. ¿Qué pueden aportar los sistemas expertos a la auditoría informática?
10. ¿Cuáles son las razones de la baja utilización de la TI como herramienta de la auditoría financiera?

CONTROL INTERNO Y AUDITORÍA INFORMÁTICA

Gloria Sánchez Valriberas

2.1 INTRODUCCIÓN

Tradicionalmente en materia de control interno se adoptaba un enfoque bastante restringido limitado a los controles contables internos. En un tiempo se relacionaba con la información financiera, el control interno era un tema que interesaba principalmente al personal financiero de la organización y, por supuesto, al auditor externo. El concepto de control interno de mucha gente no incluía muchas de las actividades operativas claves destinadas a prevenir los riesgos efectivos y potenciales a los que se enfrentan las organizaciones. Al producirse la quiebra de numerosas cajas de ahorro y otras organizaciones resultó evidente que no había suficiente conciencia de la necesidad de los controles para evitar que los problemas surgieran y crecieran.

Durante el último decenio la prensa ha informado sobre muchos escándalos relativos a errores en el otorgamiento de créditos con la garantía de inmuebles inexistentes o extremadamente sobrevalorados, la manipulación de información financiera, operaciones bursátiles realizadas con información privilegiada, y muchos otros conocidos fallos de los controles que han afectado a empresas de diferentes sectores. En España se han dado pasos importantes como consecuencia de nuestra incorporación y adaptación a Europa.

Además de la mayor atención que prestan las autoridades al problema, se observan importantes cambios en las empresas. Dichos cambios someten a una gran

tensión a los controles internos existentes*. La mayoría de las organizaciones han acometido vanas iniciativas en tal sentido, tales como:

- La reestructuración de los procesos empresariales (BP3 -*Business Process Re-engineering*).
- La gestión de la calidad total (TQM -*Total Quality Management*).
- El redimensionamiento por reducción y/o por aumento del tamaño hasta el nivel correcto.
- La contratación externa (*outsourcing*).
- La descentralización.

El mundo en general está cambiando cada vez más rápidamente, sometiendo a las empresas a la acción de muchas fuerzas externas tales como la creciente necesidad de acceder a los mercados mundiales, la consolidación industrial. La intensificación de la competencia, y las nuevas tecnologías.

Las tendencias externas que influyen sobre las empresas son, entre otras, las siguientes:

- La globalización).
- La diversificación de actividades.
- La eliminación de ramas de negocio no rentables o antiguas.
- La introducción de nuevos productos como respuesta a la competencia.
- Las fusiones y la formación de alianzas estratégicas.

Ante la rapidez de los cambios, los directivos toman conciencia de que para evitar fallos de control significativos deben reevaluar y reestructurar sus sistemas de controles internos. Deben actuar de manera proactiva antes de que surjan los problemas, tomando medidas audaces para su propia tranquilidad, así como para garantizar a los consejos de administración, accionistas, comités y público que los controles internos de la empresa están adecuadamente diseñados para hacer frente a los retos del futuro y asegurar la integridad en el momento actual.

Un centro de informática de una empresa del sector terciario suele tener una importancia crucial por soportar los sistemas de información del negocio, por el volumen de recursos y presupuestos que maneja, etc. Por lo tanto, aumenta la complejidad de las necesidades de control y auditoría, surgiendo en las organizaciones, como medidas organizativas, las figuras de control interno y auditoría informática.

La auditoría ha cambiado notablemente en los últimos años con el enorme impacto que han venido obrando las técnicas informáticas en la forma de procesar la información para la gerencia. La necesidad de adquirir y mantener conocimientos actualizados de los sistemas informáticos se vuelve cada vez más crucial. Si bien los

aspecto* básicos de U profesión no han variado. Los auditores informáticos aportan conocimientos especializados, así como MI familiaridad con la tecnología informática. Se siguen tratando las mismas cuestiones de control en la auditoría, pero los especialistas en auditoría informática de sistemas basados en computadores prestan una ayuda valiosa a la Organización y a los otros auditores en todo lo relativo a los controles sobre dichos sistemas.

En muchas organizaciones, el auditor ha dejado de centrarse en la evaluación y la comprobación de los resultados de procesos, desplazando su atención a la evaluación de riesgos y la comprobación de controles. Muchos de los controles se incorporan en programas informáticos o se realizan por parte de la función informática de la organización, representado por el Control Interno Informático. El enfoque centrado en los controles normalmente exige conocimientos informáticos a nivel de la tecnología utilizada en el área o la organización que se examina.

2.2. LAS FUNCIONES DE CONTROL INTERNO Y AUDITORÍA INFORMÁTICOS

2.2.1. Control Interno Informático

El Control Interno Informático controla diariamente que todas las actividades de sistemas de información sean realizadas cumpliendo los procedimientos, estándares y normas fijados por la Dirección de la Organización y/o la Dirección de Informática, así como los requerimientos legales.

La misión del Control Interno Informático es asegurarse de que las medidas que se obtienen de los mecanismos implantados por cada responsable sean correctas y válidas.

Control Interno Informático suele ser un órgano *staff* de la Dirección del Departamento de Informática y está dotado de las personas y medios materiales necesarios para el cumplimiento de los cometidos que se le encomienden.

Como principales objetivos podemos indicar los siguientes:

- Controlar que todas las actividades se realizan cumpliendo los procedimientos y normas fijados, evaluar su bondad y asegurarse del cumplimiento de las normas legales.

Asesorar sobre el conocimiento de las normas.

- Colaborar y apoyar el trabajo de Auditoria Informática, así como de las auditorías externas al Grupo.
- Definir, implantar y ejecutar mecanismos y controles para comprobar el logro de los grados adecuados del servicio informática, lo cual no debe considerarse como que la implantación de los mecanismos de medida y la responsabilidad del logro de esos niveles se ubique exclusivamente en la función de Control Interno, sino que cada responsable de objetivos y recursos es responsable de esos niveles, así como de la implantación de los medios de medida adecuados.

Realizar en los diferentes sistemas (centrales, departamentales, redes locales. PCs. etc.) y entornos informáticos (producción, desarrollo o pruebas) el control de las diferentes actividades operativas sobre:

- El cumplimiento de procedimiento, normas y controles dictados. Merece resaltarse la vigilancia sobre el control de cambios y versiones del *software*.
- Controles sobre la producción diaria.
- Controles sobre la calidad y eficiencia del desarrollo y mantenimiento del *software* y del servicio informática.
- Controles en las redes de comunicaciones.
- Control* sobre el *software* de base.
- Controles en los sistemas microinformáticos.
- La seguridad informática (su responsabilidad puede estar asignada a control interno o bien puede asignársele la responsabilidad de control dual de la misma cuando está encargada a otro órgano):
 - Usuarios, responsables y perfiles de uso de archivos y bases de datos.
 - Normas de seguridad.
 - Control de información clasificada.
 - Control dual de la seguridad informática.
- Licencias y relaciones contractuales con terceros.
- Asesorar y transmitir cultura sobre el riesgo informático.

2.2.2. Auditoría Informática

La Auditoria Informática es el proceso de recoger, agrupar y evaluar evidencias para determinar si un sistema informatizado salvaguarda los activos, mantiene la integridad de los datos, lleva a cabo eficazmente los fines de la organización y utiliza

eficientemente los recursos. De este modo la auditoría informática sustenta y confirma la consecución de los objetivos tradicionales de la auditoría:

- Objetivos de protección de activos e integridad de datos.
- Objetivos de gestión que abarcan, no solamente los de protección de activos, sino también los de eficacia y eficiencia.

El auditor evalúa y comprueba en determinados momento* del tiempo los controles y procedimientos informativos más complejos, desarrollando y aplicando técnica* mecanizadas de auditoría, incluyendo el uso del software. En muchos casos, ya no es posible verificar manualmente los procedimientos informatizados que resumen, calculan y clasifican datos, por lo que se deberá emplear software de auditoría y otras técnicas asistidas por computador.

El auditor es responsable de revisar e informar a la Dirección de la Organización sobre el diseño y el funcionamiento de los controles implantados y sobre la fiabilidad de la información suministrada.

Se pueden establecer tres grupos de funciones a realizar por un auditor informático:

- Participar en las revisiones durante y después del diseño, realización, implantación y explotación de aplicaciones informativas, así como en las fases análogas de realización de cambios importantes.
- Revisar y juzgar los controles implantados en los sistemas informativos para verificar su adecuación a las órdenes e instrucciones de la Dirección, requisitos legales, protección de confidencialidad y cobertura ante errores y fraudes.
- Revisar y juzgar el nivel de eficacia, utilidad, fiabilidad y seguridad de los equipóse información.

2.2.3. Control interno y auditoria informáticos: campos análogos

La evolución de ambas funciones ha sido espectacular durante la última década. Muchos controles internos fueron una vez auditores. De hecho, muchos de los actuales responsables de Control Interno Informático recibieron formación en seguridad informática tras su paso por la formación en auditoría. Numerosos auditores se pasan al campo de Control Interno Informático debido a la similitud de los objetivos profesionales de control y auditoría, campos análogos que propician una transición natural.

Aunque ambas figuras tienen objetivos comunes, existen diferencias que conviene matizar:

SIMILITUDES	Personal interno
< Conocimientos especializados en Tecnología de la Información	1
Verificación del cumplimiento de control interno*, normativa y procedimiento* establecido* por la Dirección de Informática y	I
la Dirección General para los sistemas de información	1
DIFERENCIAS	Análisis de un momento
Análisis de los controles en el día a día	informático determinado
Informa a la Dirección del Departamento de informática	Informa a la Dirección General de la Organización
Sólo personal interno	Personal interno y/o externo
El alcance de sus funciones es únicamente «dentro del Departamento de Informática	Tiene cobertura sobre todo* lo* componente* de lo* sistema* de información de la Organización

2.3. SISTEMA DE CONTROL INTERNO INFORMÁTICO

2.3.1. Definición y tipos de controles internos

Se puede definir el control interno como "cualquier actividad o acción realizada manual y/o automáticamente para prevenir, corregir errores o irregularidades que puedan afectar al funcionamiento de un sistema para conseguir sus objetivos".

Los controles cuando se diseñan, desarrollan e implantan han de ser al menos completos, simples, fiables, revisables, adecuados y rentables. Respecto a esto último habrá que analizar el coste-riesgo de su implantación.

Los controles mismos que se utilizan en el entorno informático continúan evolucionando hoy en día a medida que los sistemas informáticos se vuelven complejos. Los progresos que se producen en la tecnología de software (y de hardware) han modificado de manera significativa los procedimientos que se empleaban tradicionalmente para controlar los procesos de aplicaciones y para gestionar los sistemas de información.

Para asegurar la integridad, disponibilidad y eficacia de los sistemas se requieren complejos mecanismos de control, la mayoría de los cuales son automáticos. Resulta interesante observar, sin embargo, que hasta en los sistemas servidor/cliente avanzados, aunque algunos controles son completamente automáticos, otros son

completamente manuales. y mucho* dependen de una combinación de elemento* de software y de procedimiento».

Históricamente, lo* objetivo* de lo* controles informático* se lun clasificado en lis «guiente* categorías:

- *Controles preventivos-*, para tratar de evitar el hecho, coma un software de seguridad que impida los acceso« no autorizados al sistema
- *Controles detectivo*v. cuando fallan los preventivo* piara tratar de conocer cuanto ante* el evento. Por ejemplo, el registro de intent» de acceso no autorizados, el registro de la actividad diaria para detectar errores u omisiones. <*c.
- *Controles torredivoi*: facilitan la vuelta a la normalidad cuando se han producido incidencias. Por ejemplo, la recuperación de un uchivo daAado a partir de las copias de seguridad.

Como el concepto de controles se originó en la profesión de auditoría, resulta importante conocer la relación que existe entre los métodos de control, los objetivo* de control y los objetivo* de auditoría. Se trata de un tema difícil porel hecho de que. históricamente, cada método de control ha estado a*ociado unívocamente con un objetivo de control (por ejemplo, la seguridad de archivos de dalos se conseguía sencillamente manteniendo la sala de computadores cerrada con llave!).

Sin embargo, a medida que los sistema* informático« se tian vuelto más complejo*, los controles informáticos han evolucionado hasta convenirse en procesos integrados en los que se atenúan las diferencia* entre las categorías tradicionales de cootroies informáticos.

Por ejemplo, en los actuales sistemas informáticos puede resultar difícil ver la diferencia entre seguridad de los programas, de los datos y objetivos de control del software del sistema. porque el mismo grupo de método* de control satisface casi Hulmwu lo* tres objetivo» de control.

La relación que existe entre los métodos de control y los objetivos de control puede demostrarse mediante el siguiente ejemplo, en el que un miimo conjunto de método* de control se utiliza para satisfacer objetivos de control tanto de mantenimiento como de seguridad de los programas:

- *Objetivo de Control de mantenimiento*: asegurar que las modificaciones de los procedimientos programados están adecuadamente disecadas, probadas, aprobadas e implantada*.

- *Objetivo Je Control de seguridad de programas:* garantizar que no se pueden efectuar cambios no autorizados en los procedimientos programados.

2.3.2. Implantación de un sistema de controles internos informáticos

Los controles pueden implantarse a vahos niveles diferentes. La evaluación de los controles de la Tecnología de la Información exige analizar diversos elemente» interdependientes. Por ello es importante llegar a conocer bien la configuración del sistema, con el objeto de identificar lo* elementos, productos y herramientas qae existen para saber dónde pueden implantarse los controles, así como para identifica: posibles riesgos.

Para llegar a conocer la configuración del sistema es necesario documentar k» detalles de la red. así como los distintos niveles de control y elementos relacionados:

- *Entorno de red.* esquema de la red. descripción de la configuración hardware de comunicaciones, descripción del software que se utiliza como acceso a las telecomunicaciones, control de red. situación general de los computadores de entornos de base que soportan aplicaciones críticas y consideraciones relativas a la seguridad de la red.
- *Configuración del computador base:* configuración del soporte físico, entorno del sistema operativo, software con particiones, entornos (pruebas y real), bibliotecas de programas y conjunto de datos.
- *Entorno de aplicaciones:* procesos de transacciones, sistemas de gestión de bases de datos y entornos de procesos distribuidos.
- *Productos y herramientas:* software para desarrollo de programas, software de gestión de bibliotecas y para operaciones automáticas.
- *Seguridad del computador base:* identificar y verificar usuarios, control de acceso, registro e información, integridad del sistema, controles de supervisión, etc.

Para la implantación de un sistema de controles internos informáticos habrá que definir:

Gestión de sistemas de información: políticas, pautas y normas técnicas que sirvan de base para el diseño y la implantación de los sistemas de información y de los controles correspondientes.

- Administración de sistemas: controle* sobre la actividad de los centros de datos y otras funcione* de apoyo al sistema, incluyendo la administración de las redes.
- Seguridad: incluye las tres dase» de controles fundamentales implantados en el software del sistema, integridad del sistema, confidencialidad (control de acceso) y disponibilidad.
- Gestión del cambio: separación de las pruebas y la producción a nivel de software y controles de procedimientos para la migración de programas software aprohados y probados.

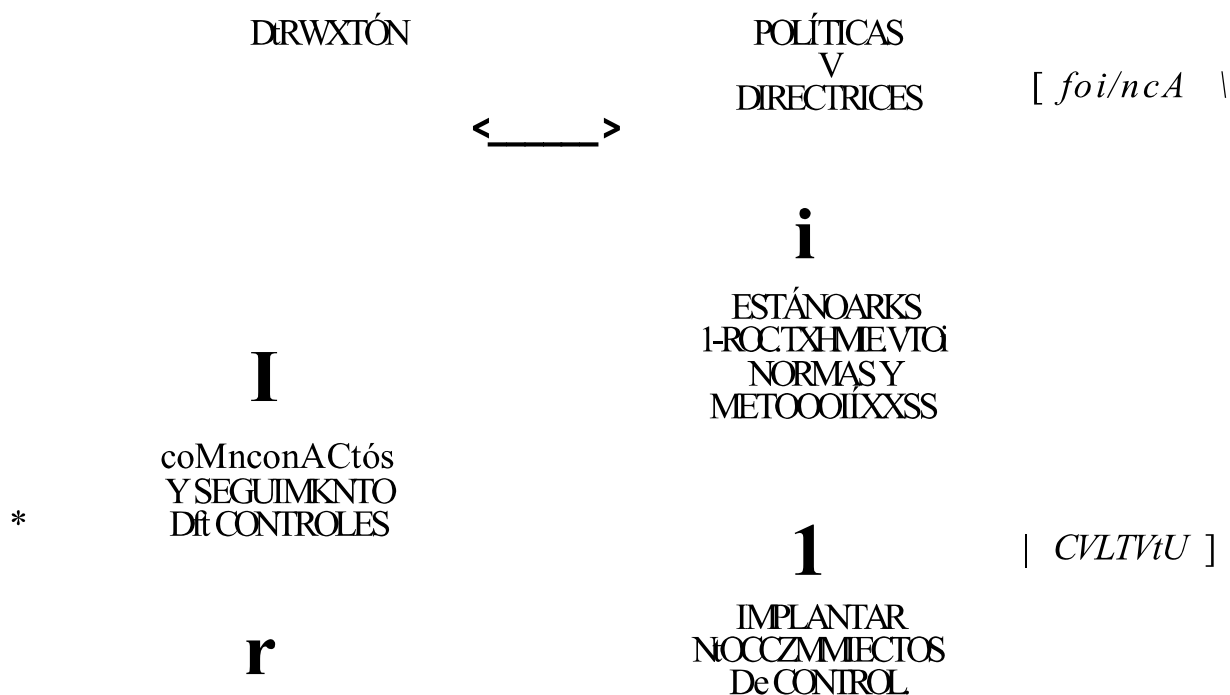
La implantación de una política y cultura sobre la seguridad requiere que sea italiuda por fases y esté respaldada por la Dirección. Cada función juega un papel ■nportante en las distintas etapas:

Dirección de Negocio o Dirección de Sistemas de Información (S.I.): Han de defieir la política y/o directrices para los sistemas de información en base a las exigencias del negocio, que podrán ser internas o externas.

türrectón J Informática-* Ha «de definir I» nornia* * fimriniumimln iVI momo informático y de cada una de las funciones de Informática mediante la creación y publicación de procedimientos, estándares, metodología y normas, aplicables a todas las áreas de Informática así como a los usuarios, que establezcan el Bureo de funcionamiento.

Control Interno Informático: Ha de definir kx* diferentes controles periódicos a realizar en cada una de las funciones informáticas, de acuerdo al noel de riesgo de cada una de ellas, y ser disertados conforme a lo- objetivos de negocio y dentro del marco legal aplicable. Éstos se plasmarán en los oportunos procedimientos de control Memo y podrán ser preventivos o de detección. Realizará periódicamente la revisión de los controles establecidos de Control Interno Informático informando de las

desviaciones a la Dirección «de Informática y sugiriendo cuantos cambios ere» convenientes en los controles, así como transmitir* constantemente a toda la organización de Informática la cultura y políticas del riesgo informático.



Auditor insrmo/txttmo informático: Ha de revisar la* diferentes controles internos definidos en cada una de las funciones informáticas y el cumplimiento de normativa interna y externa, de acuerdo al nivel de riesgo, conforme a los objetivos definidos por la Dirección de Negocio y la Dirección de Informática. Informará a la Alta Dirección de los hechos observados y al detectarse deficiencias o ausencias de controles recomendarán acciones que minimicen los riesgos qtx pueden originarse.

l-a creación de un sistema de control informático es uní responsabilidad de la Gerencia y un punto dextacable de la política en el entorno informático.

A continuación se indican algunos controles internos (no lodos los que deberían definirse) para sistemas de información, agrupados por secciones funcionales, y que serian los que Control Interno Informático y Auditoría Informática deberían verificar para determinar su cumplimiento y validez:

I. Controles generales organizativos

- Políticas: deberán servir de base para la planificación, control y evaluación por la Dirección de las actividades del Departamento de Informática.

- Planificación:
 - *Plan Estratégico de Información*, realizado por los órganos de la Alta Dirección de la Empresa donde se definen los procesos corporativos y se considera el uso de las diversas tecnologías de información así como las amenazas y oportunidades de su uso o de su ausencia.
 - *Plan Informático*, realizado por el Departamento de Informática, determina los caminos precisos para cubrir las necesidades de la Empresa plasmandolas en proyectos informáticos.
 - *Plan Central de Seguridad (física y lógica)*, que garantice la confidencialidad, integridad y disponibilidad de la información.
 - *Plan de emergencia ante desastres*, que garantice la disponibilidad de los sistemas ante eventos.
- Estándares: que regulen la adquisición de recursos, el diseño, desarrollo y modificación y explotación de sistemas.
- Procedimientos: que describan la forma y las responsabilidades de ejecución para regular las relaciones entre el Departamento de Informática y los departamentos usuarios.
- Organizar el Departamento de Informática en un nivel suficientemente superior de estructura organizativa como para asegurar su independencia de los departamentos usuarios.
- Descripción de las funciones y responsabilidades dentro del Departamento con una clara separación de las mismas.
- Políticas de personal: selección, plan de formación, plan de vacaciones y evaluación y promoción.
- Asegurar que la Dirección revisa todos los informes de control y resuelve las excepciones que ocurran.
- Asegurar que existe una política de clasificación de la información para saber dentro de la Organización qué personas están autorizadas y a qué información.
- Designar oficialmente la figura de Control Interno Informático y de Auditoría Informática (estas dos figuras se nombrarán internamente en base al tamaño del Departamento de Informática).

2. Controles de desarrollo. **adquisición** y mantenimiento **de** sistemas **de** **información**

Para que permitan alcaruar la eficacia del sistema, economía y eficiencia, integridad de los dalos, protección de los recursos y cumplimiento con las leyes y regulaciones.

- Metodología del ciclo de vida del desarrollo de sistemas: su empleo podrá garantizar a la alta Dirección que se alcanzarán los objetivos definidos para el sistema. Éstos son algunos controles que deben existir en la metodología:
 - La alta Dirección debe publicar una normativa sobre el uso de metodología de ciclo de vida del desarrollo de sistemas y revisar ¿sta periódicamente.
 - La metodología debe establecer los papeles y responsabilidades de las distintas áreas del Departamento de Informática y de los usuarios, así como la composición y responsabilidades del equipo del proyecto.
 - Las especificaciones del nuevo sistema deben ser definidas por tos usuarios y quedar escritas y aprobadas antes de que comience el proceso de desarrollo.
 - Debe establecerse un estudio tecnológico de viabilidad en el cual se formulen formas alternativas de alcanzar los objetivos del proyecto acompañadas de un análisis coste-beneficio -de cada alternativa-.
 - Cuando se seleccione una alternativa debe realizarse el plan director del proyecto. En dicho plan deberá existir una metodología de control de costes.
 - Procedimientos para la definición y documentación de especificaciones de: diserto, de entrada, de salida, de archivos, de procesos, de programas, de controles de seguridad, de pistas de auditoría, etc.
 - Plan de validación, verificación y pruebas.
 - Estándares de prueba de programas, de prueba de sistemas.
 - Plan de conversión: prueba de aceptación final.
 - Los procedimientos de adquisición de software deberán seguir las políticas de adquisición de la Organización y dichos productos debieran ser probados y revisados antes de pagar por ellos y ponerlos en uso.
 - La contratación de programas de servicios de programación a medida ha de estar justificada mediante una petición escrita de un director de proyecto.
 - Deberán prepararse manuales de operación y mantenimiento como parte de todo proyecto de desarrollo o modificación de sistemas de información, así como manuales de usuario.
- Explotación y mantenimiento: el establecimiento de controles asegurará que los datos se tratan de forma congruente y exacta y que el contenido de

sistemas sólo w i modificado mediante autorización adecuada. foto* «m algunos de los controles que se deben implantar:

- Procedimientos de control de explotación.
- Sistema de contabilidad para asignar a usuarios los costes asociados con la explotación de un sistema de información.
- Procedimientos para realizar un seguimiento y control de los cambios de un sistema de información.

3. Controle« de explotación de sistemas de información

- Planificación y Gestión de recursos: definir el presupuesto operativo del Departamento. Plan de adquisición de equipos y gestión de la capacidad de los equipos.
- Controles para usar, de manera efectiva los recursos en computadores:
 - Calendario de carga de trabajo.
 - Programación de personal.
 - Mantenimiento preventivo del material.
 - Gestión de problemas y cambios.
 - Procedimientos de facturación a usuario«.
 - Sistema de gestión de la biblioteca de soportes.
- Procedimientos de selección del software del sistema, de instalación, de mantenimiento, de seguridad y control de cambios.
- Seguridad física y lógica:

Definir un grupo de seguridad de la información, siendo una de sus funciones la administración y gestión del software de seguridad, revisar periódicamente los informes de violaciones y actividad de seguridad para identificar y resolver incidentes.

- Controles físicos para asegurar que el acceso a las instalaciones del Departamento de Informática queda restringido a las personas autorizadas.
- Las personas externas a la Organización deberán ser acompañadas por un miembro de la plantilla cuando tengan que entrar en las instalaciones.
- Instalación de medidas de protección contra el fuego.
- Formación y concienciación en procedimientos de seguridad y evacuación del edificio.
- Control de acceso restringido a los computadores mediante la asignación de un identificados de usuario con palabra clave personal e intransferible.

- Normas que regulen el acceso a los recursos informáticos.
- Existencia de un plan de contingencias para el respaldo de recursos de computado* críticos y para la recuperación de los servicios del Departamento Informático después de una interrupción imprevista de los mismos.

4. Controles en aplicaciones

Cada aplicación debe llevar controles incorporados para garantizar la entrada, actualización, validez y mantenimiento completos y exactos de los datos. Las cuestiones más importantes en el control de los datos son:

- Control de entrada de datos: procedimientos de cotverción y de entrada*, validación y corrección de datos.
- Controles de tratamientos de datos para asegurar que no se dan de aquí. modifican o borran datos no autorizados para garantizar la integridad de los mismos mediante procesos no autorizados.
- Controle* de salidas de datos: sobre el cuadro y reconciliación de salidas, procedimientos de distribución de salidas, de gestión de errores en las salidas».

5. Controles específicos de las tecnologías

- Controles en Sistemas de Gestión de Bases de Datos:
 - El software de gestión de bases de datos para prever el acceso a. b estructuración de. y el control sobre los datos compararlos, deberá instalarse y mantenerse de modo tal que asegure la integridad del software, las bases de datos y las instrucciones de control que definen el entorno
 - Que estén definidas las responsabilidades sobre la planificación. organización dotación y control de los activos de datos, es decir, un administrador de datos.
 - Que existan procedimientos para la descripción y los cambios de datos así como para el mantenimiento del diccionario de datos.
 - Controles sobre el acceso a datos y de concurrencia.
 - Controles para minimizar fallos, recuperar el entorno de las bases de datos hasta el punto de la caída y minimizar el tiempo necesario para la recuperación.
 - Controles para asegurar la integridad de los datos: programas de utilidad para comprobar los enlaces físicos -punteros- asociados a los datos, registros de

control para mantener los balances transitónos de transacciones para su posterior cuadro con totales generados por el usuario o por otros sistemas.

Controles en informática distribuida y redes:

Planes adecuados de implantación, conversión y pruebas de aceptación para la red.

Existencia de un grupo de control de red.

Controles para asegurar la compatibilidad de conjunto de datos entre aplicaciones cuando la red es distribuida.

Procedimientos que definan las medidas y controles de seguridad a ser usados en la red de informática en conexión con la distribución del contenido de bases de dato» entre los departamentos que usan la red.

Que se identifiquen todos los conjuntos de datos sensible» de la red y que se han determinado las especificaciones para su seguridad.

Existencia de inventario de todos los activos» de la red.

Procedimientos de respaldo del hardware y del software de la red.

Existencia de mantenimiento preventivo de todos los activos.

Que existen controles que verifican que todos los mensajes de salida se validan de forma rutinaria para asegurar que contienen direcciones de destino válidas.

Controles de seguridad lógica: control de acceso a la red. establecimiento de perfiles de usuario.

Procedimientos de cifrado de información sensible que se transmite a través de la red.

Procedimientos automáticos para resolver cierres del sistema.

Monitoreo/acción para medir la eficiencia de la red.

Disertar el trazado físico y las medidas de seguridad de las líneas de comunicación local dentro de la organización.

Detectar la correcta o mala recepción de mensajes.

Identificar los mensajes por una clave individual de usuario, por terminal, y |M el IIÚIIIICIU <lc XOKACU del mcu»ájic.

Revisar los contratos de mantenimiento y el tiempo medio de servicio acordados con el proveedor con objeto de obtener una cifra de control consume.

Determinar si el equipo multiplexor/concentrador/procesador frontal remoto tiene lógica redundante y poder de respaldo con realimentación automática para el caso de que falle.

Asegurarse de que haya procedimientos de recuperación y reinicio.

Asegurarse de que existan pistas de auditoría que puedan usarse en la reconstrucción de los archivos de datos y de las transacciones de los diversos

terminales. Debe cxiMir la capacidad de rastrear los Calos entre la terminal y el usuario.

- Considerar circuitos de conmutación que usen tulas alternativas pin diferentes paquetes de información provenientes del misino mensaje; esto ofrece una forma de seguridad en caso de que alguien itfercepte los mensajes
- Controles sobre computadores personales y redes de área local:
 - Políticas de adquisición y utilización.
 - Normativas y procedimientos de desarrollo y adquisición de software de aplicaciones.
 - Procedimientos de control del software contratado bajo licencia.
 - Controles de acceso a redes, mediante palabra clave, a ravés de computadores personales.
 - Revisiones periódicas del uso de los computadores penonales.
 - Políticas que contemplen la selección, adquisición e instalación de redes de área local.

Procedimientos de seguridad física y lógica.

- Departamento que realice la gestión y soporte técnico de la red. Controles para evitar modificar la configuración de una red. Recoger informadle detallada sobre los Minis existentes: Arquitectura (CFU's. Discos. Memori*. Streamers, Terminales, etc.). Conectividad (LAN. *minilo kost*, etc.), software (sistema operativo, utilidades, lenguaje«, aplicaciones. etc.). Servicios soportados.
- Inventario actualizado de todas las aplicaciones de la Kritidad.
- Política referente a la organización y utilización de los discos duros de 1« equipos, así como para la nomenclatura de los archivos que contienen, y verificar que contiene al menos: obligatoriedad de etiquetar el disco duro con el número de serie del equipo, creación de un subdirectorío por usuario en d que se almacenarán todos sus archivos privados, así como creación de un subdirectorío público que contendrá todas las aplicaciones de uso común pan los distintos usuarios.
- Implantar herramientas de gestión de la red con el fin de valorar su rendimiento, planificación y control.
- Procedimientos de control de los *filt-trantfer* que se redizan y de controles de acceso para los equipos con posibilidades de comuni.'ación. Políticas que obliguen a la desconexión de los equipos de lis líneas de comunicación cuando no se está haciendo uso de ellas.
- Adoptar los procedimientos de control y gestión adecúalos para la integridad, privacidad, confidencialidad y seguridad de la información contenida en redes de área local.

Cuando exista conexión PC-Host. comprobar que opera bajo los controles necesarios* para evitar la carga/extracción de datos de forma no autorizada.

Contrato* de mantenimiento (tanto preventivo como correctivo o defectivo).

Cuando en las acciones de mantenimiento «c requiera la acción de tercero» o la salida de los equipos de los límites de la oficina. se deberán establecer procedimientos para evitar la divulgación de información confidencial o sensible.

Mantener un registro documental de las acciones de mantenimiento realizadas, incluyendo la descripción del problema y la solución dada al mismo.

Los computadores deberán estar conectados a equipo de continuidad (UPS, grupo, etc).

Protección contra incendios, inundaciones o electricidad estática.

Control de acceso físico a los recursos microinformáticos: llaves de PCs. Áreas restringidas. Ubicación de impresoras (propia y de red). Prevención de robo de dispositivos. Autorización para desplazamiento de equipos. Acceso físico fuera de horario normal.

Control de acceso físico a los datos y aplicaciones: almacenamiento de disquetes con copias de backup u otra información o aplicación, procedimientos de destrucción de datos e informes confidenciales, identificación de disquetes. inventario completo de disquetes almacenados, almacenamiento de documentación.

En los computadores en que se procesen aplicaciones o datos sensibles instalar protectores de oscilación de línea eléctrica y sistema de alimentación ininterrumpida.

Implantar en la red local productos de seguridad así como herramientas y utilidades de seguridad.

Adecuada identificación de usuarios en cuanto a las siguientes operaciones: altas, bajas y modificaciones, cambio de password. explotación del log del sistema.

Controlar las conexiones remotas in/out (CAL): Módems. Gateway*. Mapped Procedures para la instalación o modificación de software y establecer que la dirección es consciente del riesgo de virus informáticos y otros software maliciosos, así como de fraude por modificaciones no autorizadas de software y datos.

Controles para evitar la introducción de un sistema operativo a través de disquete que pudiera vulnerar el sistema de seguridad establecido.

2.4. CONCLUSIONES

La importancia alcanzada por el uso (Se la informática durante lo» últimos artos ha »ido espectacular. Tras este fenómeno se encuentra el deseo de beneficiarse de lo» cuatro grandes logros que esta tecnología ha aportado:

- Racionalización de costos.
- Mejora de la capacidad de toma de decisiones, haciendo éstas más rápidas y de menor riesgo, al contar, de manera casi inmediata, con la información precita. Mejora de la calidad de los servicios debido al incremento de la capacidad para adaptarse dinámicamente al mercado.
- Nacimiento de servicios a clientes basado» en la nueva tecnología sin cuyo uto serían imposibles de ofrecer.

La informática no es algo neutro en la empresa, sino que tiene un ctocio estructurante que. aftadido a su carácter cada vez más intensivo, a la variedad creciente de las aplicaciones y a la de los medios distribuidos, la hacen estratégica Todo ello ha permitido mejorar, de manera sustancial, los resultados económicos al tiempo que se han disparado los costes de las inversiones informáticas.

La informática no sólo ha dejado de ser una simple herramienta por transformarse en un modo de estructuración de la empresa, sino que la información es uno de los actisos más importantes. Las aplicaciones de un funcionamiento anormal, aunque sea temporal, de la informática tendrán repercusiones cada vez más graves para la empresa, pudiendo incluso poner en peligro su supervivencia ante la enorme dependencia de los sistemas informáticos. La integración, en particular gracias a las redes, hace el problema todavía más grave: las consecuencias de una anomalía pueden propagarse al exterior de la empresa e incluso alcanzar al usuario final. No hay que ocultar los problemas con el pretexto de tranquilizarse, sino que conviene prepararse para aportar soluciones aun cuando éstas sean parciales al principio.

Es responsabilidad de la Dirección plantear una estrategia de inversiones en recursos informáticos así como implantar sistemas de controles internos de manera que se garanticen unos grados de eficiencia y seguridad suficientes de los acuos informáticos. Como consecuencia, aumenta la complejidad de las necesidades de control y auditoría surgiendo en las organizaciones como medidas preventivas, defectivas y correctivas las figuras de Control Interno y Auditoría Informáticos.

Es preciso supervisar continuamente los controles internos informáticos para asegurarse de que el proceso funciona según lo previsto. Esto es muy importante, porque a medida que cambian los factores internos y externos, controles que una vez resultaron idóneos y efectivos pueden dejar de ser adecuados y de dar a la Dirección la razonable seguridad que ofrecían antes.

L « funciones de Control Interno y Auditoria Informáticos prestan un servicio de vilo» áádido al ayudar a las organizaciones y a MIS directivos a cumplir sus obligaciones relativas al control interno mediante d proceso de recoger, agrupar y evaluar evidencias para determinar así un sistema informatizado salvaguarda los activos, mantiene la integridad de los datos, lleva a cabo eficazmente los fines de la Organización y utiliza eficientemente los recursos.

25.LECTURAS RECOMENDADAS

CPP Auditing. Auerhach Publications

ht/gerald. Jerry. *Controles internos para sistemas de computación.* Ed. Limusa Wiley.

Martin. James. *Security. Accuracy and Pri\xtcy m Computer System.* Ed. Preatice Hall.

Seguridad integral en las organizaciones. Ed. Trillas.

Instituto Auditores Internos de España. *Control interno, auditoria v seguridad informática.*

2.6.CUESTIONES DE REPASO

1. ¿Qué cambios en las empresas provocan tensión en el control interno existente?
2. ¿Cuáles son las funciones del control interno informático?
3. ¿Cuáles son los objetivos de la Auditoría Informática?
4. ¿Cuáles son las semejanzas y diferencias entre Control Interno y Auditoría Informática?
5. Ponga ejemplos de controles conectivos en diversas áreas informáticas.
6. ¿Cuáles son los principales controles en el área de desarrollo?
7. ¿Qué procesos definiría para controlar la informática distribuida y las redes?
8. ¿Qué controles se deberían establecer en las aplicaciones?

9. ¿Cómo justificaría ante un directivo de empresa la inversión necesaria en control ➤ auditoría infocmiika?
10. Describa la informática como modo de estructuración de las empresas.

METODOLOGÍAS DE CONTROL INTERNO, SEGURIDAD Y AUDITORÍA INFORMÁTICA

José María Genzdlez Zubieta

3.1 INTRODUCCIÓN A LAS METODOLOGÍAS

Según el *Diccionario de la lengua de la Real Academia Española*. MÉTODO es d "modo de decir o hacer con orden una con". Asimismo define el diccionario la palabra METODOLOGÍA como "conjunto de métodos que se ligen en una investigación científica o en una exposición doctrinal". Esto significa que cualquier proceso científico debe estar sujeto a una disciplina de proceso definida con anterioridad que llamaremos METODOLOGÍA

La Informática ha sido tradicionalmente una materia compejei en lodos tus aspectos, por lo que se hace necesaria la utilización de metodología« n cada doctrina que b componen, desde su diserto de ingeniería hasta el desarrollo del software, y cómo no. la auditoría de KM sistemas de información.

Las metodologías usadas por un profesional dicen mucho de su forma de entender » trabajo, y están directamente relacionadas con su experiencia profesional acumulada como parte del comportamiento humano de “acierto /error”.

Asimismo una metodología es necesaria para que un equipo de profesionales alcance un resultado homogéneo tal como si lo hiciera uno solo, por lo que resulta Habitual el uso de metodologías en las empresas audiioras/consultora.' profesionales, desarrolladas por los más expertos, pora conseguir resultados homogéneos en equipos de trabajo heterogéneos.

La proliferación de metodologías en el mundo de la auditoria y el contri informático* se pueden observar en k» primeros artos de la década de los ochenu, paralelamente al nacimiento y comercialización de determinadas hccramxnui metodológicas (como el software de análisis de riesgos). Pe» el uso de métodos* auditoria es casi paralelo al nacimiento de la informática, en la que existen mucha disciplinas cayo uso de metodologías constituye una practica habitual. Una de ellis a la seguridad de los sistemas de información.

Aunque de forma simplista se trata de identificar la seguridad informática a U seguridad lógica de los sistemas, nada está más lejos de h realidad hoy ea 6a, extendiéndose sus raíces a todos los aspectos que suponen riesgos para la informática

Éste y no otro, debe ser el campo de actuación de un auditor informática 6 finales del siglo XX. en uno de los grandes símbolos del desvTollo tecnológico de U época de la humanidad que nos ha tocado vivir.

Si definimos la "SEGURIDAD DE LOS SISTEMAS DE INFORMACIÓN" como la doctrina que trata de los riesgos informáticos o creados por la informática entonces la auditoria es una de las figuras involucradas en este proceso de protección/ preservación de la información y de sus medios de proceso.

Por tanto, el nivel de seguridad informática en una cuidad es un objetivo i esaluar y está directamente relacionado con la calidad y eficia de un conjunto de acciones y medidas destinadas a proteger y preservar la información de la entidad/ sus medios de proceso.

Resumiendo, la informática crea unos riesgos informáticos de los que hay que proteger y preservar a la entidad con un entramado de contramedidas, y la calidad y la eficacia de las mismas es el objetivo a evaluar para poder identificar así sus puntos débiles y mejorarlos. Ésta es una de las funciones de los audiures informáticos. Por tanto, debemos profundizar más en esc entramado de contrunedidas para ver qué popel tienen las metodologías y los auditores en el mismo. Para explicar este aspecto diremos que cualquier contramedida nace de la composición de varios factores expresados en el "gráfico valnr" Ar U figura 3.1.

Todos los factores de la pirámide intervienen en la composición de una contramedida.

Figura i. I. Factores que componen uno contramedula

1-A NORMATIVA debe definir de forma clara y precisa todo lo que debe existir y ser cumplido, tanto desde el punto de vista conceptual, como práctico, desde lo general a lo particular. Debe inspirarse en estándares, políticas, marco jurídico, políticas y normas de empresa, experiencia y práctica profesional. Desarrollando la normativa, debe alcanzarse el resto del “gráfico salor”. Se puede dar el caso en que una normativa y su carácter disciplinario sea el único control de un riesgo, pero no es frecuente.

1.A ORGANIZACIÓN la integran personas con funciones específicas y con actuaciones concretas, procedimientos definidos metodológicamente y aprobados por la dirección de la empresa, este es el aspecto más importante. ~~Un~~ sin él, si es posible. Se pueden establecer controles sin alguno de los demás aspectos, pero nunca sin personas, ya que son estas las que realizan los procedimientos y desarrollan los Planes (Plan de Seguridad. Plan de contingencias, auditorías, etc.).

LAS METODOLOGÍAS son necesarias para desarrollar cualquier proyecto que nos proponamos de manera ordenada y eficaz.

LOS OBJETIVOS DE CONTROL son los objetivos* a cumplir en el control de procesos. Este concepto es el más importante después de “LA ORGANIZACIÓN”, y solamente de un planteamiento correcto de los mismos saldrán unos procedimientos eficaces y realistas.

- LOS PROCEDIMIENTOS DE CONTROL son los procedimientos operativos de las distintas áreas de la empresa, obtenidos con una metodología apropiada, para la consecución de uno o varios objetivos de control y, por tanto, deben de estar documentados y aprobados por la Dirección. La tendencia habitual de los informáticos es la de dar más peso a la herramienta que al "control o contramedida", pero no debemos olvidar que "UNA HERRAMIENTA NUNCA ES UNA SOLUCIÓN SINO UNA AYUDA PARA CONSEGUIR UN CONTROL MEJOR". Sin la existencia de estos procedimientos, las herramientas de control son solamente una anécdota.
- Dentro de la TECNOLOGÍA DE SEGURIDAD e «aí todos los elementos, ya sean hardware o software, que ayudan a controlar un riesgo informático. Dentro de este concepto están los cifradores, autenticadores, equipos "tolerantes al fallo", las herramientas de control, etc.
- LAS HERRAMIENTAS DE CONTROL son el conjunto de software que permiten definir uno o varios procedimientos de control para cumplir una normativa y un objetivo de control.

Todos estos factores están relacionados entre sí, así como la calidad de cada uno con la de los demás. Cuando se evalúa el nivel de Seguridad de Sistemas en una institución, se están evaluando todos estos factores (pirámide) y se plantea un Plan de Seguridad nuevo que mejore todos los factores, aunque conforme vayamos realizando los distintos proyectos del plan, no irán mejorando todos por igual. Al finalizar el plan se habrá conseguido una situación nueva en la que el nivel de control sea superior al anterior.

Llamaremos PLAN DE SEGURIDAD a una estrategia planificada de acciones y productos que lleven a un sistema de información y su centro de proceso de una situación inicial determinada (y a mejorar) a una situación mejorada.

En la figura 3.2 se expone la tendencia actual en la organización de la seguridad de sistemas en la empresa. Por una parte un comité que estaría formado por el director de la estrategia y de Informática. Y por otro lado el sistema de control interno y auditoría informática. La función de control interno se ve involucrada en la realización de los procedimientos de control y es una labor de día a día. La función de auditoría informática está centrada en la evaluación de los distintos aspectos que designe su PLAN AUDITOR, con una serie de características de trabajo que son las siguientes: concreta al centro, con objetivos concretos y, tras terminar su trabajo, la presentación del informe de resultados. Por tanto, las características de su función son totalmente distintas. Lógicamente también sus métodos de trabajo.

Figura S.2. Organización interna de la seguridad informática

Queda, pues, por decir que ambas funciones deben ser independientes de la informática. dado que por la disciplina laboral la labor de la« dos funciones quedaría mediatizada y comprometida. F.tío es lo que se llama "segregación de funciones" ctttrt éstas y la informática.

3.2 METODOLOGIAS DE EVALUACIÓN DE SISTEMAS

3.2.1 Conceptos fundamentales

En el mundo de la seguridad de sistemas se utilizan todas las metodologías necesarias para realizar un plan de seguridad además de las de auditoría informática.

Las dos metodologías de evaluación de sistemas por antonomasia son las de ANÁLISIS DE RIESGOS y las de AUDITORÍA INFORMÁTICA, con dos enfoques distintos. La auditoría informática sólo identifica el nivel de "exposición" por la falta de controles, mientras el análisis de riesgos facilita la "evaluación" de k» riesgos y recomienda acciones en base al costo-beneficio de las mismas.

Introduzcamos una serie de definiciones para profundizar en esus metodologías.

- AMENAZA: una(s) persooa(s) o cosáis) vistáis) como posible fuente de peligro o catástrofe. Ejemplos: inundación, incendio, robo de datos, sabotaje, agujeros publicados, falta de procedimientos de emergencia, divulgación de

datos. implicaciones con la ley. aplicaciones mal disertadas. gasu» incontrolado*, etc.

- **VULNERABILIDAD:** La situación creada, por la falta de uno o vario» controles, con la que la amenaza pudiera acaecer y así afectar al entone informático. Ejemplos: falta de control de acceso lógico, falta de control de versiones, inexistencia de un control de sopones magnéticos, falta de separación de entorno* en el sistema, falta de cifrado en I» telecomunicaciones, etc.
- **RIESGO:** La probabilidad de que una amenaza llegue a acaecer por usa vulnerabilidad. Ejemplo: los datos estadísticos de cada evento de una base de datos de incidentes.
- **EXPOSICIÓN O IMPACTO:** La evaluación del efecto del riesgo. Ejemplo: e* frecuente evaluar el impacto en términos económico*, aunque no siempre l» es. como vidas humanas, imagen de la empresa, honor, defensa nacional, etc.

Las amenazas reales se presentan de forma compleja y son difíciles de predecir. Ejemplo: por varias causas se rompen las dos entradas de agua, inundan las línea» telefónicas (pues existe un poro en el cable), hay un cortocircuito y se quema d transformador de la central local. En cao« casos la probabilidad resultante es muy difícil de calcular.

Las metodologías de análisis de riesgos se utilizan desde los afta* setenta, en b industria del seguro basándose en grandes volúmenes de datos estadístico* agrupado« en tablas aduana*. Se emplearon en la informática en los ochenta, y adolecen dd problema de que los registros estadísticos de incidentes son escasos y. por unto, d rigor científico de ky* cálculos probabilítfko* es pobre. Aunque existen bases de incidentes en varios países, estos dalos no son muy fiables por varios motivos: la tendencia a la ocultación de los afectados, la localización geográfica, las distintas mentalidades, la informática cambiante, el hecho de que los riesgo* *e presentan en u* periodo de tiempo solamente (ventana de criticidad). etc.

Todos los riesgos que se presentan podemos:

- EVITARLOS (por ejemplo: no construir un centro donde hay peligro constante de inundaciones).
- TRANSFERIRLOS (por ejemplo: uso de un centro de cálculo contratado).
- REDUCIRLOS (por ejemplo: sistema de detección y extinción de incendios).
- ASUMIRLOS- Que e* lo que se hace si no se controla el riesgo en absoluto.

Para los tres primeros, «e actúa si se establecen controles» o contramedida». Todas las metodologías existentes en seguridad de sistemas van encaminadas a establecer y mejorar un entramado de contramedidas que garanticen que la probabilidad de que la amenaza se materialice en hechos (por falta de control) sea lo más baja posible o al menos quede reducida de una forma razonable en costo-beneficio.

3.2.2. Tipos de metodologías

Todas las metodologías existentes desarrolladas y utilizadas en la auditoría y el control informático, se pueden agrupar en dos grandes familias. Estas son:

- Cuantitativa: Basada en un modelo matemático numérico que ayuda a la realización del trabajo.
- Cualitativa: Basada en el criterio y raciocinio humano capaz de definir un proceso de trabajo, para seleccionar en base a la experiencia acumulada.

3.2.2.1. Metodologías cuantitativas

Disertadas para producir una lista de riesgos que pueden compararse entre sí con facilidad por tener asignados unos valores numéricos. Estos valores en el caso de metodología de análisis de riesgos o de planes de contingencia son datos de probabilidad de ocurrencia (riesgo) de un evento que se debe extraer de un registro de incidencias donde el número de incidencias tienda al infinito o sea suficientemente grande. Esto no pasa en la práctica, y se aproxima ese valor de forma subjetiva otorgando así rigor científico al cálculo. Pero dado que el cálculo se hace para ayudar a elegir el método entre varias contramedidas podríamos aceptarlo.

Hay varios coeficientes que conviene definir

- ALE. (*Annualized Loss Expectancy*): multiplicar la pérdida máxima posible de cada bien/recurso por la amenaza con probabilidad más alta
Reducción del ALE. (*Annualized Loss Expectancy*): Es el cociente entre el COSI anualizado de la insulachfci y el incremento de la pérdida contra el valor total del bien/recurso que se está protegiendo, en tanto por ciento.
- Retorno de la inversión (R.O.I.): ALE. original menos ALE. reducido (como resultado de la medida), dividido por el coste anualizado de la medida

Todo esto y otros coeficientes y otros disertados por los autores de las metodologías son usados para el juego de simulación que permite elegir entre varias contramedidas para el análisis de riesgos.

Por lanío, vemos con claridad dos grandes inconvenientes que presentan e«us metodologías: por una pane la debilidad de los dalos de la probabilidad de ocurre*» por los pocos registros > la poca significación de los mismos a nivel mundial, y por otra la imposibilidad o dificultad de evaluar económicamente lodos los impactos que pueden acaecer frente a la ventaja de poder usar un modrlo matemático pan d análisis.

3.2.2.2. Metodologías cualitatisas/xubjefivas

Basadas en métodos estadísticos y lógica borrosa (humara, no matemática. f^*zj *tologic*). Precisan de la *imvlucractón* de un profesional experimentado. Pero requiera menos recursos humanos/tiempo que las metodologías cuantiutivas.

La tendencia de uso en la realidad es la mezcla de ambts. En la figura 3.3 K observa un cuadro comparatisi».

3.2.3. Metodologías más comunes

Las metodologías más comunes de evaluación de sistemas que podemoi encontrar son de análisis de riesgos o de diagnósticos de seguridad, las de plan de contingencias, y las de auditoria de controles generales.

U J.I. Mdodalocia.« de análisis de riesgos

Están desarrolladas para la identificación de la falta de controles y el debilitamiento de un plan de contramedidas. Existen dos tipos: LAS CUANTITATIVAS y LAS CUALITATIVAS, de las que existen gran cantidad de nuevas clases y sólo citaremos algunas de ellas.

El esquema básico de una metodología de análisis de riesgos es, en esencia, el representado en la figura 3.4.

En base a unos cuestionarios se identifican vulnerabilidades y riesgos y se evalúa el impacto para poder identificar las contramedidas y el coste, la siguiente etapa es la más importante, pues mediante un juego de simulación (que llamaremos "¿QUÉ PASA SI...?") analizamos el efecto de las distintas contramedidas en la disminución de los riesgos analizados, eligiendo de esta manera un plan de contramedidas (plan de seguridad) que compondrá el informe final de la evaluación.

Otra forma genérica las metodologías existentes se diferencian en:

- Si son cuantitativas o cualitativas, o sea si para el "¿Qué pasa si L.T'" utilizan un modelo matemático o algún sistema cercano a la elección subjetiva. Aunque, bien pensado, al aproximar las probabilidades por esperanzas matemáticas subjetivamente, las metodologías cuantitativas, aunque utilicen aparatos matemáticos en sus simulaciones, tienen un gran componente subjetivo.
- Y además se diferencian en el propio sistema de simulación.

En el INFOSEC92 proyecto S2014 se identificaron 66 metodologías de las cuales, por limitaciones de tiempo, se analizaron sólo 12 con sus respectivos paquetes.

y u i el informe «de este trabajo acabó siendo un contraste de Us (icnucionet de dicta paquete* según lo* fabricante* y la opinión de la* consultore* del equipo. E«oi método* analizado* eran: ANAUZY. BDSS. BIS RISK ASSESOR. BUDDY SYSTEM. COBRA. CRAMM. DD1S MARION AP*. MELISA. RISAN. RISKPAC. RISKWATCH.

Después de e*tas metodologías han nacido mucha* otras como, por ejemplo, U MACERfT. desarrollada por b administración espartóla. Citaremos algunas a modo de ejemplo:

Figura 3.6. Cuestionario para iatorar la seguridad

MARION

Método documentado en dos libros de los cuales el más actual es *La Sécurité des réseaux-Methodes et Techniques* de J.M. Lameré y Leroux. J. Toorty. Tiene dos productos: MARION AP+, para sistemas individuales, y MARION RSX para sistemas distribuidos y conectividad.

Es un método cuantitativo y se basa en la encuesta anual de miembros del C.L.U.S.I.F. (base de incidentes francesa). No contempla probabilidades, sino esperanzas matemáticas que son aproximaciones numéricas (valores subjetivos).

La MARION AP+ utiliza cuestionarios y parámetros correlacionados enfocados a la representación gráfica de las distintas soluciones de contramedidas (figura 3.5). en cada uno de los factores (27 factores en seis categorías). Las categorías son: seguridad informática general, factores socioeconómicos, concienciación sobre la seguridad de software y materiales, seguridad en explotación y seguridad de desarrollo.

Figura 3.7. Valores de ponderación para diferentes sectores

En la figura 3.6 se puede ser un cuestionario al que hay que responder sí con un 4. no con un cero, y *i no aplicable*, para luego aplicarle« uno» valore* de ponderación según los sectores de la figura 3.7 de negocio de la empresa donde st esté pasando la metodología. El cuestionario de la figura 3.6 correspondería al factor 101.

El análisis de riesgos k> hace «obre diez ireas problemática» con otros cuestionario». Estas áreas son riesgos materiales, sabotajes físicos, averías, comunicaciones, errores de desarrollo, errores de explotación, fraude, robo de información, robo de software, problemas de personal. Sirve para evaluar el impacto ífigura 3.8).

Las pérdidas posibles no deben sobrepasar nunca el valor del "RIESGO MÁXIMO ADMISIBLE", vaio» extraído de los valores dados por un estudio del Banco de Francia donde figuran 50 ramos para distintas áreas sectoriales ya mencionadas en la figura 3.7. El diagrama de la figura 3.8 se llama de radar, y la metodología MELISA usa uno similar. Esta metodología es de las más antiguas ; difíciles de entender y manejar.

RISCKPAC

Todas las metodologías que se desarrollan en la actualidad están pensadas para su aplicación en herramientas. La primera de esta familia la desarrolló PROMU: ANALYSIS CORPORATION, y la primera instalación en cliente data de 1984. Según DATAPRO es el software más vendido.

Su enfoque es metodología cualitativa/subjetiva. Sus resultados son exportables a procesadores de texto, bases de datos, hoja electrónica o sistemas gráficos. Está estructurada en los tres niveles Funtion/Procesador/Aplicación* con 26 categorías de riesgo en cada nivel. Tiene un "¿qué pasa si...?" con un nivel de riesgo de evaluación subjetiva del 1 al 5 y ofrece una lista de contramedidas o recomendaciones básicas para ayuda al informe final o plan de acciones.

CRAMM

Se desarrolló entre 1985 y 1987 por BIS y CCTA (CENTRAL COMPUTER & TELECOMMUNICATION AGENCY RISK ANALYSIS & MANAGEMENT METHOD. Inglaterra). Implantado en más de 750 organizaciones en Europa, sobre todo de la administración pública. Es una metodología cualitativa y permite hacer análisis "¿Qué pasa si...?".

PRIMA (PREVENCIÓN DE RIESGOS INFORMÁTICOS CON METODOLOGÍA ABIERTA)

Es un compendio de metodologías desarrolladas entre los años 1990 y la actualidad con un enfoque subjetivo. Sus características esenciales son:

- Cubrir las necesidades de los profesionales que desarrollan cada uno de los proyectos necesarios de un plan de seguridad.
- Fácilmente adaptable a cualquier tipo de herramienta.
- Posee cuestionarios de preguntas para la identificación de debilidades o faltas de controles.

- Posee listas de ayuda para los usuarios menos experimentados de debilidades, riesgo» y contramedidas (sistema de ayuda)
- Pemute fácilmente la generación de informe« final».
- Las “Lista« de ayuda" (figura 3.10) y los cuestionarios son abierto«, y por tanto es potable introducir información nueva o cambiar la existente. De ah(la expresión Abierta de «u nombre.
- Tiene un "¿qué pasa cualitativo, y capacidad de aprendizaje al poseer una base de conocimiento o registro de incidentes que van variando las esperanza« matemáticas de partida y adaptándose a los entornos de trabajo.

En las figuras 3.9 y 3.10 se expone b metodología de análisis de riesgo« PRIMA.

Con la misma filosofía abierta existen del mismo autor, en b actualidad, las siguientes metodologías:

- Análisis de riesgos.
- Plan de contingencias informática y de recuperación del negocio.
- Pbn de restauración interno informático.
- Clasificación de b información.
- Definición y desarrollo de procedimientos de control informáticos.
- Pbn de cifrado.
- Auditoría informática.
- Definición y desarrollo de control de acceso lógico. Entornos distribuidos y single sig-on.

Figura i. ¿O. Mita de ayuda de la metodología PRIMA

3.2J.2. Plan de contingencias

El auditor debe conocer perfectamente los conceptos de un plan de contingencia* para poder auditorio. Hay varias formas* de llamarlo, pero conviene no confundir. Un concepto* que KC manejan alrededor de los nombres*. El plan de contingencia* y de recuperación del negocio es* lo mismo, pero no así el plan de restauración interno. Éste va enfocado hacia la restauración del C.P.D., pero sobre eventos* que suceden dentro del entorno (caídas del sistema, roturas leves, etc.), y cuya duración no afecta gravemente a la continuidad del negocio.

También se manejan a veces los conceptos* de plan de contingencias informática y plan, de contingencia* corporativo, cuyos conceptos son sólo de alcance. El corporativo cubre no sólo la informática, sino todos los departamentos* de una entidad, y puede incluir también el informático como un departamento más. Frecuentemente se realiza el informático.

DEFINICIÓN. El Plan de Contingencias es una estrategia planificada constituida por: un conjunto de recursos de respaldo, una organización de emergencia y unos procedimientos de actuación encaminada a conseguir una restauración progresiva y ágil de los servicios de negocio afectados por una paralización total o parcial de la capacidad operativa de la empresa.

Esa estrategia, materializada en un manual, es el resultado de todo un proceso de análisis y definiciones que es lo que da lugar a las metodologías. Esto es, las metodologías que existen versan sobre el proceso necesario para obtener dicho plan.

Es muy importante tener en cuenta que el concepto a considerar es* “la continuidad del negocio- : estudiar todo lo que puede paralizar la actividad y producir pérdidas. Todo lo que no considere este criterio no será nunca un plan de contingencias.

FASES DE UN PLAN. Las fases de un plan son las siguientes:

FASE I. ANÁLISIS Y DISEÑO. Se estudia la problemática, las necesidades de recursos, las alternativas de respaldo, y se analiza el coste/beneficio de las mismas, fue la fase más importante, pudiendo llegarse al final de la misma incluso a la conclusión de que no es viable o es muy costoso su seguimiento. En la forma de desarrollar esta fase, se diferencian las dos familias metodológicas*. Éstas son las de “RISK ANALYSIS” y las de “BUSINESS IMPACT”.

Las de Risk Analysis se basan en el estudio de los posibles riesgos desde el punto de vista de probabilidad de que los mismos sucedan. Aunque los registros de accidentes, al igual que ocurría en las metodologías de análisis de riesgos, son escasos y poco fiables, aun así es más fácil encontrar este tipo de metodologías que las segundas.

Las de Business Impact, se basan en el estudio del impacto (pérdida económica o de imagen) que ocasiona la falta de algún recurso de los que soporta la actividad del negocio. Estas metodologías son más escasas, pero tienen grandes ventajas como es el mejor entendimiento del proceso o el menor empleo de tiempo de trabajo por ir más directas al problema.

Las tareas de esta fase en las metodologías de Risk Analysis son las siguientes:

1. Identificación de amenazas.
2. Análisis de la probabilidad de materialización de la amenaza.
3. Selección de amenazas.
4. Identificación de entornos amenazados.
5. Identificación de servicios afectados.
6. Estimación del impacto económico por paralización de cada servicio.
7. Selección de los servicios a cubrir.
8. Selección final del ámbito del Plan.
9. Identificación de alternativas para los entornos.
10. Selección de alternativas.
11. Descripción de estrategias de respaldo.
12. Selección de las estrategias de respaldo.

La» laucas pora 1« de Business Impaci son las siguientes:

1. Identificación de servicios finales.
2. Análisis del impacto. En estas metodologías se evalúan los datos económicos y de imagen y otros aspectos no económicos, lo que 1« da una veMaja en ks casos en los que intervienen otros valores que no sean los económicos.
3. Selección de servicios críticos.
4. Determinación de recursos de soporte.
5. Identificación de alternativas pora entornos.
6. Selección de alternativas.
7. Diserto de estrategias globales de respaldo.
8. Selección de la estrategia global de respaldo.

Como puede verse, el enfoque de esta segunda es más práctico y xe va mis directo a las necesidades reales de la entidad sin tener que justificar con datos de probabilidades que aportan poco por la pobreza de los datos. Éstas se basan en hech» ciertos, que se analizan y se justifican económicamente. Permiten, por tanto, hacer estudios costo/beneficio que justifican las inversiones con má> rigor que los estudios de probabilidad que se obtienen con los análisis de riesgos.

Hay un factor importante a determinar en esta fase que es el *Time Fronte* o tiempo que la empresa puede asumir con paralización de la attividad operativo ¿-Jes de incurrir en pérdidas significativas. Este factor marcirà las estrategias de recuperación y se extraerà del análisis del impacto.

FASE II: DESARROLLO DEL PLAN. Esta fase y la tercera son similares es todas las metodologías. En ella se desarrolla la estrategia seleccionada implantándose hasta el final todas las acciones previstas. Se definen las distintas organizaciones de emergencia y se desarrollan los procedimientos de actuación generando así li documentación del plan.

Es en esta fase cuando se analiza la vuelta a la normalidad, dado que pasar de U situación normal a la *ahematira* debe concluirse con la reconstrucción de la situacite inicial antes de la contingencia y esto es lo que no todas las metodologías incluyen.

FASE III: PRUEBAS Y MANTENIMIENTO. En esla fase se definen 1« prueHm. «us caracerfrsic» y sus ciclos, y se realiza la *primen prueba* como comprobación de todo el trabajo realizado, así como mentalizar al personal implicada

Asimismo se define la estrategia de mantenimiento, la organización destinada i ello y la normativa y procedimientos necesarios pora llevarlo a cabo

IIERRAMIEWTAS. En este caso, como en todas las metodologías la herramiecu es una anécdota y lo importante es tener y usar la mctocblogfa apropiada pan

dturrollar mis tarde la hcnamicnta que *c necesite. fçJ esquema de una herramienta dete tener al menos los uguicntes puntos:

- base de datos relacionar
- módulo de entrada de datos
- módulo de consultas
- proceso de textos
generador de informes
- a)vdas *on-lme*
- hoja de cálculo
- gestor de proyectos
- generador de gráficos

Existen en el mercado producios que cubren estas metodologías, en menor cantidad que los de análisis de riesgos y enfocados sobre todo a análisis de nesgo* con ditos de poca significación científica. Hoy en día la mayoría le tos equipos profesionales desarrollan su software al oomten/o de lo« trabajos tras definir la netodología

Es importante para terminar este punto decir que una práctica hatitual es realizar la fase I y contratar un servicio de *back-up* sin desarrollar las fases II y III. Esto no *Mo* constituye un error conceptual, sino que en realidad sólo se tiene un estudio y un contrato de servicios pero no un PLAN DE CONTINGENCIAS.

3.3. LAS METODOLOGÍAS DE AUDITORIA INFORMÁTICA

Las únicas metodologías que podemos encontrar en la auditoría informática son do» familias distintas: las auditorías de CONTROLES GENERALES como produelo estándar de la auditores profesionales, oue son una homologación de las mismas a «rífl internacional, y las METODOLOGIAS de los auditores internos.

El objetivo de las auditorías de controles generales es "dar una «pintón sobre la natiilnlod de lus datus del computador para la auditoría financiera". El rebultado externo es un escueto informe como parte del informe de auditoría, dende *e destacan lat vulnerabilidades encontradas. Están basadas en pequeño* cuestionarios estándares que dan como resultado informes muy generalistas.

Tienen apañados para definir “pruebas” y anotar sus resultados. Ésta es una característica clara de la diferencia con las metodologías de evaluación de la consultaría como la* de análisis de riesgos *que no timen estos apenados*, aunque urribiín tratan de identificar vulnerabilidades o falta de controle; Esto es. la ratizaoón de pruebas e* consustancial a la auditoría, dado que tarto el trabajo de con«litaría como el análisis de riesgos espera siempre la colaboración del analizado, y

por el contrario la auditoria debe demostrar con pruebas toda», u n afirmaciones. y pa ello siempre debe contener el apartado de las pruebas. Llegando al extremo de que hay auditorías que se basan sólo en pruebas como la "auditoría de integridad- .

fcsta\ metodologías están muy desprestigiada*, pero no porque sean malas en í mismas, sino porque dependen mucho de la experiencia de ka profesionales que la usan y existe una práctica de utilizarlas profesionales sin ningún experiencia.

Ninguna de estas metodologías usa ayudas de contramedida*. Llegándose a U aberración de que se utilizan metodologías de análisis de riesgos para hacer auditorias.

Todas estas anomalías nacen de la dificultad que tiene un profesional sa experiencia que asume la función auditora y busca una fórmula fácil que le perrina empezar su trabajo rápidamente. Esto ex una utopía El auditor informático necesita una larga experiencia tutelada y una gran formación tanto audtora como mformíbea. Y esta formación debe ser adquirida mediante el estudio y la práctica tutelada.

Llegamos al punto en el que es necesario decir que la netodología de aud*r ■Memo debe ser disertada y desarrollada por el propio ajditor. y ésta será b significación de su grado de experiencia y habilidad.

Por unto, entre la* dos metodologías de evaluación de sistemas (análisis de riesgo* y auditoria) existen similitudes y grandes diferencias. Ambas tienen pápelo de trabajo obtenidos del trabajo de campo tras el plan d< entrevistas, pero Vs cuestionarios son totalmente distintos. Los de la figura 3.6 son de análisis de nesgas y se trata de preguntas dirigidas a la identificación de la falu de controles. Se vea dirigidas a consultores por la planificación de los tiempo* y por ser preguntas mis concretas.

En el punto 3.7 se expone un ejemplo real de una metodotigía de auditor interno necesaria para revisar cualquier aplicación. Como se ve en el ejemplo esU formad» por recomendaciones de plan de trabajo y de lodo el proceso que debe segar También define el objetivo de la misma, que habrá que describílo en el memorindura de apertura al auditado. Asimismo lo describe en forma de oestionarios genéricos, con una orientación de los controles a revisar.

En este caso del auditor interno informático le servirá de ¿uía pora confecciona el programa real de trabajo de la auditoria. El auditor deberá hacer los cuestionarios más detallados si así lo estima oportuno y definir cuanus pmtbas estime oportunas Asimismo, si cuando empieza una auditoria el auditor deteru vía* alternativas a revisar, su deber es seguirla* cambiando el plan de trabajo. Per tanto, el concepto de las metodologías de análisis de riesgos de "tiempos medid**" es mis bien pm consultores profesionales que para auditores interno*, listos, aunque deben planificar

MU tiempos. en principio no deben constituir nunca su factor principal. dado que la función es la de vigilancia, y ésta se cumple si el auditado se viene vigilado.

El auditor interno debe crear sus metodologías necesarias para auditar los distintos aspectos o áreas que defina en el plan auditor que veremos en el siguiente punto.

También es interesante aclarar que hay herramientas software de ayuda a la auditoría de cuentas que aunque se les llame herramientas de auditoría, sólo lo son para los auditores de cuentas, y esto no es auditoría informática sino ayuda a la auditoría de cuentas.

Es decir, que no es lo mismo ser una informática de los auditores que ser auditor informático. La auditoría financiera es un dictamen sobre el estado de cuentas. Y la auditoría informática es una auditoría en sí misma, y si el auditor informático no certifica la integridad de los datos informáticos que usan los auditores financieros, éstos no deben usar los sistemas de información para sus dictámenes. Tal es la importancia de la existencia de los auditores informáticos, que son los garantes de la veracidad de los informes de los auditores financieros que trabajan con los datos de los sistemas de información.

El esquema metodológico del auditor está definido por el plan auditor que vemos a continuación.

3.4. EL PLAN AUDITOR INFORMÁTICO

Es el esquema metodológico más importante del auditor informático. En este documento se debe describir todo sobre esta función y el trabajo que realiza en la entidad. Debe estar en sintonía con el plan auditor del resto de los auditores de la entidad.

Las partes de un plan auditor informático deben ser al menos las siguientes:

- Funciones. Ubicación de la figura en el organigrama de la empresa. Debe existir una clara segregación de funciones con la Informática y de control interno informático, y éste debe ser auditado también. Deben describirse las funciones de forma precisa, y la organización interna del departamento, con todos sus recursos.
- Procedimientos para las distintas tareas de las auditorías. Entre ellos están el procedimiento de apertura, el de entrega y discusión de debilidades, entrega de informe preliminar, cierre de auditoría, redacción de informe final, etc.

- Tipos de auditorías que realiza. Metodologías y cuestionarios de las mismas. Ejemplo: revisión de la aplicación de facturación, revisión de la LOPD, revisión de seguridad física, revisión de control interno, etc. Existen «tres tipos de auditorías según su alcance: b Full o completa de una área (por ejemplo: control interno, informática, limitada a un aspecto: por ejemplo: una aplicación, la seguridad lógica, el software de base, etc.), la Corrective Action Review (CAR) que es la continuación de acciones correctivas de auditorías anteriores.
- Sistema de evaluación y los distintos aspectos que evalúa. Independientemente de que exista un plan de acciones en el informe final, debe hacerse el esfuerzo de definir varios aspectos a evaluar como nivel de gestión económica, gestión de recursos humanos, cumplimiento de normas, etc., así como realizar una evaluación global de resumen para toda la auditoría. En nuestro país esta evaluación suele hacerse en tres niveles que son "Bien", "Regular", o "Mal", significando la visión de grado, de gravedad. Esta evaluación final nos servirá para definir la fecha de repetición de la misma auditoría en el futuro según el nivel de exposición que se le haya dado a este tipo de auditoría en cuestión.

CICLO DE AUDITORIAS_____

Figura J. 11. Método de exposición para definir la frecuencia de la auditoría

- Nivel de exposición. Con este ejemplo podemos ver la figura 3.11. El nivel de exposición es en este caso un número del uno al diez definido subjetivamente y que me permite en base a la evaluación final de la última auditoría realizada sobre ese tema definir la fecha de la repetición de la misma auditoría. Este número no conviene confundirlo con ninguno de los parámetros utilizados en el análisis de riesgo que está enfocado a probabilidad de ocurrencia. En este caso el valor del nivel de exposición significa la suma de factores como impacto, peso del área, situación de control en el área. O sea se puede incluso

rebajar el nivel de un área auditada porque está muy bien y no merece la pena revivarla tan a menudo.

- lista de distribución de informe*.
- Seguimiento de bu acciones» corredoras.
- lian quinquenal. Todas la« áreas a auditar deben corresponderse con cuestionarios metodológico* y deben repartirse en cuatro o cinco aAos de trabajo. Ksta planificación, además de las repeticiones y añadido de las auditorías no programadas que se estimen oportunas, deberá componer anualmente el plan de trabajo anual.
- lian de trabajo anual. Deben estimarse tiempos de manera racional y componer un calendario que una ve/ terminado nos d< un resultado de horas de trabajo previstas y. por tanto, de lo* recunos que se necesitarán.

Debemos hacer notar que es interesante tener una herramienta programada con metodología abierta que permita confeccionar los cuestionario* de las distintas auditorias y cubrir fácilmente los hitos y fases de los programas de trabajo una vez definida la metodología completa. Bao te puede hacer sin dificultad con cualquier herramienta potente de las que existen en la actualidad.

Las metodologías de auditoria informática son del tipo cualitativoVsubjetivo. Pedemos decir que son las subjetivas por excelencia. P«ir tanto, están basadas en profesionales de gran nivel de experiencia y formación, capaces de dictar recomendaciones técnicas, operativas y jurídicas, que exigen una gran profesionalidad y formación continuada. Sólo así esta función se consolidará en las entidades, esto es, por el "respeto profesional" a los que ejercen la función.

3.5. CONTROL INTERNO INFORMÁTICO. SUS MÉTODOS Y PROCEDIMIENTOS. LAS HERRAMIENTAS DE CONTROL

3.5.1 La función de control

Hoy en día la tendencia generalizada es contemplar, al lado de la figura del auditor informático, la de control interno informático. Tal es el caso de la organización internacional I.S.A.C.A. (Information Systems Audit and Control Association) que con anterioridad se llamó The EDP Auditor* Association Inc.

Aunque hay una cierta polémica profesional con esta función y no existe una aceptación tan clara como la función de auditoría informática, parece razonable y sin «tención de crear doctrina definirla como existe en general en muchas multinacionales.

La función de Control Informático Independiente debería ser en primer lugar independiente del departamento controlado. Ya que "por segregación de funciones U informática no debería controlarte a sí misma". Partiendo de la base de un concepto en el que la seguridad de sistemas abarca un campo mucho mayor de lo que es la seguridad lógica, podríamos decir que:

- El área informática monta los procesos informáticos seguros.
- El Control interno monta los controles.
- La Auditoría Informática evalúa el grado de control.

Por tanto, podríamos decir que existen claras diferencias entre las funciones de control informático y las de auditoría informática.

1.a Auditoría Informática

- Tiene la función de vigilancia y evaluación mediante dictámenes, y todas sus metodologías van encaminadas a esta función.
- Tiene sus propios objetivos distintos a los auditores de cuentas, aunque necesarios para que éstos puedan utilizar la información de sus sistemas para sus evaluaciones financieras y operativas. Evalúan eficiencia, costo y seguridad en su más amplia visión. es decir todos los riesgos informativos, ya sean los clásicos (confidencialidad, integridad y disponibilidad), o los costos y los jurídicos, dado que ya no hay una clara separación en la mayoría de los casos.
- Operan según el plan auditor.
- Utilizan metodologías de evaluación del tipo cualitativo con la característica de las pruebas de auditoría.
- Establecen planes quinquenales como ciclos completos.
- Sistemas de evaluación de repetición de la auditoría por nivel de exposición del área auditada y el resultado de la última auditoría de esta área.
- La función de soporte informático de todos los auditores (opcionalmente), aunque dejando claro que no se debe pensar con esto que la auditoría informática consiste en esto solamente.

Control Interno Informático

- Tiene funciones propias (administración de la seguridad lógica, etc.).
- Funciones de control dual con otros departamentos.
- Función normativa y del cumplimiento del marco jurídico.

- Operan según procedímiemos de control en lo* que se ven involucrados y que luego se desarrollarán.
- Al igual que en la auditoría y de forma opcional pueden ser el soporte informático de control interno no informático.

Podemos pasar ya a proponer las funcione» de control interno más comunes:

- Definición de propietarios y perfiles según "Clasificación de la Información" (utilizando metodología).
- Administración delegada en Control Dual (dos personas intervienen en una acción como medida de control) de la seguridad lógica.
- Responsable del desarrollo y actualización del Plan de Contingencias. Manuales de procedimientos y Plan de Seguridad.
- Promover la cultura de Seguridad Informática al Comité de Seguridad.
- Dictar Normas de Seguridad Informática.
- Definir los Procedimientos de Control.
- Control del Entorno de Desarrollo.
- Control de Soportes Magnéticos según la Clasificación de la Información.
- Control de Soportes Físicos (listados, etc.).
- Control de Información Comprometida o Sensible.
- Control de Microminformática y Usuarios.
- Control de Calidad de Software.
- Control de Calidad del Servicio Informático.
- Control de Costes.
- Responsable del Departamento (gestión de recursos humanos y técnicos).
- Control de Licencias y Relaciones Contractuales con terceros.
- Control y Manejo de Claves de cifrado.
- Relaciones externas con entidades relacionadas con la Seguridad de la Información.
- Definición de Requerimientos de Seguridad en Proyectos Nuevos.
- Vigilancia del Cumplimiento de las Normas y Controles.
- Control de Cambios y Versiones.
- Control de Paso de Aplicaciones a Explotación.
- Control de Medidas de Seguridad Física o corporativa en la Informática.
- Responsable de Datos Personales (LOPD y Código Penal).
- Otros controles que se le designen.
- Otras funciones que se le designen.

Todas estas funciones son un poco ambiciosas para desanclarlas desde el instante inicial de la implantación de esta figura, pero no debemos perder el objetivo de que el control informático es el componente de la "actuación segura" entre los usuarios, la informática y control interno, todos ellos auditado? por auditoría informática-

Para obren« el entramado de contramedida* o contrito, compuesto pe» la factores que veíamos en la figura 3.1. deberemos ir abortando proyecto« usafe distintas metodologías, ul como se observa en la figura 3.12.que irán confomuedoj mejorando el número de controles.

Figura 3.12. Obtención de tos controlej

Este plan de proyectos lo llamaremos "Plan de Seguridad Informática". Dos de estos proyectos de vital importancia son la Xclasificación de la Información" y los "Procedimientos de Control- . El punto B) de la figura corresponde al primero y el Cl al segundo, y sus metodologías se ven a continuación.

3.5.2. Metodologías de clasificación de la información y de obtención de los procedimientos de control

Clasificación dr la información

No es frecuente encontrar metodologías de o te tipo, pero U metodología PRIMA tiene do* módulos que desarrollan estos dos aspecto« y que vemos a continuación.

Contemplando la figura 3.12 podrían*» preguntamos si es suficiente con un análisis de riesgos para obtener un plan de contramedidas qte nos llevará a una situación de control como se desea, I-a respuesta es no. dado q»e todas las entidades de información u proteger no tienen el mismo grado de importancia, y el análisis de riesgos metodológicamente no permite aplicar una diferenciacrfn de contramedidas según el activo o recurvo que protege, sino por la probabilidad del riesgo analizado.

Tiene que ver otro concepto, como el que se baraja en la clasificación de la información. Esto es "SI IDENTIFICAMOS DISTINTOS NIVELES DE CONTRAMEDIDAS PARA DISTINTAS ENTIDADES DE INFORMACIÓN CON DISTINTO NIVEL DE CRITICIDAD. ESTAREMOS OPTIMIZANDO LA EFICIENCIA DE LAS CONTRAMEDIDAS Y REDUCIENDO LOS COSTOS DE LAS MISMAS".

Por ejemplo, si en vez de cifrar la red de comunicaciones por igual tomo* capaces de diferenciar por qué línea* va la información que clasificamos como Restringida a lo» propietario* de la misma. podremos cifrar solamente estas líneas para protegerla una necesidad de hacerlo para todas, y de esa manera disminuirémos el costo de la contramedida "cifrado".

Tradicionalmente el concepto de información clasificada se aplicó a los documentos de papel, aunque los criterios y jerarquías nunca han sido más de dos. Con la tecnología de la información, el concepto ha cambiado, e incluso se ha perdido el control en entornos sensibles. Nace pues el concepto de ENTIDAD DE INFORMACIÓN como el objetivo a proteger en el entorno informático. y que la clasificación de la información nos ayudará a proteger especializando las contramedidas según el nivel de confidencialidad o importancia que tengan.

Esta metodología es del tipo cualitativo/subjetivo, y como el resto de la metodología PRIMA tiene listas de ayuda con el concepto abierto, esto es. que el profesional puede añadir en la herramienta niveles o jerarquías, colindares y objetivos a cumplir por nivel, y ayudas de contramedidas.

Ejemplos de Entidades de Información son: una pantalla, un listado, un archivo de datos, un archivo en un "streamer". una microficha de saldos, los sueldos de los directivos*, los datos de tipo "salud" en un archivo de personal, una transacción. un JO .. un editor, etc.

O sea los factores a considerar son los requerimientos legislativos, la sensibilidad a la divulgación (confidencialidad). a la modificación (integridad), y a la destrucción.

Las jerarquías suelen ser cuatro, y según se trate de óptica de preservación o de protección, los cuatro grupos serían: Vital-Crítica-Valuada-No sensible o bien Altamente confidencial-Confidencial-Restringida-No sensible.

PRIMA, aunque permite definirla a voluntad, básicamente define:

- * Estratégica (información muy restringida, muy confidencial, vital para la subsistencia de la empresa).
- Restringida (a los propietarios de la información).

- De uso interno (a todo* los empleados).
- De uso general (sin restricción).

Los pasos de la metodología son los siguientes:

1. IDENTIFICACIÓN DE LA INFORMACIÓN.
2. INVENTARIO DE ENTIDADES DE INFORMACIÓN RESIDENTES Y OPERATIVAS. Inventario de programas, archivos de datos, estructura de datos, topónimos de información, etc.
3. IDENTIFICACIÓN DE PROPIETARIOS. Son aquellos que necesitan para su trabajo, usan o custodian la información.
4. DEFINICIÓN DE JERARQUÍAS DE INFORMACIÓN. Suelen verse cuatro porque es difícil distinguir entre sus niveles.
5. DEFINICIÓN DE LA MATRIZ DE CLASIFICACIÓN. Esto consiste «en definir las políticas, estándares objetivos de control y contramedidas por unidad» y jerarquías de información.
6. CONFECCIÓN DE LA MATRIZ DE CLASIFICACIÓN. En la figura 3.12 se observa un ejemplo de matriz de clasificación en la que se relaciona cada entidad de información con los elementos que se correlacionan, como una transacción, archivos, soportes, propietarios, y jerarquía. En esta fase se complementa toda la matriz, asignándole a cada entidad un nivel de jerarquía lo que la asocia a una serie de hitos a cumplir según el punto anterior, para cuyo cumplimiento deberemos desarrollar acciones concretas en el punto siguiente.
7. REALIZACIÓN DEL PLAN DE ACCIONES. Se confecciona el plan detallado de acciones. Por ejemplo, se reforma una aplicación de nómina para que un empleado utilice el programa de subidas de salario y su supervisor lo apruebe.
8. IMPLANTACIÓN Y MANTENIMIENTO. Se implanta el plan de acciones y se mantiene actualizado.

Y así se completa esta metodología.

Obtención de los procedimientos de control

Otra metodología necesaria para la obtención de los controles* expresados en la figura 3.1, es "la Obtención de los Procedimientos de Control". Es frecuente encontrar manuales de procedimientos en todas las áreas de la empresa que explican las funciones y cómo se realizan las distintas tareas diariamente, siendo éstos útiles para que los auditores realicen sus revisiones operativas, evaluando si los procedimientos son correctos y están aprobados y sobre todo (i se cumplen

Pero podríamos preguntarnos si desde el punto de vista de control informático es suficiente y cómo se podrían mejorar.

La respuesta nos la da la metodología que se expone a continuación, que nos dará otro plan de acciones que tal como trata de expresar la figura 3.12. contribuirá a asignarse a los distintos proyectos de un plan de seguridad para mejorar el cumplimiento de contramedidas.

Metodología

Fase I. Definición de Objetivos de Control.

Se compone de tres fases

Tarea I. Análisis de la empresa. Se estudian los procesos, organigramas y funciones.

Tarea 2. Recopilación de exlindares. Se estudian tixlas las fuentes de información necesarias para conseguir definir en la siguiente fase ka obj«iv« de control a cumplir (por ejemplo. ISO. ITSEC. CISA. etc.).

Tarea.3. Definición de los Objetivos de Control.

Fase II. Definición de los Controles.

Tarea I. Definición de los Controles. Con los objetivos de control definido«, analizamos los procesos y vamos definiendo los distintos controle« qoe se necesiten.

Tarca 2. Definición de Necesidades Tecnológicas «hardware y herramientas de control).

Tarca 3. Definición de los Procedimientos de Control. Se desarrollan ku distintos procedimientos que se generan en las áreas usuaria«, informática, control informático y control no informático.

Tarca 4. Definición de las necesidades de recursos humanos.

Fase III. Implantación de los controles.

Una vez definidos los controles, las herramientas de control y los recurra humanos necesarios, no resta mis que implantarlos en forma de acciones específicas.

Terminado el proceso de implantación de acciones habrá que documentar kn procedimientos nuevos y revisar los afectados de cambio. Los procedimiento» resultantes serán:

- Procedimientos propios de control de la actividad informática (control interna informático).
- Procedimientos de distintas áreas usuarias de la informática, mejorados.
- Procedimientos de áreas informáticas, mejorados.
- Procedimientos de control dual entre control interno informática y el área informática, los usuarios informáticos, y el área de control no informático.

3.5.3. Las herramientas de control

Ya hemos hablado de (oda* las capas de la figura 3.1. excepto d:l último sub-
(rato de U pirámide, esto es. las herramientas de control. En la tecnología de la seguri-
dad informática que se ve envuelta en los controles, existe tecnología hardware (como
los cifradores) y software. Las herramientas de control son elemento* software que
por sus características funcionales permiten vertebrar un control de una manera más
actual y más automatizada. Pero no olvidenlos que la herramienta en <í misma no es
tuda. Ya hemos visto en el punto anterior que el control se define en todo un proceso
metodológico, y en un punto del mismo se analiza si existe una herramienta que
automatice o mejore el control para más tarde definir todo el control con la
herramienta incluida, y al final documentar los procedimientos de las distintas áreas
involucradas para que éstas: los cumplan y sean auditados. O sea. comprar una
herramienta sin más y ver qué podemos hacer con ella es. un error profesional grave,
que no conduce a nada, comparable a trabajar sin método c improvisando en cualquier
disciplina informática.

Las herramientas de control (software) más comunes son:

- Seguridad lógica del sistema.
- Seguridad lógica complementaria al sistema (desarrollado a medida).
- Seguridad lógica para entornos distribuidos.
- Control de acceso físico. Control de presencia.
- Control de copias.
- Gestión de sopones magnéticos.
- Gestión y control de impresión y envío de listados por red.
- Control de proyectos.
- Control de versiones.
- Control y gestión de incidencias.
- Control de cambios.
- Etc.

Todas estas herramientas están inmersas en controles nacidos de unos objetivos
de luviliul y que icyuUiáii la «sluotión Je la» distinta» ¿reo* ¡nvclucrada». Pbr
ejemplo, si el objetivo de control es "separación de entornos cntte desarrollo y
producción", habrá un procedimiento en desarrollo de "paso de aplicaciones a
explotación" y otro en explotación de "paso a explotación de ¡plicacionc* de
desarrollo". Soportado todo por una herramienta de control de acceso lógico que en
un proceso de clasificación ha definido distintos perfiles en desarrollo > explotación, y
tras implantarlo en la herramienta, impide acceder a uno y a otros al enoroq que no es
el suyo. Por tanto, para pasar una aplicación de uno a otro cuando está terminada, se
aecesita un procedimiento en el que intervengan las dos áreas y un control informático
que acula de llave. Esto que parece dificultoso, no lo es en la práctiica.

Sólo a modo de ejemplo pongamos ktt objetivos de control en el acceso lógico il igual que deberíamos ir haciendo en cada una de las herramientas de control anta enumeradas.

Objetóos de control de acceso lógico

- Segregación de funciones entre los usuarios del sistema: productores de software, jefes de proyecto (si existe un proceso metodológico asi), técnico* de sistemas, operadores de explotación, operadores de telecomunicaciones, gmpos de usuarios de aplicaciones (con perfiles definidos por la Clasificadla de la información), administrador de la seguridad lógica (en control dual al sa de alto riesgo), auditoría, y tantos como se designen.
- Integridad de los "log" c imposibilidad de desactivarlos por ningún perfil pun poder revisarlos. Fácilmente legibles c interpretables por control informático.
- Gestión centralizada de la seguridad o al menos única (por control infor-mático).
- Contrasefta tónica (a ser posible) para los distintos Sistemas de la red. Y b autenticación de entrad* una sola vez. Y una vez dentro, controlar lo» derechos de uso.
- luí contraseña y archivos con perfiles y derechos inaccesibles a todos, incluso a los administradores de seguridad
- El sistema debe rechazar a los usuarios que no usan la clave o los derechos de uso correctamente, inhabilitando y avisando a control, que tomara las medidas oportunas.
- Separación de entornos. Significa que los distintos usuarios pueden hacer solamente lo qué y cómo se ha autorizado que hagan para su función. Habrí tantos entornos como se precisen y el control tendrá que estar en situacióo normal como en emergencia y no entorpecer la operatoria.
- El log. o los log'*, de actividad no podrán desactivarse a voluntad, y si se dud¿ de su integridad o carencia, resolver con un terminal externo controlado.
- El sistema debe obligar al usuario a cambiar la coniraserta, de forma que sólo la conozca él. que es la única garantía de autenticidad de sus actos.

- Es frecuente encontrar mecanismos de *auto logout*, que expulsan del «Mema a la terminal que permanece inactiva más de un tiempo determinado, que son ayudas adicionales a la seguridad.

Muchos de estos objetivos se pueden sacar de los propios estándares (ISO. Libro Naranja. ITSEC. etc.).

Este ejemplo nos puede servir para introducir otra metodología del compendio PRIMA, utilizada para la implantación del control sobre los "Entornos distribuidos", verdadero reto de nuestros días.

Todo estaba controlado en los grandes sistemas en su nivel C2/E2 (no es mucho, pero suficiente para el nivel comercial, según los fabricantes). Y llega la proliferación de los entornos distribuidos... "el caos". ¿Está controlada la seguridad lógica en la actualidad? ¿Cada responsable de seguridad debe plantárselo! ¿Se cumple el marco jurídico sin seguridad lógica?

Se podría implantar el control de acceso lógico, sistema a sistema con los propios software de seguridad de cada uno de ellos, con un enorme esfuerzo de recursos humano* y complicada operativa. Podemos resolver mejor el problema adquiriendo e instalando un software de control de entornos distribuidos. ¿Pero qué hacer... cómo abordar el problema? ¿Ver mucho* productos y escoger uno? ¿Será lo mejor para el futuro? ¿Cómo están haciendo los demás?

La forma más apropiada de resolver este problema, hasta donde se pueda, es utilizar un método práctico que paso a desarrollar.

ANÁLISIS DE PLATAFORMAS. Se trata de inventariar las múltiples plataformas actuales y futuras (MVS. UNIX. AIX3.2.5.. TANDEN GUARDIAN D30. etc. que más tarde nos servirán para saber qué productos del mercado nos pueden servir*. tanto los productos actuales como los futuros planes que tengan los fabricantes.

CATÁLOGO DE REQUERIMIENTOS PREVIOS DE IMPLANTACIÓN. Desde el primer momento nace esta herramienta (control del proyecto), que inventaría lo que no se va a conseguir (limitaciones), así como lo necesario para la implantación, inventariado como acciones y proyecto*, calendarizados. y su duración para su seguimiento y desarrollo.

ANÁLISIS DE APLICACIONES. Se trata de inventariar las necesidades de desarrollar INTERFACES con los distintos software de seguridad de las aplicaciones y base* de datos. Estos desarrollos* deberían entrar en el catálogo de R.P.I. como proyectos a desarrollar. Por ejemplo: DB2. Oracle 7.1.6. SAP R/3.2.2, Clickpoint

Firewall-I. OFFICE 2.6. o la propia de Recursos Humanos, etc. Es importante la conexión a Recursos Humanos para que se detecten automáticamente la* alteraciones en los empleados (altas, bajas, cambios). También en este punto conviene ver si el producto ofrece interfaces soportan el tiempo real, o el proceso batch. o sus* posibilidades de registros de actividad.

INVENTARIO DE FUNCIONALIDADES Y PROPIETARIOS. En este punto trataremos todo el esquema de funcionalidades de la seguridad lógica actual. Es el momento de crear unas jerarquías de estándares a cumplir (clasificación de la información) y tratar de definir en ese momento los controles que se deberían tener, ya sea de usuario* de las aplicaciones como de los usuarios de los sistemas* y el uso de las herramientas.

Este punto es importante para ver si con el nuevo esquema de control al que vamos perdemos objetivos de control o nos salen acciones nuevas para el catálogo de R.P.I.S.

Es importante inventariar también en este punto la situación de la administración de la seguridad lógica en los distintos entornos y las características de las herramientas, « i como la operativa tanto de los usuarios de los distintos sistemas como de las distintas administraciones de seguridad y el control de *log o reporting*.

Todo este inventario nos servirá para hacer un análisis de mejora* y pérdidas o limitaciones en los nuevos escenarios con los* software de control de los entornos distribuidos*, según convenga para elegir el mejor en costo/beneficio.

ADMINISTRACIÓN DE LA SEGURIDAD. Se analizarán, de las distintas opciones del mercado, las* características de cada producto.

No olvidemos que se trata de conseguir que el escenario de los entornos distribuidos se pueda controlar como si de un computador con un solo control de acceso (véase la figura 3.14) se tratara. E incluso mejorando el nivel de control si se puede. Esto hará necesario un conjunto de software a instalar en cada plataforma, «mudo a una serie de interfaces en las plataformas que lo necesiten y que a los ritmos nos hará observar la seguridad lógica total como un todo.

En este punto nos interesa ver las siguientes funcionalidades y objetivos de control requeridos al nuevo sistema de control de acceso:

- ¿Permite el producto establecer un conjunto de reglas de control aplicables a todos los recursos del sistema?
- ¿Permite el producto al administrador de seguridad establecer un perfil de privilegios de acceso para un usuario o un grupo de usuarios?
- ¿Permite el producto al administrador de seguridad asignar diferentes administradores?
- ¿Permite el producto al administrador de seguridad asignar a estos administradores la posibilidad de gestionar privilegios de acceso para grupos y recursos definidos (por ejemplo, sistemas y aplicaciones)?
- ¿Permite a un administrador pedir acceso para el mismo, tanto como para cualquier usuario de su área de responsabilidad?
- ¿Impide el producto que un administrador se provea él mismo de sus propias peticiones?

Hay que recapitular todos los objetivos de control que se están demandando al conjunto de entornos, en lo referente a la administración de la seguridad, y saber con precisión cuál de las soluciones a analizar cumple mejor los requerimientos.

Es importante pensar en la conexión automática con la información del estado de los recursos humanos que componen el conjunto de usuarios para formatear compatibilidades por segregación de funciones marcadas por la clarificación de la información y por tener actualizadas las bajas/altas y períodos de ausencia del parque de usuarios.

Son muchos otros los aspectos que deben exigirse, como son que se pueda soportar más de un perfil en un usuario, o que se puedan definir perfiles de todo un departamento o puesto de trabajo, asignaciones temporales de los *backups* de cada empleado para períodos de ausencia del titular, que el perfil de un ingeniero no pueda acceder a una aplicación crítica, que se sincronicen *passwd* en todos los entornos, etc. En resumen, tantos cuantos objetivos de control se le exijan.

SINGLE SIGN ON. Este concepto podemos definirlo como: "Cue es necesario solamente un *password* y un *User ID*. para un usuario, para acceder y usar su

información y MIS recursos, de todos los sistemas como si <Je un solo enlomo K iraiara". Evidentemente a este concepto habría que añadir todos los conceptos w vinos en un control de acceso lógico (*time-out*. salvapanialUt. log. de.).

Además podríamos enumerar algunos de los requerimientos que se le pMkn a plataforma dentro de este apartado:

- Sobre qué soporta el producto el single Mg-on. ¿Windows 3.1. Windows NT. Windows 2000. Unix workstation. terminal 3270. un usuario reino<o entranfe a través de un servidor de acceso remoto?
- ¿El producto faculta al usuario de un recurso a acceder vía *single sif-ct* mientras otros usuarios acceden al mismo recurso directamente?
- ¿El producto encripta las transacciones del *single sig-on* entre la *ti-or/utatitoj* el servidor de seguridad?

FACILIDAD DE USO Y REPORTING. En este punto se valora la "interfaz* usuario" y la calidad de la misma (si tiene interfaz, gráfica, si tiene help mcniis. um para el usuario como para el administrador, si tiene mensajes de error, si easeA»d perfil de un determinado usuario al administrador, mensajes en las modificackna como "*are you sure?*~, mensajes a través de las aplicaciones, etc.).

Asimismo se evalúa el nivel de *reponing* para k» administradores y auditora **Así como:**

- ¿El producto ofrece un repon de todas las plataformas y aplicaciones a la* qu los usuarios tienen acceso, así como un repon de todos los usuarios que tiene» acceso a una plataforma o aplicación?
- ¿Un repon de todas las demandas que un administrador ha hecho, o en ua focha diada, o durante un período de tiempo, o a un centro de costo, o de toda las inactividades, o de todos los usuarios activos y privilegios de acceso de u centro de costo, o de demandas pendientes en orden de antigüedad de U demanda, o un repon de actividad, de las aplicaciones y sistemas (pa ejemplo, el número de demandas aceptadas, pendientes y rechazadas por cada sisMni)?
- ¿Un log de violaciones?

En cualquier caso todo registro debe tener garantizada su integridad incluso p»n los administradores, no pudiendo desactivarse a voluntad, dado que quien quiera haga algo "no permitido", lo primero que hará es asegurarse de que no quede constancia dd hecho.

SEGURIDADES. En este punto se trata de ver aspectos de seguridad clásico del propio producto, como que el administrador no vea las *passM-ord* de los usuarios una longitud de *pass*vrđ* mínima, que el producto requiera un ID y *passnvrđ* de

tagjod mínima para el acceso ni propio producto, el administrador pueda paralizar a en un periodo determinado, dual control en las funciones de riesgo (esto es. con un user IDes necesario una *first password* y una *second password* como acceso dual de dos administradores físicos), cifrado de *password*. privacidad en la propagación de *fcunord* en todo momento, acceso a los auditores para poder ver la ID databa.se. un registro de rechazos e intentos infructuosos, la posibilidad de *recovery y backup* incremental] de todo el sistema de seguridad, la posibilidad del *mirroring* de la database de seguridad para los planes de contingencias de conmutación en tiempo cero al centro alternativo, etc.

También facilidades especiales tales como que se pueda restringir el acceso a un curso local a un usuario.

Hemos de hacer notar que las limitaciones que vayamos encontrando para todos los productos, tendremos que resolverlas con exclusiones o procedimientos que estarán en el catálogo de R.P.I.'s, verdadero artífice de la metodología que nos permitirá a resolver las acciones antes de implantar el producto, y que será un control del proyecto durante su desarrollo.

ADQUISICIÓN, INSTALACIÓN E IMPLANTACIÓN. FORMACIÓN. MANUALES DE PROCEDIMIENTOS DE CONTROL. Tras los pasos anteriores. Queda más que comprar el producto e instalarlo, así como implantar el nuevo esquema de seguridad lógica. Y tras eso. dar la formación apropiada a los implicados y desarrollar los procedimientos de control, que generarán procedimientos operativos para los usuarios de aplicaciones, los usuarios informativos, y los administradores de seguridad lógica.

Todo este complejo proceso es vital hacerlo de modo ordenado y usando un método que permita en todo momento saber qué se "quiere" y qué se "puede" conseguir con los productos existentes de control de entorno, tratando de suplir con procedimientos de control los huecos que no podamos cubrir con tecnología. Aun así. el reto que tenemos por delante es importante, porque las soluciones que ofrecen los fabricantes van muy detrás frente a la proliferación de entornos y aplicaciones nuevos. y por eso una utilidad imprescindible de las soluciones propietarias de seguridad. hará que los fabricantes de soluciones para entornos distribuidos tengan productos de seguridad cada vez mejores, y que en vez de "adaptar el nivel de seguridad lógica a los productos, sean los productos los que resuelvan las situaciones nuevas de seguridad lógica".

3.6. CONCLUSIONES

Son muchas* pues las metodologías que se pueden encontrar en el mundo de la auditoría informática y control interno. Muchas hemos visto en este capítulo. Pasa como resumen se podría decir que la metodología es el fruto del nivel profesional* cada uno y de su visión de cómo conseguir un mejor resultado en el nivel de coherencia de cada entidad, aunque el nivel de control resultante debe ser similar.

Pero en realidad todas ellas son herramientas de trabajo mejores o peores *que* ayudan a conseguir mejores resultados. Sólo resta animar a los profesionales que lean este libro a trabajar con las únicas herramientas verdaderas de la auditoría y el control "LA ACTITUD y LA APTITUD", con una actitud vigilante y una formación continuada.

3.7. EJEMPLO DE METODOLOGÍA DE AUDITORÍA DE UNA APLICACIÓN

Metodología de trabajo

Revisión de controles sobre aplicaciones

Objetivo

Determinar que los sistemas producen informaciones exactas y completas en el momento oportuno. Esta área es tal vez la más importante en el trabajo de auditoría informática.

Programa de la revisión

1. Identificar el área a revisar (por ejemplo, a partir del calendario de revisiones notificar al responsable del área y prepararse utilizando papeles de trabajo de auditorías anteriores.
2. Identificar las informaciones necesarias para la auditoría y para las pruebas.
3. Obtener informaciones generales sobre el sistema. En esta etapa, se definen los objetivos y el alcance de la auditoría, y se identifican los usuarios específicos que estarían afectados por la auditoría (plan de entrevistas).

4. Obtener un conocimiento detallado de la aplicación/sistema. Se pisan las entrevistas con los usuarios y el personal implicado en el sistema a revisar, se examina la documentación de usuarios, de desarrollo y de operación, y se identifican los aspectos más importantes del sistema (entrada, tratamiento, salida de datos, etc.), la periodicidad de procesos, las programaciones, características y estructuras de archivos de datos, así como pistas de auditoría.
- J. Identificar los puntos de control críticos en el sistema. Utilizando organigramas de flujos de informaciones, identificar los puntos de control críticos en entrevistas con los usuarios con el apoyo de la documentación sobre el sistema. El auditor tiene que identificar los peligros y los riesgos que podrían surgir en cada punto. Los puntos de control críticos son aquellos donde el riesgo es más grave, es decir, donde la necesidad de un control es más importante. A menudo, son necesarios controles en los puntos de interfaz entre procedimientos manuales y automáticos.
6. Diseño y elaboración de los procedimientos de la auditoría.
7. Ejecución de pruebas en los puntos críticos de control. Se podría incluir la determinación de las necesidades de herramientas informativas de ayuda a la auditoría no informática. Se revisa el cumplimiento de los procedimientos para verificar el cumplimiento de los estándares y los procedimientos formales, así como los procesos descritos por los organigramas de flujos. Así se verifican los controles internos del cumplimiento de a) planes, políticas, procedimientos, estándares, b) del trabajo de la organización. c) requerimientos legales, d) principios generales de contabilidad y e) prácticas generales de informática.

Se hacen revisiones substantivas y pruebas, como resultado de la revisión del cumplimiento de procedimientos. Si las conclusiones de la revisión de cumplimiento fuesen generalmente positivas, se podrían limitar las revisiones substantivas. Dentro de este punto del programa de la revisión podríamos analizar si existen los siguientes controles:

Controles de preparación de datos

Revisar procedimientos escritos para iniciar, autorizar, recoger, preparar y probar los datos de entrada en la forma de un manual de usuario. Verificar que los usuarios entienden y siguen estos procedimientos.

Revisar que se dé la formación del "uso del terminal" necesaria a los usuarios.

Revisar los documentos fuente u otros documentos para determinar si son correctos.
También revisar códigos de identificación de transacciones y otros

campos de uso frecuentes para determinar si son codificados previamente para minimizar errores en los procesos de preparación, entrada y conversión de datos.

Cuando sea necesario, verificar que todos los datos de entrada en un sistema pasan por validación y registro antes de su tratamiento.

Determinar si los usuarios preparan totales de control de los datos de entrada por terminales. Comprobar la existencia de una reconciliación de los totales de entrada con totales de salida.

Comprobar la existencia y seguimiento de calendarios de entrada de datos y la distribución de informes (listados).

Determinar si el archivo y retención de documentos fuente y otros formularios de entrada es lógica y accesible, y cumple las normas y requerimientos legales.

Revisar los procedimientos de corrección de errores.

Comprobar la existencia de períodos de retención para documentos fuente y copias magnéticas.

Controles de entrada de datos

Establecer los procedimientos de entrada y control de datos que explican la revisión necesaria de entradas y salidas, con fecha límite, criterios de validación de datos de entrada: códigos, mensajes y detección de errores; la corrección de errores y la reentrada de datos.

Para sistemas interactivos, verificar el uso de métodos preventivos para evitar la entrada incorrecta de datos: funciones de ayuda a la pantalla, formatos fijos, el uso de menús y mensajes para el operador.

Para sistemas interactivos, determinar la grabación de datos de entrada con fecha y hora actual, así como con una identificación del usuario/terminal y ubicación.

Revisar logs de acceso por líneas de telecomunicaciones para determinar posibles accesos y entradas no autorizados.

Revisar los programas para determinar si contienen procesos internos de validación de datos (por ejemplo, chequeos de dígitos, tests razonables, totales de batch, número de cuentas, etc.). Evaluar su exactitud.

Comparar, validar, apuntar y recalcular campos o elementos de datos crítico* por todos manuales o automáticos.

Para sistemas interactivos determinar que los datos se verifican en el momento de entrada en el sistema.

Comprobar que los usuarios revisan regularmente las tablas internas del sistema para validar sus contenidos.

Revisar funciones matemáticas que redondean cálculos para ver si tienen aplicaciones negativas.

Determinar que existen pistas de auditoría adecuadas en el diccionario de datos. Unificar la interrelación entre los programas y los datos para dejar la posibilidad de seguir la pista de datos dentro de programas y sistemas en los errores.

Revivar los procedimientos de corrección de errores.

Identificar con los usuarios cualquier código de errores críticos que deberían aparecer en momentos específicos pero que nunca surgen. ¿Se han desactivado los códigos o mensajes de error?

Centros de tratamiento y actualización de datos

Ver si hay establecidos controles internos automatizados de proceso. Tales como rutinas de validación, en el momento de la actualización de los archivos de transacción, referencia y maestros.

Identificación de transacciones por el uso de números de lote, códigos de transacción y otros indicadores.

Revisión del log de transacciones para identificar problemas encontrados* por el operador y las medidas seguidas*.

Restricción de la posibilidad de pasar por encima de procesos de validación.

Aceptación por los usuarios finales de todas las transacciones y cálculo* de la aplicación.

Revisar los totales de control de entrada de datos*.

Verificar que exiuen total« de control para confirmar la buena interfaz entre jeto Oprogramas.

Comprobar que existen validación« entre totales de control, manual« j automático«, en punios de ta interfaz entre procesos manuales y automatizados.

Verificar que lo* log's de actividad de sistemas son revisados por la responsables, para investigar accesos y manipulaciones no autorizados.

Ver los controles sobre la entrada de datos.

Controles de salida de dato i

Determinar si los usuarios comparan te*ales de control de los datos de entrada cco totales de control de dalos de salida.

Determinar si el control de datos revisa los informes de salida (lisiados) pwi delectar errores evidentes tales como campos de datos que fallan, valores se razonables o formatos incorrectos.

Verificar que se hace una identificación adecuada sobre los informes, pœ ejemplo, nombre y número de informe, fecha de salida, nombre de área/departamento, etc.

Comparar la lista de distribución de informes con tos usuarios que los reciben et realidad. ¿Hay personas que reciben el informe y que no deberían recibirlo?

Verificar que los informes que pasan de aplicabilidad se destruyen, y que no pasan simplemente a la basura, sin seguridad de destrucción.

Revisar la justificación de informes, que existe una petición escrita para cada un» y que se utilizan realmente, asf como que está autorizada la petición.

Verificar la existencia de periodos de retención de informes y su suficiencia.

Revisar los procedimientos de corrección de los dalos de salida.

Controles de documentación

Verificar que dentro de las actividades de desarrollo y mantenimiento de aplicaciones se produce la documentación de sistemas, programas, operaciones y funciones, y procedimientos de usuario.

Existencia de una persona específica encargada de la documentación y que mantiene un archivo de documento* ya distribuidos y a quiénes.

Comprobar que los jefes de área se informen de fallas de documentación adecuada para sus empleados.

Dstrucción de toda la documentación de antiguos sistemas.

Que no se acepten nuevas aplicaciones por los usuarios sin una documentación completa.

Actualización de la documentación al mismo tiempo que los cambios y modificaciones en los sistemas.

La existencia de documentación de sistemas, de programas, de operación y de osario para cada aplicación ya implantada.

Controles de backup y rearranque

Existencia de procedimientos de *backup* y rearranque documentados y ceoprohados para cada aplicación en uso actualmente. (No confundir con el plan de aaungenctav)

Procedimientos escritos para la transferencia de materiales y documentos de *búctup* entre el C.P.D. principal y el sitio de *backup* (centro alternativo). Mantenimiento de un inventario de estos materiales.

Existencia de un plan de contingencia.

Identificación de aplicaciones y archivos de datos critico« para el plan de coaóngencia.

Revisar los contratos del plan de contingencia y *backup* pora determinar mi adecoactón y actualización.

Pruebas de aplicaciones críticas en el entorno de *backup*. con los materiales del pUnde contingencia (soportes magnéticos, documentación, personal, etc.).

Exterminación de qué se revisa, si cada aplicación de un sistema es crítica y si debería incluirse en el plan de contingencia.

Grabación de todas las transacciones ejecutadas por teicproceso. cada día; pan facilitar la reconstrucción de archivos actualizados durante el día en caso del fallo dd sistema.

Existencia de procesos manuales pora sistemas críticos en el caso del fallo de contingencia.

Actualización del plan de contingencia cuando es necesario: pruebas anuales.

Controles sobre programas de auditoria

Distribución de políticas y procedimientos escritos a auditores y responsable! de ¿reas sobre la adquisición, desarrollo y uso de software de auditoria.

Uso de software de auditoría únicamente por personas autorizadas.

Participación del auditor en la adquisición, modificación/adaptación, instalaos de paquetes de software de auditoría.

Participación del auditor en la planificación, diseño, desarrollo e implantackb de software de auditoría desarrollado internamente.

Formación apropiada para los auditores que manejan software de auditoría.

Participación del auditor en todas las modificaciones y adaptaciones del tofraat de auditoría, ya sea externo o de desarrollo propio. Actualización de k documentación de software.

Verificación de que los programas de utilidad se utilizan correctamente (cusid» no se puede utilizar el software de auditoría).

Revisión de tablas de contraseñas pora augurar que no se guinia identificaciones y contraseñas de personas que han causado baja.

Controles de la satisfacción de los usuarios

Disponibilidad de políticas y procedimientos sobre el acceso y uso de k información.

Resultados fiables, completos, puntuales y exactos de las aplicaciones (imecgnAd dédalos).

Utilidad de la información de salida de la aplicación en la toma de decisión por los **«Marios»**.

Comprensión por los usuarios de los informes e informaciones de salida de las aplicaciones.

Satisfacción de los usuarios con la información que produce la aplicación.

Revisión de los controles de recepción, archivo, protección y acceso de datos guardados sobre todo tipo de soporte.

Participación activa de los usuarios en la elaboración de requerimientos de «sanos, especificaciones de diseño de programas y revisión de resultados de pruebas.

Controles por el usuario en la transferencia de informaciones por intercambio de documento».

Resolución fácil de problemas, errores, irregularidades y omisiones por buenos contactos entre usuarios y el personal del C.P.D.

Revisiones regulares de procesos que podrían mejorarse por automatización de aspectos particulares o reformamientos de procesos manuales

Evaluación de la revisión y/o resultados de pruebas. En esta etapa se identifican y se evalúan los puntos fuertes y débiles de los procedimientos y prácticas de control interno en relación con su adecuación, eficiencia y efectividad. Cuando se identifique una debilidad, se determinará su causa.

Se elaboran las conclusiones basadas sobre la evidencia; lo que deberá ser suficiente, relevante, fiable, disponible, comprobable y útil.

Preparación del informe. Recomendaciones.

Informe previo

Para mantener una relación buena con el área revisada, se emite un informe previo de los puntos principales de la revisión. Esto da a los responsables del área revisada la posibilidad de contribuir a la elaboración del informe final y permitirá una mejor aceptación por parte de ellos.

Informe final de la revisión

Se emite el informe final después de una reunión con los responsables del área implicados en la revisión. El contenido del informe debería describir los puntos de control interno de la manera siguiente:

- Opinión global (conclusión).
- Problema(s) específico(s).
- Explicación de la violación de los controles internos, planes organizacionales, estándares y normas.
- Descripción de los riesgos, exposición o pérdidas que resultarían de las violaciones.

Cuando sea posible, se identificará el impacto de cada problema en términos económicos. Se da una solución específica y práctica para cada debilidad. Se identificarán las personas que se responsabilizarán de cada aspecto de las soluciones. Las recomendaciones son razonables, verificables, interesantes económicamente y tienen en cuenta el tamaño de la organización.

El informe debe tener un tono constructivo. Si es apropiado se anotan los puntos fuertes.

Para su distribución, se preparará un resumen del informe.

Después de la revisión del informe final con los responsables del área revisada, se distribuirá a las otras personas autorizadas.

El área auditada tiene la posibilidad de aceptar o rechazar cada punto de control. Todos los puntos rechazados se explicarán por escrito. El área acepta los riesgos implícitos de la debilidad encontrada por el auditor.

Se hace un seguimiento de la implantación de las recomendaciones para asegurarse de que el trabajo de revisión produce resultados concretos.

38. LECTURAS RECOMENDADAS

- Jim« A. Schweitzer. *Managing Information Security* (Administrative, Electronic, and Legal Measures io Project Business Information). Buttervorths. ISBN 0-409-90195-4.
- J. M. l-anvetc. *La Seguridad Informática* (Metodología). Ediciones Arcadia. ISBN 84-86299-13-6.
- J. M. Lamere. *La securité des petits et moyens systèmes informatiques*. Dunod informatique. ISBN 2-04-018721-9.
- i. M. Lamere. Y. l-eroux, J. Orly. *La securité des rescata* (Methode* et techniques). Dunod informatique. ISBN 2-01-018886-X.

39. CUESTIONES DE REPASO

1. ¿Qué diferencias y similitud» existen entre las metodologías cualitativas y las cuantitativas? ¿Qué ventajas y qué inconvenientes tienen?
2. ¿Cuáles son los componentes de una contramedida o control ipirimide de la seguridad)? ¿Qué papel desempeñan las herramientas de control? ¿Cuáles son las herramientas de control mis frecuentes?
3. ¿Qué tipos de metodologías de Plan de Contingencias existen? ¿En qué se diferencian? ¿Qué es un Plan de Contingencias?
4. ¿Qué metodologías de auditoría informática existen? ¿Pata qué se usa cada una?
5. ¿Qué es el nivel de exposición y para qué sirve?
6. ¿Qué diferencias existen entre las figuras de auditoría infonrática y control interno informático? ¿Cuáles son las funciones más importan!« de éste?
7. ¿Cuáles son las dos metodologías más importantes para control interno informático? ¿Para qué sirve cada una?
8. ¿Qué papel tienen las herramientas de control en los controles?
9. ¿Cuáles son los objetivos de control en el acceso lógico?
10. ¿Qué es el *Single Sign On*? ¿Por qué es necesario un software especial para el control de acceso en los entornos distribuidos?

CAPÍTULO 4

EL INFORME DE AUDITORÍA

José de la Peña Sánchez

11 INTRODUCCIÓN

El tema de este capítulo es el Informe de Auditoría Informática, que a su vez es el objetivo de la Auditoría Informática.

Para comprender ésta, en función del Informe que realiza un, digamos, experto o perito -al que llamaremos Auditor Informático-, conviene explicar sonoramente el contexto en el que se desenvuelve hoy su práctica.

La sociedad actual, está en fase tecnológica; apenas guarda recuerdo práctico de etapas evolutivas (la artesanal, por ejemplo): más aún. las va olvidando a atónita velocidad, generación tras generación.

El dominio de la tecnología como motor de cambio social acelerado y como catalizador de cambios tecnológicos que se superponen, se hace ruidosamente evidente en las llamadas Tecnologías de Información y Comunicaciones de uso en las «situaciones». (Tras el mainframe y los terminales tontos, surgieron los PC's y las redes, el EDI, los entornos distribuidos, las arquitecturas cliente-servidor, las redes TCP/IP -intranet*, extrañéis, redes privadas virtuales...-, los accesos remotos y móviles mediante portátiles y teléfonos móviles, y, finalmente -por ahora-, se nos proponen terminales domésticos vinculados con el equipo de televisión y terminales inteligentes de trabajo conectados a servidores dominantes descentralizados... Y todo « en un período no superior a ¡treinta y cinco años!)

Está claro: las tecnologías de la información, al tiempo que dominan de modo irrefragable las relaciones humanas (personales, familiares, mercantiles, institucionales...). tienen un ciclo de vida cada vez más corto.

Sea como fuere, una «Je las consecuencia» «Je lo dicho consiste en la difiailuli: asimilación rápida y equilibrada en la empresa de lo» enlomo» tecnológico y á organización (referido el primero a la» Tecnología.» de Información y Comunicaciones y el segundo a lo mercantil).

En este »emido. el Auditor Informático, en tanto que experto, k) tiene erais (menos. sin embargo, que el Auditor de Cuenta»), al tener que eneirx profestonalmcntc y en el paisaje que estoy presentando, plagado de necesidades di reciclaje y formación, el llamado "desfase entre las expectativa.» de los usuario»; los Informes de auditoría". l)» cosa» ya no son como eran, y algo habrá que haga para encontrar un punto de equilibrio razonable entre el desfase mencionado y U contabilidad de lo» usuarios en el Informe (y en el Auditor Informático).

La complejidad de los sistemas de información crece con sus prestación« j características (conectividad. portabilidad...); la necesidad de utilizarlos que tienen U organizaciones -públicas y privadas- en todos sus ámbitos, alcanza hoy un valer estratégico de competitividad y supervivencia... Podemos afirmar que nunca aata hemos sido tan dependientes de los sistemas de información. Y nunca antes herna necesitado tanto a expertos eficientes (no infalibles) en Auditoría Informática.

Conviene mencionar, al respecto de la práctica de la Auditoría (Informática),; siempre en función del Informe de Auditoría, la existencia del fraude y del error, sota todo si son significativos, así como la valoración de las garantías que aportan los informe» de los auditores informáticos a los usuarios, incluyendo gobiernos y organizaciones nacionales e internacionales.

La Informática es muy joven; por tanto, la Auditoría Informática lo es más (a España, por cierto. »Je modo superlativo). No está todo sin hacer, pero sí queda muchos cabos por alar, y en esto el tiempo no es neutral.

En este capítulo (y en este contexto) vamos a tratar de fijar la práctica de la Auditoría Informática en función, como queda dicho, del Informe. Paraello. repasaremos someramente aspectos previos fundamentales, como son las normas, el concepto de evidencia en auditoría, las Irregularidades, los papdes de trabajo o documentacka para, finalmente, encarar el Informe, sus componentes, características y tendencia detectada.' Intentaremos, tamban, ofrecer algunas conclusiones de interés, sin perder de vista en todo caso que en el mundo auditor de hoy todo ejercicio de predicción es. en principio, una temeridad.

42. LAS NORMAS

En 1996 la Unión Europea publicó el Libro Verde de la Auditoría, dedicado al papel, la posición y la responsabilidad del auditor legal. Su contenido afecta a la Auditoría Informática.

En principio, el Libro acepta las Normas Internacionales IFAC para su adaptación adecuada a la Unión Europea: por tanto, se transmitirán a través de las Directivas correspondientes a España para que se transformen en legislación positiva.

En lo referente al Tratamiento Automatizado de Datos de Carácter Personal -incluso disponiendo de una Ley orgánica-, el asunto se resolverá por los mismos medios, con la trasposición de la actual Directiva de protección de datos personales y, quizá, de otra, en forma de propuesta todavía, relacionada con los servicios de telecomunicaciones* apoyados en tecnología digital y especialmente Red Digital de Servicios Integrados.

Otra fuente de Normas Internacionales es ISACA, ya más específica de Auditoría Informática. Nuestro país está representado en ISACA por la Organización de Auditoría Informática, en pleno *take off*.

Hoy por hoy, la normativa española oficial que afecta, en mayor o menor medida, a la Auditoría Informática, es la siguiente:

- ICAC: Normas Técnicas de Auditoría: punto 2.4.10. Estudio y Evaluación del Sistema de Control Interno.
- AGENCIA DE PROTECCIÓN DE DATOS: Instrucción relativa a la prestación de servicios sobre solvencia patrimonial y créditos. Norma cuantitativa: Forma de Comprobación.

Del artículo 9 de la LORTAD se desprende el desarrollo reglamentario de medidas técnicas y organizativas alusivas a la seguridad en lo que concierne a integridad y confidencialidad de los datos personales automatizados. Todavía no ha sido publicado el reglamento, pero sería de esperar que se incluyera en su texto alguna referencia específica sobre Auditoría Informática.

También conviene reseñar que dentro de la Unión Europea, la FEE tiene en marcha el Proyecto EDIFICAS.EUROPE, dentro del UN/EDIFACT, en el que España está representada por el IACJCE, que se estructura en cuatro grupos de trabajo: Masajes, Auditoría (Guías de Auditoría de entornos de EDI), Promoción y Asuntos Energéticos.

La Auditoría Informática no está muy desarrollada y, por añadidura, se encuentra en un punto crucial para la definición del modelo en que deberá implantarse y practicarse en la Unión Europea y, por tanto, España, vía directivas UE/legislación positiva y normas profesionales.

Maticemos este aspecto: hay dos tendencias legislativas y de práctica y disciplinas: la anglosajona, basada en la *Common Law*, con pocas leyes y jurisprudencia relevante; y la latina, basada en el Derecho Romano, de legislación muy detallada.

La tensión entre estos dos modelos, esto es, entre el intervencionismo más latino y el mínimo intervencionismo anglosajón, es ya insostenible. Uno de los dos deberá prevalecer, si es que realmente nos encaminamos a la sociedad global.

Justo es reconocer que los parámetros del cambio tecnológico parecen hacer más práctico el modelo anglosajón: no en vano, en Estados Unidos, tanto la Auditoría como la Informática (y las Comunicaciones), tienen un desarrollo muy experimental y, sobre todo, adaptativo. Los parámetros de velocidad y tiempo hacen aconsejable un esfuerzo por conseguir la disponibilidad armonizada de normas legales y normas de origen profesional.

Si la globalización antes mencionada es un hecho incuestionable, el sabio uso de los llamados *principios generalmente aceptados* hará posible la adaptación suficiente a la realidad de cada época.

En este sentido, no podemos olvidar que los organismos de armonización, normalización, homologación, acreditación y certificación tendrán que funcionar a un ritmo más acorde con las necesidades cambiantes. El conjunto ISO-CEN-AFNOR; los vinculados con seguridad, ITSEC/ITSEM Europa, TCSEC USA y Contraintensidad Criterio UE/Norteamérica, necesitan ir más rápido, ya que su lentitud está provocando, en un mundo tan acelerado, la aparición de multitud de organizaciones privadas, consorcios y asociaciones que con muy buena voluntad y óptimo sentido de la conveniencia mercantil, pretenden unificar normas y proinocular estándares.

Por último, conviene que se clarifique el panorama normativo, de prácticas; responsabilidades en lo que concierne a los problemas planteados por los servicios profesionales multidisciplinarios, ya que el Informe de Auditoría Informática se compone de tres términos: Informática, Auditoría e Informe.

4.3. LA EVIDENCIA

En c*lc epígrafe parece saludable revertir algunos aMinios previo*, referidos a la redxción del Informe. Iraudos en otros capítulo* de esta obra, puesto que el referido (sfanne « su consecuencia.

Por tanto, tratemos de recordar en qui consiste la evidencia en Auditoria híormítica. así como las pruebas que la avalan, sin olvidar la importatela relativa y el riesgo probable, inherente y de control.

La certeza absoluta no siempre existe, según el punto de vista de los auditores; los ísmrios piensan lo contrario. No obstante lo dicho, el desarrollo del control interno, incteso del específicamente informático, está en efervescencia, gracias al empuje de b» Informes USA/Treadway (1987). UK/Cadbury (1992) y Francia/Yienot (1995). y ca lugar destacado el USA/COSO (1992). traducido al espa/iol *for* Coopers & Lybrand y el Instituto de Auditores Internos de Esparta.

Pero volvamos a la evidencia, porque ella es la base razonable d: la opinión del Auditor Informático. e«o es. el Informe de Auditoria Informática.

La evidencia tiene una serie de calificativos; a saber:

- La evidencia relevante, que tiene una relación lógica con los objetivos de la auditoria.
- La evidencia fiable, que es válida y objetiva, aunque con nivel de confianza.
- La evidencia suficiente, que es de tipo cuantitativo para soportar la opinión profesional del auditor.
- La evidencia adecuada, que es de tipo cualitativo parí afectar a las conclusiones del auditor.

En principio, tu» prueba:, MUI de cumplimiento o RUstflniivw.

Aunque ya tratado en otro capítulo, conviene recordar el escolla práctico de la Importancia relativa o materialidad, así como el riesgo probable.

La opinión deberá estar basada en evidencias justificativas, ex decir, desprovistas de prejuicios, si es preciso con evidencia adicional.

Es momento adecuado de separar lo significativo de lo no significativa debidamente evaluados por su importancia > vinculación con el factor riesgo, tarea eminentemente de carácter profesional y ético, según el leal saber y entender del Auditor Informático.

Aunque no existe un formato vinculante, sí existen esquemas recomendados con los requisitos mínimos aconsejables respecto a estructura y contenido.

También es cuestión previa decidir si el informe es largo o, por el contrario, corto, por supuesto con otros informes sobre aspectos, bien más detallados, bien más concretos, como el Informe de debilidades del control interno, incluso de hechos» aspectos: todo ello teniendo en cuenta tanto la legislación vigente como el contrato con el cliente.

En mi modesta opinión, los términos cliente o proveedor/interno o externo», típicos de la Gestión de la Calidad, resultan más apropiados que informático/auditor informático/usuario, ya que este último término tiene una lamentable connotación peyorativa.

En lo referente a su redacción, el Informe deberá ser claro, adecuado, suficiente) comprensible. Una utilización apropiada del lenguaje informático resulta recomendable.

Los puntos esenciales, genéricos y mínimos del Informe de Auditoría Informática, son los siguientes:

1. Identificación del Informe

El título del Informe deberá identificarse con objeto de distinguirlo de otros informes.

2. Identificación del Cliente

Deberá identificarse a los destinatarios y a las personas que efectúen el encargo.

3. Identificación de la entidad auditada

Identificación de la entidad objeto de la Auditoría Informática.